

# Daily Vulnerability Report - 2026-09-25

Window (UTC): 2026-09-24T05:26 to 2026-09-25T05:26 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-25 05:27:23 UTC

| Total | New | Updated | KEV added | KEV | Critical | High | Medium | Unscored | Watchlist |
|-------|-----|---------|-----------|-----|----------|------|--------|----------|-----------|
| 632   | 593 | 37      | 2         | 2   | 31       | 192  | 141    | 250      | 258       |

## New today - published in this report window

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package                              | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|---------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-61732</a> | New    | 10.0 | CRIT |     |       | pip:decepticon, pip:decepticon-core, pip:decepticon-sdk | Decepticon is an autonomous hacking agent for red teams. Versions prior to 1.1.17 wrap web crawl results — the output of agent reconnaissance against target services — into LLM messages without neutralizing ChatML special-token literals. Under the BYOK (Bring Your Own Key) deployment model, users configure their own LLM credentials to any OpenAI-compatible endpoint. Most ope... |
| <a href="#">CVE-2026-97359</a> | New    | 10.0 | CRIT |     |       |                                                         | HFS2 version 2.4.0 and earlier contains a template injection vulnerability in the multipart upload handler that allows unauthenticated attackers to achieve remote code execution by embedding malicious template syntax in a filename. Attackers can craft a filename containing a closing template quoting sequence followed by an exec macro, which bypasses the authorization check i... |
| <a href="#">CVE-2026-97360</a> | New    | 10.0 | CRIT |     |       |                                                         | HFS2 version 2.4.0 and earlier contains an unauthenticated arbitrary file access vulnerability that allows unauthenticated attackers to read, write, append, and delete files anywhere the HFS service account has filesystem access outside the shared folder. Attackers can exploit the macro dispatcher's lack of authorization model combined with the path resolver's failure to con... |
| <a href="#">CVE-2026-19072</a> | New    | 9.9  | CRIT |     |       |                                                         | Velociraptor stores the compiled VQL in the hunt object internally to avoid having to recompile the artifacts for each endpoint in the hunt. Although the field "compiled_collector_args" is an internal field, Velociraptor allowed the field to be set from a user API call. This allows another user who can schedule a hunt (minimal role of "investigator" ) to set the compiled VQL... |
| <a href="#">CVE-2026-93425</a> | New    | 9.9  | CRIT |     |       |                                                         | Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the patch.readRepoDirectories tRPC procedure passes the user-controlled repoPath value from apps/dokploy/server/api/routers/patch.ts into a shell command in packages/server/src/services/patch-repo.ts without safe argument quoting. An authenticated organization member with service:read permission... |
| <a href="#">CVE-2026-12227</a> | New    | 9.8  | CRIT |     | 0.008 |                                                         | The Visual Composer Website Builder plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 45.16.0 via the `vcv-template` parameter. This makes it possible for unauthenticated attackers to include and execute arbitrary files on the server, allowing the execution of any PHP code in those files. This can be used to bypass access contro... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package                                                                                               | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|--------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-13249</a> | New    | 9.8  | CRIT |     |       |                                                                                                                          | An unauthenticated Remote Code Execution via Arbitrary File Upload vulnerability in the web management interface in Honeywell PD45 Industrial Printer version F10.19.010040, allows upload of attacker controlled files without requiring authentication. An attacker could potentially exploit this vulnerability, leading to the execution of malicious files and commands. Honeywell...    |
| <a href="#">CVE-2026-78308</a> | New    | 9.8  | CRIT |     | 0.003 |                                                                                                                          | Improper Authentication vulnerability in DIAEnergie allows Authentication Bypass. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                          |
| <a href="#">CVE-2026-93207</a> | New    | 9.8  | CRIT |     |       |                                                                                                                          | In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Zero rpc_gss_wire_cred at svcauth_gss_decode_credbody() entry<br>svcauth_gss_decode_credbody() writes the caller's rpc_gss_wire_cred field by field and assigns gc_ctx.len only on the success tail. The caller storage is svcddata->clcred, which lives in the per-svc_rqst gss_svc_data and is reused across... |
| <a href="#">CVE-2026-97413</a> | New    | 9.8  | CRIT |     |       |                                                                                                                          | In the Linux kernel, the following vulnerability has been resolved: RDMA/rtrs-srv: Fix integer underflow in process_read and process_write usr_len is read from a network-supplied message field (le16_to_cpu) and used to compute data_len = off - usr_len without validating that usr_len <= off. A malicious RDMA client can send usr_len > off causing an integer underflow, result...    |
| <a href="#">CVE-2026-81549</a> | New    | 9.6  | CRIT |     |       |                                                                                                                          | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of the X-Forwarded-Proto header.                                                                                                                                                                                                           |
| <a href="#">CVE-2026-13016</a> | New    | 9.3  | CRIT |     |       |                                                                                                                          | ServiceNow has remediated a SQL injection vulnerability that was identified in the ServiceNow AI Platform. This vulnerability could enable an unauthenticated user, in certain circumstances, to execute arbitrary SQL statements against the instance's underlying database and gain access to, or modify, instance data beyond what was intended. ServiceNow deployed a security ...        |
| <a href="#">CVE-2026-61604</a> | New    | 9.3  | CRIT |     |       | go:github.com/ixofoundation/ixo-blockchain, go:github.com/ixofoundation/ixo-blockchain/v3, go:github.com/ixofoundation/i | The ixo Blockchain is a Layer 1 blockchain that runs on both Testnet and Mainnet. Prior to version 8.0.0, the x/bonds module moved funds from an address that was resolved from a DID verification method, without verifying that the resolved address belonged to the transaction signer. Affected handlers included MsgMakeOutcomePayment, MsgBuy, MsgSell, MsgSwap, and MsgWithdrawSha...  |
| <a href="#">CVE-2026-61741</a> | New    | 9.3  | CRIT |     |       | maven:org.http4s:http4s-scala-xml_2.12, maven:org.http4s:http4s-scala-xml_2.13, maven:org.http4s:http4s-scala-xml_3      | http4s-scala-xml provides `EntityDecoder[F, scala.xml.Elem]` instances that parse XML message bodies. Prior to versions 0.24.1 and 1.0.0-M39, these decoders used a `javax.xml.parsers.SAXParserFactory` obtained from `SAXParserFactory.newInstance` without any security configuration. With the JDK's default settings, the parser resolves DOCTYPE declarations, external general an...   |
| <a href="#">CVE-2026-61742</a> | New    | 9.3  | CRIT |     |       | npm:@bytebase/dbhub                                                                                                      | DBHub is a database MCP server for Postgres, MySQL, SQL Server, Oracle, MariaDB, SQLite. Versions prior to 0.22.5 expose an unauthenticated HTTP MCP endpoint when started with the documented HTTP transport mode, for example `--transport http --port 8080`. The HTTP server attempts to protect browser-origin access by checking whether the `Origin` hostname equals the `Host` hos...  |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-86860</a> | New    | 9.3  | CRIT |     |       |                            | ServiceNow has remediated a missing authorization vulnerability that was identified in the ServiceNow AI Platform. This vulnerability could enable an unauthenticated user, in certain circumstances, to extract instance data beyond what was intended, resulting in privilege escalation. ServiceNow deployed a security update to hosted instances and ServiceNow provided the up...      |
| <a href="#">CVE-2026-91187</a> | New    | 9.3  | CRIT |     |       |                            | Improper Verification of Cryptographic Signature vulnerability in dashbit nimble_zta allows an unauthenticated remote attacker to authenticate as an arbitrary Cloudflare service token. Applications using the Cloudflare Zero Trust authentication strategy are affected. verify_token/2 in lib/nimble_zta/cloudflare.ex matches the result of JOSE.JWT.verify/2 against {_, token, _s...  |
| <a href="#">CVE-2026-93291</a> | New    | 9.3  | CRIT |     |       |                            | Omni C20 lacks proper certificate validation which could allow an attacker to perform a man-in-the-middle attack which could allow them to execute arbitrary code.                                                                                                                                                                                                                           |
| <a href="#">CVE-2026-81630</a> | New    | 9.2  | CRIT |     |       |                            | The Botslab G980H dash camera firmware does not adequately verify the authenticity of firmware updates. The update process retrieves firmware through an unprotected connection and relies on an integrity value supplied with the firmware instead of a trusted cryptographic signature. A suitably positioned attacker who intercepts a firmware download, or an authenticated attacker... |
| <a href="#">CVE-2026-90481</a> | New    | 9.2  | CRIT |     |       |                            | In PortSwigger Burp Suite DAST (formerly Burp Suite Enterprise Edition) before 2026.8, an authentication bypass can occur via an alternate path or channel.                                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-97404</a> | New    | 9.2  | CRIT |     |       |                            | In OpenStack Zaqr before 22.0.2, WSGI transport mishandles the URL-Signature header. By sending a request with an empty URL-Signature header, an unauthenticated remote attacker who knows a target project's UUID may bypass both Keystone authentication and pre-signed URL verification, resulting in the ability to read, enumerate, create, and delete that project's queues, messa...  |
| <a href="#">CVE-2026-78312</a> | New    | 9.1  | CRIT |     | 0.003 |                            | Path Traversal in DIAEnergie. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                                                                             |
| <a href="#">CVE-2026-79766</a> | New    | 9.1  | CRIT |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 2.4.1 until 2.5.1, an authenticated Termix administrator can store attacker-controlled domain and email values through PATCH /users/acme-ssl-settings and trigger their interpolation into a certbot shell command through POST /users/acme-ssl-request. In src/backen... |
| <a href="#">CVE-2026-93228</a> | New    | 9.1  | CRIT |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject Write/Reply chunks with segcount 0 A peer can send a Write or Reply chunk whose segcount field is zero. xdr_check_write_chunk() only rejects segcount > rc_maxpages, so zero passes the range check, and xdr_inline_decode(stream, 0) returns the current (non-NULL) cursor without advancing. The ...   |
| <a href="#">CVE-2026-93289</a> | New    | 9.0  | CRIT |     |       |                            | The affected products are vulnerable to command injection attack that could allow an unauthenticated attacker to execute system commands during the pairing process.                                                                                                                                                                                                                         |
| <a href="#">CVE-2026-94606</a> | New    | 8.9  | HIGH |     |       |                            | authentik is an open-source identity provider. Prior to 2026.2.7, 2026.5.7, and 2026.8.2, authentik email authenticator enrollment during an authentication or enrollment flow accepts a recipient address supplied in the setup request instead of using the address already established by the flow. An actor who knows a target user's password can substitute an attacker-controlled ... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-13248</a> | New    | 8.8  | HIGH |     |       |                            | An Authenticated Remote Code Execution via Arbitrary File Write in the Intermec Fingerprint Command Interface vulnerability in the web management interface in Honeywell PD45 Industrial Printer version F10.19.010040, allows an authenticated user with access to the admin or itadmin account to submit commands written in the Intermec Fingerprint programming language directly to ...  |
| <a href="#">CVE-2026-78309</a> | New    | 8.8  | HIGH |     | 0.002 |                            | SQL Injection vulnerability in DIAEnergie. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-78311</a> | New    | 8.8  | HIGH |     | 0.002 |                            | SQL Injection vulnerability in DIAEnergie. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-81539</a> | New    | 8.8  | HIGH |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.                                                                                                                                                                                                   |
| <a href="#">CVE-2026-81545</a> | New    | 8.8  | HIGH |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.                                                                                                                                                                                               |
| <a href="#">CVE-2026-81547</a> | New    | 8.8  | HIGH |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to path traversal.                                                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-81548</a> | New    | 8.8  | HIGH |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.                                                                                                                                                                                               |
| <a href="#">CVE-2026-81552</a> | New    | 8.8  | HIGH |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of environment variables.                                                                                                                                                                                                                |
| <a href="#">CVE-2026-82093</a> | New    | 8.8  | HIGH |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to unsafe deserialization of untrusted data.                                                                                                                                                                                                                            |
| <a href="#">CVE-2026-85682</a> | New    | 8.8  | HIGH |     | 0.001 |                            | The YOP Poll plugin for WordPress is vulnerable to Origin Validation Error in all versions up to, and including, 7.0.10. This is due to the plugin transmitting a wp_rest nonce to window.opener via postMessage() with a wildcard targetOrigin. This makes it possible for unauthenticated attackers to steal a REST nonce scoped to a logged-in Administrator and use it to change the ...  |
| <a href="#">CVE-2026-93280</a> | New    | 8.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: greybus: audio: bound the topology section sizes against the fetched size gb_audio_gb_get_topology() fetches a topology blob of a module-supplied size, and gbaudio_tplg_parse_data() then walks it by adding the module-supplied size_dais, size_controls and size_widgets fields to form the control, widget and ...    |
| <a href="#">CVE-2026-93284</a> | New    | 8.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: drm/pagemap: dma-unmap pages before handling migration errors<br>drm_pagemap_migrate_unmap_pages() relies on the pages array to determine which pages require DMA unmapping. However, drm_pagemap_migration_unlock_put_pages() clears the array as part of its cleanup, leaving drm_pagemap_migrate_unmap_pages() with... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package                                                                    | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93790</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mvm: fix out-of-bounds tid_data access in BA notif mvmsta->tid_data was indexed by the TFD loop counter 'i' instead of the actual TID value 'tid'. This writes lq_color into a random tid_data slot unrelated to the BA entry. Since multi-TID blockack is not really in use, 'i' was always 0 and n...   |
| <a href="#">CVE-2026-93793</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mvm: validate TX_CMD response layout TX_CMD parsing uses frame_count to walk status entries and then read the trailing SCD SSN. Make the minimum-length check follow that exact runtime layout calculation before parsing the payload. For new TX API, reject TX_CMD responses with frame_count != ...    |
| <a href="#">CVE-2026-93799</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mvm: validate sta_id in BA window status notif BA_WINDOW_STATUS_NOTIFICATION_ID extracts a 5-bit sta_id from the firmware notification and uses it to index fw_id_to_mac_id[] without bounds checking. Validate sta_id before array access to prevent out-of-bounds indexing.                             |
| <a href="#">CVE-2026-93806</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: wifi: cfg80211: validate assoc response length before status and IE access cfg80211_rx_assoc_resp() initialises the status and response-IE fields of cfg80211_connect_resp_params from the management frame before proving that the frame is long enough for those offsets. S1G and regular association responses a...   |
| <a href="#">CVE-2026-94609</a> | New    | 8.8  | HIGH |     |      |                                                                                               | authentik is an open-source identity provider. Prior to 2026.2.7, 2026.5.7, and 2026.8.2, an account with delegated permission to manage a group, group membership, or a user can grant superuser status to an account or assign an existing role to a group without holding the permissions that gate those privileges. Group hierarchy checks do not consistently account for superuser... |
| <a href="#">CVE-2026-97409</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: nvme-fc: Do not cancel requests in io target before it is initialized A new nvme-fc controller in CONNECTING state sees admin request timeout schedules ctrl->ioerr_work to abort inflight requests. This ends up calling __nvme_fc_abort_outstanding_ios() which aborts requests in both admin and io tagsets. In ...   |
| <a href="#">CVE-2026-97442</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: fix invalid data access in ath11k_dp_rx_h_undecap_nwifi In certain cases, hardware might provide packets with a length greater than the maximum native Wi-Fi header length. This can lead to accessing and modifying fields in the header within the ath11k_dp_rx_h_undecap_nwifi() function for the ...   |
| <a href="#">CVE-2026-97509</a> | New    | 8.8  | HIGH |     |      |                                                                                               | In the Linux kernel, the following vulnerability has been resolved: thunderbolt: Keep XDomain reference during the lifetime of a service This is needed because we release the service ID in tb_service_release() and the ID array is owned by the parent XDomain.                                                                                                                           |
| <a href="#">CVE-2026-56744</a> | New    | 8.7  | HIGH |     |      | npm:@bsv/wallet-toolbox,<br>npm:@bsv/wallet-toolbox-client,<br>npm:@bsv/wallet-toolbox-mobile | `@bsv/wallet-toolbox` provides BRC-100 wallet signing and storage components, while `@bsv/wallet-toolbox-client` and `@bsv/wallet-toolbox-mobile` provide client-focused distributions for standard and mobile applications using wallet storage services. A vulnerability in these packages causes transactions created through a remote `StorageClient` to trust output locking scripts... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package    | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-61825</a> | New    | 8.7  | HIGH |     |      |                               | code16 Sharp is a Laravel-based framework for building content-management and administrative interfaces. Versions before 9.22.5 contain a stored cross-site scripting vulnerability in `SharpEditorFormField`: attacker-controlled content bearing the `data-html-content` attribute can bypass HTML sanitization and preserve executable markup, which may execute when another user vie... |
| <a href="#">CVE-2026-63498</a> | New    | 8.7  | HIGH |     |      | composer:snipe/snipe-it       | Snipe-IT is an IT asset/license management system. Prior to 8.7.0, the uploaded-files API endpoint GET /api/v1/{object_type}/{id}/files/{file_id} allows an authenticated user with file-management access to upload XML and XSLT attachments and request them with the inline=true parameter. The app/Http/Controllers/Api/UploadedFilesController.php show() path does not apply the sa... |
| <a href="#">CVE-2026-82566</a> | New    | 8.7  | HIGH |     |      |                               | The Botslab G980H dash camera firmware contains a session management vulnerability in which authentication state can remain valid after the associated client connection has been terminated or replaced. Under certain connection conditions, a newly established connection can displace an existing client while previously established session state remains active until a separate ... |
| <a href="#">CVE-2026-84399</a> | New    | 8.7  | HIGH |     |      |                               | The Botslab G980H dash camera firmware contains an authorization vulnerability in its session based command functionality. The product does not sufficiently associate an authenticated session with the client connection that established it, and subsequent privileged operations rely on possession of a valid session identifier without adequately validating the requesting client... |
| <a href="#">CVE-2026-85057</a> | New    | 8.7  | HIGH |     |      | go:github.com/zitadel/zitadel | ZITADEL is an open source identity management platform. From 3.0.0 until 3.4.13 and 4.16.1, ZITADEL Actions V1 enables the goja Node-compatible require() registry without restricting its filesystem source loader. An organization Action author with ORG_OWNER, org.action.write, and org.flow.write permissions can run JavaScript at OIDC, SAML, and login-flow trigger points and l... |
| <a href="#">CVE-2026-86858</a> | New    | 8.7  | HIGH |     |      |                               | ServiceNow has remediated an improper access control security issue that was identified in the ServiceNow AI Platform. This security issue could enable an unauthenticated user, in certain circumstances, to create, modify, or delete instance data beyond what was intended. In August 2026, ServiceNow deployed a security update to hosted instances and ServiceNow provided th...      |
| <a href="#">CVE-2026-86859</a> | New    | 8.7  | HIGH |     |      |                               | ServiceNow has remediated an authorization bypass security issue that was identified in the ServiceNow AI Platform. This security issue, if exploited, could enable an unauthenticated user to access data within the ServiceNow AI Platform that the user otherwise would not be entitled to access, potentially enabling further unintended access. ServiceNow deployed a security...      |
| <a href="#">CVE-2026-87721</a> | New    | 8.7  | HIGH |     |      |                               | Uncontrolled Resource Consumption (CWE-400 / CWE-407) in the ANTLR 3 search query parser (QueryParser / Query.g) in Gerrit Code Review versions 2.0.19 through 3.12.9, 3.13.0 through 3.13.8, and 3.14.0 through 3.14.2 allows an unauthenticated remote attacker (or an authenticated user if anonymous read access is disabled) to cause a persistent denial of service (CPU exhaustion... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-87722</a> | New    | 8.7  | HIGH |     |      |                            | Uncontrolled Resource Consumption (CWE-400 / CWE-1333) in regex search query predicates (such as RegexProjectPredicate, RegexRefPredicate, RegexPathPredicate, and sibling predicates) and REST regex filter endpoints (RegexListSearcher /projects/?r= and RefFilter /projects/{project}/branches/?r=) in Gerrit Code Review versions 2.1.6 through 3.12.9, 3.13.0 through 3.13.8, and 3... |
| <a href="#">CVE-2026-91122</a> | New    | 8.7  | HIGH |     |      |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, the video placeholder component allowed crafted HTML to cause an attribute breakout and inject an attacker-controlled event handler. An authenticated user with default trust-level posting privileges could store the crafted placeholder in a post. When another user opened the ... |
| <a href="#">CVE-2026-96883</a> | New    | 8.7  | HIGH |     |      |                            | pgcollection is an open source extension to PostgreSQL. A type confusion issue in AWS pgcollection 2.0.0 through 2.1.1 might allow an authenticated remote user to execute arbitrary code as the postgres operating system user via crafted SQL statements that rely on mismatched type metadata in collection value retrieval and array conversion functions. To remediate this issue...    |
| <a href="#">CVE-2026-97057</a> | New    | 8.7  | HIGH |     |      |                            | redis-parser through 3.0.0 fails to validate the multi-bulk length value in RESP protocol parsing, allowing attackers to trigger an uncaught RangeError by supplying an excessively large declared length. A malicious or compromised Redis endpoint can deliver a crafted RESP header with a length above 2^32-1 to crash the Node.js client process.                                       |
| <a href="#">CVE-2026-97362</a> | New    | 8.7  | HIGH |     |      |                            | HFS2 version 2.4.0 and earlier contains a denial of service vulnerability that allows unauthenticated attackers to cause a complete and persistent loss of availability by sending a single crafted request. Attackers can trigger a hung serving thread that enters a busy loop, rendering the entire file server unresponsive to all clients without self-recovery until an operator ma... |
| <a href="#">CVE-2026-63493</a> | New    | 8.6  | HIGH |     |      | composer:snipe/snipe-it    | Snipe-IT is an IT asset/license management system. Prior to 8.7.0, a password-authenticated session for an account with self.api permission can reach the personal-access-token API flow before completing the account's second-factor challenge because CheckForTwoFactor is enforced in the web middleware group but not the API middleware group. The advisory states that the resulti... |
| <a href="#">CVE-2026-77581</a> | New    | 8.6  | HIGH |     |      |                            | BentoPDF is a client-side PDF toolkit that is self hostable. In 2.8.6 and earlier, the certificate and timestamp CORS proxy in cloudflare/cors-proxy-worker.js uses isPrivateOrReservedHost() to validate a supplied hostname separately from the DNS resolution used by fetch(targetUrl), allowing an attacker-controlled hostname to resolve to an internal or reserved destination aft... |
| <a href="#">CVE-2026-77874</a> | New    | 8.6  | HIGH |     |      |                            | IBM Enterprise Build of Quarkus 3.27.1 through 3.27.5.SP1, and 3.33.1 through 3.33.3.SP1 is vulnerable to SQL injection. A remote unauthenticated attacker could send specially crafted SQL statements, which could allow the attacker to view, add, modify, or delete information in the back-end database.                                                                                 |
| <a href="#">CVE-2026-77967</a> | New    | 8.6  | HIGH |     |      |                            | The Botslab G980H dash camera firmware accepts a reusable authentication value without adequately verifying its freshness or association with the requesting client. An unauthenticated attacker with adjacent network access who captures a valid authentication value could replay it from another client to establish an authenticated session and access privileged device functional... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package                                | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|-----------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-81455</a> | New    | 8.6  | HIGH |     |      |                                                           | Dell ThinOS 10, versions prior to SecurityAddon_2605.10.2766_T10, contain a Missing Authentication for Critical Function vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.                                                                                                                         |
| <a href="#">CVE-2026-95985</a> | New    | 8.6  | HIGH |     |      |                                                           | The file write tool in Amazon Kiro IDE versions before 1.0.242 might allow remote unauthenticated actors to inject crafted instructions into the agent's context. When a user runs the agent in a crafted repository as an untrusted workspace, sending any message can cause agent modifications to auto-loaded global configuration paths. We recommend you upgrade to Kiro IDE vers...    |
| <a href="#">CVE-2026-96515</a> | New    | 8.6  | HIGH |     |      |                                                           | This vulnerability exists in the Netlink ICT HG323RW router due to insufficient authorization and input validation controls in the diagnostic script import functionality. An authenticated attacker could exploit this vulnerability by uploading and executing a specially crafted script through the web management interface. Successful exploitation of this vulnerability coul...      |
| <a href="#">CVE-2026-97818</a> | New    | 8.6  | HIGH |     |      |                                                           | phpIPAM through 1.8.3 has incorrect authorization for id=="admins" and id=="all" in api/controllers/User.php.                                                                                                                                                                                                                                                                                |
| <a href="#">CVE-2026-56738</a> | New    | 8.5  | HIGH |     |      | composer:phpmyfaq/phpmyfaq,<br>composer:thorsten/phpmyfaq | phpMyFAQ is an open source FAQ web application. The `StopWords::add()` method inversions prior to 4.1.6 builds a SQL `INSERT` statement using `sprintf()` and inserts the user-supplied stop word value directly into the query string without calling the application's database escaping function on it. A sibling method, `StopWords::update()`, which modifies an existing stop word,... |
| <a href="#">CVE-2026-56739</a> | New    | 8.5  | HIGH |     |      |                                                           | Logto is the modern, open-source auth infrastructure for SaaS and AI apps. Prior to 1.43.0, Logto fetches administrator-controlled outbound destinations without validating the address used for the connection. Webhook delivery in packages/core/src/libraries/hook/utls.ts can reach special-use and cloud metadata addresses. Custom OAuth2 connectors can use an attacker-selected ...  |
| <a href="#">CVE-2026-82371</a> | New    | 8.5  | HIGH |     |      |                                                           | Plaintext exposure of sensitive authentication data in Brocade SANnav discovery service log files enables individuals with file read access to retrieve administrative switch credentials and active session tokens. An attacker with access to system logs or support bundles can leverage exposed authentication details to compromise managed network infrastructure and access active... |
| <a href="#">CVE-2026-82372</a> | New    | 8.5  | HIGH |     |      |                                                           | Improper handling of sensitive data during IPsec policy creation and modification in Brocade SANnav versions before 3.0.1a results in pre-shared keys being recorded in application logs. Individuals with read access to system log files or support bundles can view these credentials, leading to the potential exposure of keys used to secure network tunnels.                          |
| <a href="#">CVE-2026-85082</a> | New    | 8.5  | HIGH |     |      |                                                           | Root Browser Classic 3.3.0 passes the path of a selected SQLite database to an operating-system shell without safely separating the filename from the command.                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-97730</a> | New    | 8.5  | HIGH |     |      |                                                           | In Netgate pfSense Plus before 26.07 and pfSense CE before 2.9.0, a Local File Inclusion (LFI) vulnerability in the Dashboard (index.php) widget sequence data handling allows an authenticated attacker to execute arbitrary PHP code. To exploit this, an attacker with privileges to modify Dashboard settings and write arbitrary files to the pfSense firewall system (e.g., /tmp/te... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                               |
|--------------------------------|--------|------|------|-----|------|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-14443</a> | New    | 8.4  | HIGH |     |      |                            | Incomplete log sanitization during bulk IPsec policy collection in Brocade SANnav versions before 3.0.1a permit extension switch pre-shared keys to be written to system logs. Individuals with read access to container logs or support archives can obtain these keys, leading to the potential compromise of encrypted network tunnels.                                                |
| <a href="#">CVE-2026-86857</a> | New    | 8.4  | HIGH |     |      |                            | ServiceNow has remediated an authorization bypass security issue that was identified in the ServiceNow AI Platform. This security issue, if exploited, could enable an authenticated user to access data within the ServiceNow AI Platform that the user otherwise would not be entitled to access, potentially enabling further unintended access. ServiceNow deployed an update to...   |
| <a href="#">CVE-2026-93827</a> | New    | 8.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: virtio-fs: avoid double-free on failed queue setup virtio_fs_setup_vqs() allocates fs->vqs and fs->mq_map before calling virtio_find_vqs(). If virtio_find_vqs() fails, the error path frees both pointers and returns an error to virtio_fs_probe(). virtio_fs_probe() then drops the last kobject reference, and... |
| <a href="#">CVE-2026-95699</a> | New    | 8.4  | HIGH |     |      |                            | Prior to 9/18/2026, the iSteamX mobile application's AWS policy could grant authenticated users access to wildcard MQTT topics, which can expose other users' device data and allow the attacker to start and stop other connected users' devices. This risked exposing user profile information and potential scalding due to unintended device activation.                              |
| <a href="#">CVE-2026-97450</a> | New    | 8.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: validate handler object type in two places ACPICA: validate handler object type in acpi_ev_has_default_handler() and acpi_ev_find_region_handler().                                                                                                                                                           |
| <a href="#">CVE-2026-97451</a> | New    | 8.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Fix integer overflow in acpi_ex_opcode_3A_1T_1R() (mid_op) Add overflow check for Index + Length to prevent integer overflow when calculating the truncation length. This prevents negative size parameter being passed to memcpy().                                                                          |
| <a href="#">CVE-2026-97452</a> | New    | 8.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Prevent adding invalid references Prevent adding references for local, argument, and debug objects in acpi_ut_copy_simple_object().                                                                                                                                                                           |
| <a href="#">CVE-2026-97455</a> | New    | 8.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Fix use-after-free in acpi_ds_terminate_control_method() Fix use-after-free issue in acpi_ds_terminate_control_method() by clearing references to method locals and arguments.                                                                                                                                |
| <a href="#">CVE-2026-13465</a> | New    | 8.3  | HIGH |     |      |                            | Stack-based buffer overflow vulnerability in Altera Trusted Firmware on HPS allows Exploitation of Improperly Configured or Implemented Memory Protections. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                 |
| <a href="#">CVE-2026-13466</a> | New    | 8.3  | HIGH |     |      |                            | Incorrect calculation of buffer size vulnerability in Altera Trusted Firmware on HPS allows Overflow Buffers. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                                                               |
| <a href="#">CVE-2026-13467</a> | New    | 8.3  | HIGH |     |      |                            | Out-of-bounds write vulnerability in Altera Trusted Firmware on HPS allows Exploitation of Improperly Configured or Implemented Memory Protections. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                         |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package                             | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-58004</a> | New    | 8.3  | HIGH |     |      |                                                        | Out-of-bounds read vulnerability in Altera Trusted Firmware on HPS allows Privilege Escalation and Overflow Buffers. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                                                           |
| <a href="#">CVE-2026-58005</a> | New    | 8.3  | HIGH |     |      |                                                        | Out-of-bounds read vulnerability in Altera Trusted Firmware on HPS allows Privilege Escalation and Overflow Buffers. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                                                           |
| <a href="#">CVE-2026-58006</a> | New    | 8.3  | HIGH |     |      |                                                        | Untrusted pointer dereference vulnerability in Altera Trusted Firmware on HPS allows Exploitation of Improperly Configured or Implemented Memory Protections. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                  |
| <a href="#">CVE-2026-58007</a> | New    | 8.3  | HIGH |     |      |                                                        | Untrusted pointer dereference vulnerability in Altera Trusted Firmware on HPS allows Exploitation of Improperly Configured or Implemented Memory Protections. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                  |
| <a href="#">CVE-2026-58008</a> | New    | 8.3  | HIGH |     |      |                                                        | Stack-based buffer overflow vulnerability in Altera Trusted Firmware on HPS allows Exploitation of Improperly Configured or Implemented Memory Protections. This issue affects Trusted Firmware: through socfpga_v2.14.0.                                                                                                                                                                    |
| <a href="#">CVE-2026-82157</a> | New    | 8.3  | HIGH |     |      |                                                        | Dell ThinOS 10, versions prior to SecurityAddon_2605.10.2766_T10, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Protection mechanism bypass and Unauthorized access.                                                                                          |
| <a href="#">CVE-2026-96746</a> | New    | 8.3  | HIGH |     |      |                                                        | An out-of-bounds write in the connection-monitoring logic of the MongoDB C Driver may allow an unauthenticated party who controls name resolution and the responses of the hosts named in a client's connection string to write beyond the end of a heap buffer. This may cause the application using the driver to terminate unexpectedly.                                                  |
| <a href="#">CVE-2026-96748</a> | New    | 8.3  | HIGH |     |      |                                                        | PyMongo's connection string parsing decodes percent-encoded characters in the host portion before the host list is separated on its delimiters. When an application places a hostname value supplied by an unauthenticated party into a connection string, that party may cause additional servers of their choosing to be added to the application's database client. The application ma... |
| <a href="#">CVE-2026-56736</a> | New    | 8.2  | HIGH |     |      | composer:phpmyfaq/phpmyfaq, composer:thorsten/phpmyfaq | phpMyFAQ is an open source FAQ web application. A stored cross-site scripting (XSS) vulnerability in versions prior to 4.2.0-alpha allows any unauthenticated user (or low-privileged registered user) to inject arbitrary JavaScript that executes in an administrator's browser when they review or edit a user-submitted FAQ entry. This leads to admin account takeover via session t... |
| <a href="#">CVE-2026-85056</a> | New    | 8.2  | HIGH |     |      | go:github.com/zitadel/zitadel                          | ZITADEL is an open source identity management platform. From 4.0.0 until 4.16.1, ZITADEL Login V2 creates a browser session after password verification and can reuse that session for a later authentication request without verifying a user's enrolled TOTP, OTP, or U2F second factor. When the MFA step is abandoned and login starts again, session-validity checks require MFA onl... |
| <a href="#">CVE-2026-91160</a> | New    | 8.2  | HIGH |     |      |                                                        | OpenWA is a free, open source, self-hosted WhatsApp API gateway. Prior to 0.23.5, the /events WebSocket gateway delivers the session.qr event to a VIEWER API key that subscribes by event name or through either wildcard subscription form, even though GET /api/sessions/{sessionId}/qr requires the OPERATOR role. When an allowed session is waiting to be paired, the exposed QR le... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package                             | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97059</a> | New    | 8.2  | HIGH |     |       |                                                        | DCMTK through 3.7.0 contains a heap over-read vulnerability in ConcatenationLoader that copies pixel data frames without validating the PixelData buffer length against the declared NumberOfFrames. Attackers can craft malicious DICOM instances declaring more frames than the buffer contains to trigger heap over-reads that crash the application or leak adjacent heap memory.        |
| <a href="#">CVE-2026-97433</a> | New    | 8.2  | HIGH |     |       |                                                        | In the Linux kernel, the following vulnerability has been resolved: nvme: validate FDP configuration descriptor sizes Validate descriptor sizes while walking the FDP configurations log so dsze == 0 or a descriptor past the log end cannot cause unbounded iteration or reads past the buffer.                                                                                            |
| <a href="#">CVE-2026-56737</a> | New    | 8.1  | HIGH |     |       | composer:phpmyfaq/phpmyfaq, composer:thorsten/phpmyfaq | phpMyFAQ is an open source FAQ web application. Versions 3.2.0 through 4.1.5 contain an authentication bypass in its public two-factor authentication verification flow: an unauthenticated attacker can submit an account's numeric user ID and a valid or brute-forced six-digit TOTP code without first authenticating with the account password, allowing takeover of any 2FA-enabled... |
| <a href="#">CVE-2026-57590</a> | New    | 8.1  | HIGH |     | 0.002 |                                                        | A missing authorization vulnerability exists in the Task Group APIs of Apache DolphinScheduler. The affected APIs do not properly verify whether the authenticated user has permission to access the project associated with the target Task Group. This issue affects Apache DolphinScheduler: before 3.4.3. Users are recommended to upgrade to version 3.4.3, which fixes the is...       |
| <a href="#">CVE-2026-62368</a> | New    | 8.1  | HIGH |     |       | composer:snipe/snipe-it                                | Snipe-IT is an IT asset/license management system. Prior to 8.7.0, a user with the customfields.create permission can store markup in CustomField.name, and app/Presenters/AssetPresenter.php assigns that value as an unescaped bootstrap-table header title. When another user opens an asset-list page associated with the fieldset, the stored markup executes on page load in that u... |
| <a href="#">CVE-2026-77294</a> | New    | 8.1  | HIGH |     |       |                                                        | TREK is a collaborative travel planner. Prior to 3.3.0, TREK allows an authenticated user to store an attacker-controlled llm_base_url through the settings API when the LLM_PARSING feature is enabled. Write permission to the target trip instance is required to trigger the vulnerable AI-assisted import path. The value is consumed by the clients in server/src/nest/llm-parse/cl... |
| <a href="#">CVE-2026-81473</a> | New    | 8.1  | HIGH |     |       |                                                        | Dell Rugged Control Center (RCC), versions prior to 5.2.206, contain an Improper Authorization vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of Privileges.                                                                                                                                                  |
| <a href="#">CVE-2026-90959</a> | New    | 8.1  | HIGH |     |       |                                                        | A path traversal vulnerability was found in pulpcore. The content upload API accepts a 'file_url' parameter that allows users with file repository privileges to specify a local file URL for Pulp to download and store. A URL scheme validation check uses a string prefix comparison that only rejects URLs beginning with 'file://', but Python's URL parser recognizes the 'file:' s... |
| <a href="#">CVE-2026-93221</a> | New    | 8.1  | HIGH |     |       |                                                        | In the Linux kernel, the following vulnerability has been resolved: nfsd: convert nfsd_net boolean flags to unsigned long flags word nfsd_net contains several boolean fields that are accessed from concurrent contexts without serialization. In particular, nfsd4_end_grace() guards its drain path with a plain bool: if (nn->grace_ended) return; nn->grace_...                         |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93224</a> | New    | 8.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: svcrdma: Fix unmatched rn_unregister on failed accept When svc_rdma_accept() takes the errout path before rpcrdma_rn_register() has succeeded, the existing cleanup block calls rpcrdma_rn_unregister(dev, &newxpvt->sc_rn) unconditionally. svcxpvt_rdma is kzalloc'd, so on that path sc_rn.rn_index is 0 and sc_...   |
| <a href="#">CVE-2026-93282</a> | New    | 8.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix maximum allowed access checks The DACL permission check looks for an ACE matching the current user and falls back to the Everyone ACE. It does not consider an Authenticated Users ACE, even though an authenticated session is a member of that well-known group. As a result, opening a file whose ac...    |
| <a href="#">CVE-2026-93354</a> | New    | 8.1  | HIGH |     |      |                            | Taskview Community before 1.56.0 contains a missing authentication vulnerability that allows unauthenticated attackers to register arbitrary OAuth clients and take over user accounts by exploiting the OAuth 2.0 Dynamic Client Registration endpoint, which is enabled by default and requires no authentication. Attackers can send a POST request to the registration endpoint to ob... |
| <a href="#">CVE-2026-93786</a> | New    | 8.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ksmbd: preserve VFS inherited POSIX ACL mask The VFS initializes a child's POSIX ACL from the parent's default ACL and the requested creation mode. Do not mutate the parent ACL or overwrite the child's VFS-computed access and default ACLs afterwards. This preserves restrictive ACL_MASK entries and prevent...    |
| <a href="#">CVE-2026-93787</a> | New    | 8.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: smb: client: bound dirent name against end of SMB response in cifs_filldir cifs_filldir() copies the entry name out of an SMB1 TRANS2_FIND_FIRST / FIND_NEXT response using a length (de.namelen) supplied by the server. The kcalloc'd SMB response buffer is bounded, but nothing checks that de.name + de.namele...   |
| <a href="#">CVE-2026-94611</a> | New    | 8.1  | HIGH |     |      |                            | authentik is an open-source identity provider. Prior to 2026.2.7, 2026.5.7, and 2026.8.2, authentik API serializers return stored credentials when an account has view permission on an affected configuration, even when that account is not authorized to change the configuration or read its secrets. Affected configurations include one-time code delivery by mail or SMS, outbound... |
| <a href="#">CVE-2026-97735</a> | New    | 8.0  | HIGH |     |      |                            | ITFlow before 26.08 allows SVG attachments in the ticket email parser (cron/ticket_email_parser.php) for email messages that may arrive over SMTP from arbitrary senders.                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-89325</a> | New    | 7.8  | HIGH |     |      |                            | An uncontrolled search path element in InsightVM assessment content in Rapid7 Insight Agent on Windows allows a local, low-privileged user to execute arbitrary code as SYSTEM via a planted executable resolved from the machine PATH. Assessment content at or below version 0.0.261.0 included a check that invoked the `code` command without a fully qualified path from a process ...  |
| <a href="#">CVE-2026-93237</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: LoongArch: Add DIRECT_MAP_PHYSMEM_END definition get_free_mem_region() and mhp_get_pluggable_range() bound their search to DIRECT_MAP_PHYSMEM_END. LoongArch does not define it, so the fallback in include/linux/mm.h applies: under CONFIG_SPARSEMEM_VMEMMAP it is (1ULL << MAX_PHYSMEM_BITS) - 1, a compile-time...   |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|------|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93250</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: vxlan: mdb: Fix use-after-free in vxlan_mdb_flush() vxlan_mdb_flush() iterates over the MDB entries using hlist_for_each_entry_safe(), which only tolerates the removal of the current entry. Contrary to the comment above the loop, the removal of an entry can trigger the removal of another entry. Flushing t...  |
| <a href="#">CVE-2026-93262</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: md/raid5-ppl: fix use-after-free in ppl_do_flush() The loop in ppl_do_flush() continues iterating after calling ppl_io_unit_finished(), touching io->pending_flushes and leading to a use-after-free. Add a break statement to stop the loop once io is freed.                                                         |
| <a href="#">CVE-2026-93277</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: RDMA/bnxt_re: Validate udata before executing commands The destroy callbacks currently zero the udata output after tearing down driver resources. If the userspace access fails, uverbs preserves the uobject and allows the destroy callback to run again, even though the driver resource has already been freed.... |
| <a href="#">CVE-2026-93287</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: i2c: smbus: reject oversized block transfers in the common path The SMBus block transfer length data->block[0] is validated in i2c_smbus_xfer_emulated() but that check runs too late for tracepoints and is skipped entirely when the adapter provides a native smbus_xfer implementation. This allows user-contro... |
| <a href="#">CVE-2026-93288</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: netfilter: nfnetlink_log: wait for rcu grace period before freeing pernet state sashiko reports: "nfnl_log_net_exit() calls nf_log_unset(), which clears the logger pointer without an RCU grace period. Immediately after, ops_free_list() frees the per-net state while concurrent packets might still be execut...  |
| <a href="#">CVE-2026-93782</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: vhost-scsi: flush backend after device ioctl vhost-scsi translates guest response descriptors into userspace iovecs when commands are submitted. Target-core completes those commands asynchronously, so VHOST_SET_MEM_TABLE can replace the memory table while an in-flight command still retains response iovec...   |
| <a href="#">CVE-2026-93798</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: btrfs: fix reloc root cleanup in merge_reloc_roots() If the root we got has zero root refs in its root item, we are resetting the root's ->reloc_root without using barriers like we do everywhere else. Sashiko complained about this while reviewing another patch, and it's correct (see the Link tag below). A...  |
| <a href="#">CVE-2026-93813</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: btrfs: tree-checker: validate INODE_REF's namelen [BUG] A crafted btrfs image can trigger the following crash: BUG: unable to handle page fault for address: ffffd1dc42884000 #PF: supervisor write access in kernel mode #PF: error_code(0x0002) - not-present page CPU: 9 UID: 0 PID: 1034 Comm: poc Not...          |
| <a href="#">CVE-2026-93817</a> | New    | 7.8  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: perf: Fix addr_filter_ranges lifetime Lee Jia Jie reported that since event::addr_filter_ranges is used under RCU, it should be RCU freed.                                                                                                                                                                             |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-95519</a> | New    | 7.8  | HIGH |     |       |                            | A flaw was found in rpm. An attacker can supply a crafted manifest file that, when processed by a user or automation using `rpm -q -p` or similar manifest-processing flows, leads to arbitrary code execution. This occurs because manifest entries are unexpectedly macro-expanded before being opened, allowing embedded shell commands to run with the privileges of the `rpm` proces...  |
| <a href="#">CVE-2026-95521</a> | New    | 7.8  | HIGH |     |       |                            | A command injection flaw was found in rpm. Installing or rebuilding a source RPM whose source or spec file basenames contain a %() macro construct causes rpm to execute an attacker-controlled shell command via popen() while relocating the source file list. This allows arbitrary command execution as the invoking (typically non-root) user, simply by installing, rebuilding, or ...  |
| <a href="#">CVE-2026-97185</a> | New    | 7.8  | HIGH |     | 0.001 |                            | A flaw was found in GIMP. When processing a specially crafted GIMPpressionist preset file, the plug-in does not properly validate vector indices before writing into fixed-size arrays. This can lead to an out-of-bounds write, corrupting memory. An attacker could exploit this by convincing a user to load a malicious preset file, potentially causing a crash or enabling arbitrary... |
| <a href="#">CVE-2026-97415</a> | New    | 7.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: btrfs: tree-checker: validate names in ROOT_REF and ROOT_BACKREF ROOT_REF and ROOT_BACKREF items contain a struct btrfs_root_ref followed by the subvolume name. Several readers assume that this layout is already valid and then use the on-disk name length directly. A corrupted item can therefore make those ...    |
| <a href="#">CVE-2026-97421</a> | New    | 7.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: RDMA/umem: Be careful about boundary conditions in ib_umem_find_best_pgsz() Several corner cases, especially important on 32 bits: - umem->iova is u64, the function argument should pass in u64 or iova will be truncated - Check that the length is not too large for the iova - Check that lengths > 4G don't...       |
| <a href="#">CVE-2026-97429</a> | New    | 7.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: fix UAF race in destroy_queue_cpsch wait_on_destroy_queue() drops locks to wait for queue resume, allowing a concurrent destroy to free the queue. Use is_being_destroyed flag to serialize destruction.                                                                                                      |
| <a href="#">CVE-2026-97478</a> | New    | 7.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: virt: acrn: Fix irqfd use-after-free during eventfd shutdown acrn_irqfd_deassign() and the eventfd EPOLLHUP wakeup can race and free the same struct hsm_irqfd: CPU0 CPU1 ---- ---- eventfd_release() wake_up_poll(EPOLLHUP) hsm_i...                                                                                     |
| <a href="#">CVE-2026-97497</a> | New    | 7.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Check bounds for allocate_sdma_queue restore_sdma_id allocate_sdma_queue has an option where the sdma queue id can be specified (used by CRIU). We weren't bounds-checking that value. Confirm it's less than the maximum number of queues.                                                                   |
| <a href="#">CVE-2026-97513</a> | New    | 7.8  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: media: chips-media: wave5: Release m2m_ctx after Instance Removed from List Possible use after free if IRQ thread manages to obtain spinlock between m2m_ctx release and wave5_release function removing stream instance from list of active instances. The IRQ thread looks for the m2m_ctx which is freed so null...    |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-79764</a> | New    | 7.7  | HIGH |     |      |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 2.5.0 until 2.5.1, the /homepage/proxy endpoint accepts an authenticated user's url query parameter and passes it to http.get or https.get without destination restrictions. In src/backend/database/routes/homepage-proxy-routes.ts, new URL performs only syntactic ... |
| <a href="#">CVE-2026-85496</a> | New    | 7.7  | HIGH |     |      |                            | The Botslab G980H dash camera firmware generates session identifiers using a small sequential value space rather than a suitably unpredictable source. An unauthenticated attacker with adjacent network access and knowledge that an active session exists could potentially determine a valid session identifier and use it to bypass intended authorization controls.                     |
| <a href="#">CVE-2026-88390</a> | New    | 7.7  | HIGH |     |      |                            | An out-of-bounds write vulnerability in jslGetTokenValueAsString() in Espruino 2v29 (commit bffc6d0) allows crafted JavaScript input containing an overlong token to trigger a one-byte write beyond the JsLex.token buffer in RELEASE/NO_ASSERT builds. The out-of-bounds write corrupts the adjacent tokenValue pointer, resulting in memory corruption and potentially causing applica... |
| <a href="#">CVE-2026-93265</a> | New    | 7.7  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI/pwrctrl: tc9563: Fix parsing the integrated Ethernet MAC Endpoint node DSP3 has an integrated Ethernet MAC Endpoint which has its own set of config registers for configuring settings such as ASPM. The Endpoint device has two physical functions and those two functions share the same settings. Parse the...    |
| <a href="#">CVE-2026-97428</a> | New    | 7.7  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: harden FRU PIA parsing with bounded helpers Replace the open-coded TLV walk with fru_pia_advance() and fru_pia_copy_field() helpers that bound every read by the actual EEPROM data length, preventing out-of-bounds reads on truncated or malformed FRU data.                                               |
| <a href="#">CVE-2026-97444</a> | New    | 7.7  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: add boundary checks in two places Add boundary checks in acpi_ps_get_next_namestring() and acpi_ps_peek_opcode() to prevent out-of-bounds access.                                                                                                                                                                |
| <a href="#">CVE-2026-97445</a> | New    | 7.7  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Enhance buffer validation in acpi_ut_walk_aml_resources() Enhance buffer validation in acpi_ut_walk_aml_resources() to prevent buffer overflows.                                                                                                                                                                 |
| <a href="#">CVE-2026-97448</a> | New    | 7.7  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Add validation for node in acpi_ns_build_normalized_path() Add validation for node in acpi_ns_build_normalized_path() to prevent use-after-free vulnerabilities.                                                                                                                                                 |
| <a href="#">CVE-2026-97454</a> | New    | 7.7  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: add boundary checks in acpi_ps_get_next_field() Add boundary checks in acpi_ps_get_next_field() to prevent out-of-bounds access.                                                                                                                                                                                 |
| <a href="#">CVE-2026-63203</a> | New    | 7.6  | HIGH |     |      |                            | Logto is the modern, open-source auth infrastructure for SaaS and AI apps. From 1.31.0 until 1.42.0, the Account API handlers in packages/core/src/routes/account/third-party-tokens.ts allow a caller holding a same-user access token with only the openid scope to retrieve stored social or enterprise SSO provider access tokens through GET /api/my-account/identities/{target}/acc... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package         | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-87720</a> | New    | 7.6  | HIGH |     |       |                                    | Incorrect Authorization (CWE-863) in project name normalization (ProjectUtil.stripGitSuffix) and ProjectCache eviction logic (ProjectCacheImpl) in Gerrit Code Review versions 2.16.0 through 3.12.9, 3.13.0 through 3.13.8, and 3.14.0 through 3.14.2 allows an authenticated user (or an unauthenticated user if the repository was previously public) to cause unauthorized disclosure...  |
| <a href="#">CVE-2026-14780</a> | New    | 7.5  | HIGH |     | 0.003 |                                    | A vulnerability exists in the PaperCut NG/MF platform's device-scripting functionality due to insufficient sanitization and access restrictions within the embedded execution engine. An authenticated user with administrative access to the management interface can supply a malicious script that escapes the runtime sandbox. A successful execution enables an attacker to run u...     |
| <a href="#">CVE-2026-51995</a> | New    | 7.5  | HIGH |     |       |                                    | An issue in geelen mcp-remote 0.1.32 through 0.1.38 allows a remote attacker to obtain sensitive information via the src/lib/authorization-server-metadata.ts, src/lib/utlis.ts components                                                                                                                                                                                                    |
| <a href="#">CVE-2026-57440</a> | New    | 7.5  | HIGH |     |       |                                    | The EmbedVideo Extension is a MediaWiki extension which adds a parser function called #ev and various parser tags for embedding video clips from various video sharing services. Prior to 4.1.0, with \$wgEmbedVideoRequireConsent disabled (not the default), the urls for videos are passed into an iframe src attribute without sanitization. When given a malformed url or id, the src... |
| <a href="#">CVE-2026-61782</a> | New    | 7.5  | HIGH |     |       | npm:@rsdoctor/rspack-plugin        | Rdoctor is a build analyzer tailored for projects built with Rspack. Prior to version 1.5.16, the default Rdoctor report HTTP server started by `@rsdoctor/rspack-plugin` binds to all network interfaces (`0.0.0.0`) and serves a `POST /api/data/key` endpoint with no authentication and wildcard CORS (`Access-Control-Allow-Origin: *`). Any network-adjacent or remote attacker c...    |
| <a href="#">CVE-2026-61816</a> | New    | 7.5  | HIGH |     |       | composer:zbateson/mail-mime-parser | zbateson/mail-mime-parser is a mail mime parser alternative to PHP's imap* functions and Pear libraries for reading messages in Internet Message Format RFC 822. Starting in version 2.0.0 and prior to version 3.0.6 and 4.0.2, an uncontrolled resource consumption / algorithmic complexity vulnerability (CWE-400) affects any application that parses untrusted email with this libr...  |
| <a href="#">CVE-2026-63645</a> | New    | 7.5  | HIGH |     |       |                                    | OpenObserve is a cloud-native observability platform. Prior to 0.90.3, OpenObserve registers the /config/runtime endpoint without authentication and serializes the complete server configuration after applying the hide_sensitive_fields keyword filter. The filter does not recognize dsn or creds field names, so meta_postgres_dsn, meta_postgres_ro_dsn, meta_ddl_dsn, and usage_re...  |
| <a href="#">CVE-2026-71540</a> | New    | 7.5  | HIGH |     |       |                                    | Wazuh is an open-source security platform providing unified XDR and SIEM protection for endpoints and cloud workloads. From 3.9.0 until 4.14.7, wazuh-clusterd in framework/wazuh/core/cluster/common.py allocates a payload buffer using the size declared in a 20-byte cluster protocol header before Fernet decryption validates the peer. An unauthenticated network peer can declare...  |
| <a href="#">CVE-2026-7169</a>  | New    | 7.5  | HIGH |     |       |                                    | a vulnerability involving an unchecked search path element in Evope Collector, versions prior to 1.1.7.13, allows a local attacker without privileges to load a malicious DLL by placing a 'wtsapi32.dll' file in the 'C:\ProgramData\Evope\' directory. The 'Evope.Service.exe' component, which runs with 'NT AUTHORITY\SYSTEM' privileges, loads this DLL without properly verifying i...  |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-75907</a> | New    | 7.5  | HIGH |     |       |                            | The door access control on a Norwegian Cruise Line asset grants entry based only on the credential's static 7-byte UID stored on an NTAG212 NFC chip. A UID is a manufacturer serial number sent in the clear on every read and is not intended to be secret or to authenticate the holder. Validating on the UID of the NTAG212 NFC chip alone is identification, not authentication, an... |
| <a href="#">CVE-2026-77193</a> | New    | 7.5  | HIGH |     | 0.004 |                            | The eesy_ID2WP – Publish InDesign HTML5 plugin for WordPress is vulnerable to Path Traversal in all versions up to, and including, 1.0.3 via the `id2wp_path` parameter. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information.                                                                |
| <a href="#">CVE-2026-80513</a> | New    | 7.5  | HIGH |     | 0.002 |                            | The wpForo Forum WordPress plugin before 3.1.6 does not restrict which classes may be instantiated when it deserializes a user-supplied profile field value, allowing authenticated users with Subscriber-level access and above to inject a PHP Object. No POP chain is present in the wpForo Forum WordPress plugin before 3.1.6 itself; if one is present via another installed wpForo... |
| <a href="#">CVE-2026-88357</a> | New    | 7.5  | HIGH |     |       |                            | nDPI 5.1.0 contains a memory access issue in the DNS dissector and serializer deserialization code. Specially crafted network input can cause byte-buffer addresses at odd offsets to be cast to uint16_t or wider integer pointers and directly dereferenced without alignment checks. This results in undefined behavior and can cause process termination in UBSan-instrumented builds... |
| <a href="#">CVE-2026-88368</a> | New    | 7.5  | HIGH |     |       |                            | NanoSVG commit 239e102ec contains an incorrect numeric conversion vulnerability in the rasterizer's nsvg__addActive() function. A specially crafted SVG document containing sufficiently large geometry coordinates can cause fixed-point-scaled edge coordinates to exceed the range representable by int. The rasterizer subsequently converts these values to int without range valida... |
| <a href="#">CVE-2026-88372</a> | New    | 7.5  | HIGH |     |       |                            | libsndfile 1.2.2 contains an integer overflow vulnerability in mat4_read_header() when parsing crafted MAT4 (MATLAB v4) files.                                                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-88376</a> | New    | 7.5  | HIGH |     |       |                            | Bento4 1.6.0.0 contains an integer underflow vulnerability in AP4_AvccAtom::Create() and AP4_HvccAtom::Create(). A specially crafted MP4 file containing an avcC or hvcc atom with a declared size smaller than the atom header size can cause the payload-size calculation to wrap to a large unsigned value. The resulting invalid buffer allocation and copy operations can cause appl... |
| <a href="#">CVE-2026-88382</a> | New    | 7.5  | HIGH |     |       |                            | hiredis commit 29ea279 (post-v1.5.0) contains an uncontrolled memory allocation vulnerability in its RESP aggregate parser.                                                                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-93826</a> | New    | 7.5  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: HID: hidpp: fix potential UAF in hidpp_connect_event() If input_register_device() fails, we call input_free_device(), but keep stale pointer to the old device in hidpp->input, which could potentially lead to UAF. Fix that by resetting it to NULL before returning from hidpp_connect_event().                       |
| <a href="#">CVE-2026-93830</a> | New    | 7.5  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: net: stmmac: xgmac2: disable RBUE in default RX interrupt mask Enabling the RX Buffer Unavailable (RBUE) interrupt is counterproductive and can trigger a MAC interrupt storm under heavy RX pressure. When the DMA runs out of RX descriptors it fires RBUE continuously until software refills the ring. However...    |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-94613</a> | New    | 7.5  | HIGH |     |      |                            | authentik is an open-source identity provider. Prior to 2026.2.7, 2026.5.7, and 2026.8.2, an unauthenticated attacker can submit a malformed SAML message to an authentik deployment using SAML in either the identity-provider or SAML source role. The message can stop the worker handling /application/saml/* or /source/saml/*, causing the requests assigned to that worker to fail... |
| <a href="#">CVE-2026-96749</a> | New    | 7.5  | HIGH |     |      |                            | An integer overflow in the BSON document encoding component of the MongoDB Python Driver's bundled native extension may occur when a single document is built from an unusually large amount of caller-supplied data. Size arithmetic is performed in a signed 32-bit type, and the guard meant to catch the overflow is written in a form whose behavior is not defined by the C languag... |
| <a href="#">CVE-2026-97417</a> | New    | 7.5  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_contrack: use get_unaligned_be32() in tcp_sack() The timestamp-only fast path dereferences the option stream as *(__be32 *)ptr, which assumes 4-byte alignment that the TCP option stream does not guarantee. Use get_unaligned_be32() instead, which reads the value safely and already returns hos...    |
| <a href="#">CVE-2026-97508</a> | New    | 7.5  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: thunderbolt: Set tb->root_switch to NULL when domain is stopped Similarly what we do with the firmware connection manager. This makes tb_xdp_handle_request() return error to the remote host. However, we need to make sure we keep the uuid alive so that we can reply until the whole domain is released.             |
| <a href="#">CVE-2026-57178</a> | New    | 7.4  | HIGH |     |      | pip:social-auth-core       | Python Social Auth is a social authentication/registration mechanism. Prior to version 5.0.0, the `vk-app` backend accepted VK application callback data without verifying the callback signature when the `auth_key` parameter was omitted. Applications using this backend could treat unsigned attacker-controlled data as a verified VK identity. An attacker could choose callback f... |
| <a href="#">CVE-2026-61788</a> | New    | 7.4  | HIGH |     |      | npm:@bytebase/dbhub        | DBHub is a database MCP server for Postgres, MySQL, SQL Server, Oracle, MariaDB, SQLite. Prior to version 0.22.6, setting `readonly = true` on the `execute_sql` tool does not make the connection read-only. The connectors are written to set PostgreSQL `default_transaction_read_only=on` (and open SQLite in `readOnly` mode), but that code is gated on a config value that is neve... |
| <a href="#">CVE-2026-88907</a> | New    | 7.4  | HIGH |     |      |                            | Incorrect Authorization vulnerability in TÜB■TAK ULAKB■M UlakPDF allows Authentication Bypass. This issue affects UlakPDF: through 09092026.                                                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-93225</a> | New    | 7.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: phy: fsl-imx8mq-usb: fix typec switch leak on probe error path If probe fails after imx95_usb_phy_get_tca() succeeds, the typec switch leaks because the only cleanup path was in .remove(), which never runs on probe failure. Use devm_add_action_or_reset() so the switch is cleaned up on both probe failure a...    |
| <a href="#">CVE-2026-93260</a> | New    | 7.4  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: powerpc/xive: propagate IPI init errors to prevent use-after-free When xive_init_ipis() fails (e.g. irq_domain_alloc_irqs() fails), the error path frees the global xive_ipis array. However, xive_smp_probe() previously ignored this failure and proceeded to call xive_setup_cpu_ipi(), which dereferences the ...    |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93543</a> | New    | 7.4  | HIGH |     |       |                            | An out-of-bounds read in libXi's X12 class parser in libXi before 1.8.4 could be used by malicious X servers to crash an attached X client.                                                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-94612</a> | New    | 7.4  | HIGH |     |       |                            | authentik is an open-source identity provider. Prior to 2026.2.7, 2026.5.7, and 2026.8.2, an authentik SAML Source verifies an assertion's signature and validity period but does not ensure that the identity provider issued the assertion for that Source or in response to a login request from that Source. The SAML Source also does not record already accepted assertions, allowi... |
| <a href="#">CVE-2026-97474</a> | New    | 7.4  | HIGH |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: mld: purge async notifications upon nic error This fixes a kernel panic in reconfig failure: 1. we have a BSS connection 2. we have a NAN connection 3. FW error occurs 4. reconfig restores the BSS connection 5. however, restoring the NAN connection fails due to a FW error. 6. erroneously, i...   |
| <a href="#">CVE-2026-97737</a> | New    | 7.4  | HIGH |     |       |                            | In Wakapi before 2.17.6, the user caching service allows a lookup to be resolved in an unintended lookup context, leading to account takeover.                                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-12559</a> | New    | 7.3  | HIGH |     |       |                            | A Stored Cross-Site Scripting (XSS) vulnerability has been identified in OpenText Vendor Invoice Management for SAP Solutions Capture Validation application. Under certain conditions, this issue could allow execution of unauthorized script content in a user's browser, potentially impacting confidentiality and integrity of information processed through the application.           |
| <a href="#">CVE-2026-61823</a> | New    | 7.3  | HIGH |     |       |                            | code16 Sharp is a Laravel-based framework for building content-management and administrative interfaces. Versions before 9.22.5 contain a stored cross-site scripting vulnerability in the rich-text editor because the HTML sanitizer permits the `srcdoc` attribute on iframe elements. Although markup inside `srcdoc` is HTML-encoded during sanitization, browsers decode attribute ... |
| <a href="#">CVE-2026-82077</a> | New    | 7.3  | HIGH |     | 0.007 |                            | An improper limitation of a pathname to a restricted directory (path traversal) vulnerability in the Scan-to-Fax component of PaperCut NG and PaperCut MF allows an authenticated administrator to execute arbitrary commands on the underlying host via crafted fax provider settings.                                                                                                      |
| <a href="#">CVE-2026-96750</a> | New    | 7.3  | HIGH |     |       |                            | MongoDB Compass can interpolate a database name without escaping into the initial input of its embedded MongoDB shell when a user opens the shell from that database's view. A user with privileges to create databases on a server that a Compass user connects to may, under specific conditions, have content evaluated as shell input within the Compass process, with that process's... |
| <a href="#">CVE-2026-97231</a> | New    | 7.3  | HIGH |     |       |                            | A vulnerability was found in volatat Anagnorisis up to 0.3.1/0.4.0. Affected is an unknown function of the file app.py of the component Socket.IO Connect Interface. The manipulation results in missing authentication. It is possible to launch the attack remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did n... |
| <a href="#">CVE-2026-97324</a> | New    | 7.3  | HIGH |     |       |                            | A vulnerability was identified in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. Affected is the function updateDemoOrderPaid of the file yudao-module-pay/src/main/java/cn/iocoder/yudao/module/pay/controller/admin/demo/PayDemoOrderController.java of the component Demo-order Payment Callback Handler. The manipulation of the argument ID leads to improper authorization. The ... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package         | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97326</a> | New    | 7.3  | HIGH |     |       |                                    | A weakness has been identified in songxinjianqwe Chat up to ac63d25297079eed5e4ba7e88d3b7a032637150d. Affected by this issue is some unknown functionality of the file chat-server/src/main/java/cn/sinjinsong/chat/server/ChatServer.java of the component chat-server. This manipulation causes server-side request forgery. The attack may be initiated remotely. The exploit has been...  |
| <a href="#">CVE-2026-97646</a> | New    | 7.3  | HIGH |     |       |                                    | A weakness has been identified in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. This affects an unknown function of the file admin/fun/getStudent.php. This manipulation of the argument sid causes authorization bypass. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used f...  |
| <a href="#">CVE-2026-61815</a> | New    | 7.2  | HIGH |     |       | composer:zbateson/mail-mime-parser | zbateson/mail-mime-parser is a mail mime parser alternative to PHP's imap* functions and Pear libraries for reading messages in Internet Message Format RFC 822. Prior to version 3.0.6 and 4.0.2, CRLF (carriage-return / line-feed) header injection (CWE-93) affecting any application that uses this library to build or forward MIME messages with an attacker-influenced attachment...  |
| <a href="#">CVE-2026-88843</a> | New    | 7.2  | HIGH |     | 0.002 |                                    | The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not validate one of its display-style settings before using it to build a template path, allowing users with the Contributor role and above to include and execute arbitrary local PHP files on the server. An equivalent path was corrected in an earlier release and this one was not, so the issue persists ...   |
| <a href="#">CVE-2026-91123</a> | New    | 7.2  | HIGH |     |       |                                    | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, the iframe src traversal guard did not treat literal backslashes as path separators after decoded dot segments. A crafted source could therefore pass an allowed_iframes subpath check while browser URL normalization moved the iframe outside the intended allowed path. The resu...  |
| <a href="#">CVE-2026-4638</a>  | New    | 7.1  | HIGH |     |       |                                    | PRTG Network Monitor before version 26.2.120.1449 ships a demo EXE/Script sensor that multiplies two integer parameters using cscript.exe. If a non-numeric value is passed instead, cscript.exe raises a 'Type mismatch' runtime error that includes the offending parameter value in plaintext. PRTG provides a documented placeholder variable, %windowsspassword, which resolves to th... |
| <a href="#">CVE-2026-48070</a> | New    | 7.1  | HIGH |     |       |                                    | Docmost is open-source collaborative wiki and documentation software. Prior to 0.80.1, authenticated users can store attacker-controlled avatarUrl values that are later reused by avatar cleanup without confinement to the intended directory on local-storage deployments. A low-privileged user can cause deletion of arbitrary local files or directories reachable by the Docmost s...  |
| <a href="#">CVE-2026-77293</a> | New    | 7.1  | HIGH |     |       |                                    | TREK is a collaborative travel planner. Prior to 3.3.0, the DELETE /api/trips/:tripId/collab/notes/:noteId/files/:fileId endpoint authorizes an authenticated user against the attacker-controlled tripId but deleteNoteFile in server/src/services/collabService.ts resolves the target only by note and file identifiers without requiring the file to belong to that trip. A user with...  |
| <a href="#">CVE-2026-82094</a> | New    | 7.1  | HIGH |     |       |                                    | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to traverse directories on the system due to improper limitation of a pathname to a restricted directory.                                                                                                                                                                                             |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-82164</a> | New    | 7.1  | HIGH |     |      |                            | Dell Trusted Device Client, versions prior to 8.1.359.0, contain an Incorrect Permission Assignment for Critical Resource vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information tampering.                                                                                                                         |
| <a href="#">CVE-2026-82585</a> | New    | 7.1  | HIGH |     |      |                            | The Botslab G980H dash camera firmware transmits sensitive information over unencrypted HTTP and RTSP connections. An attacker capable of intercepting communications on the device's WiFi network could obtain stored recordings, live video, location information, images, diagnostic logs, or other sensitive information exchanged between the device and its mobile application.        |
| <a href="#">CVE-2026-82708</a> | New    | 7.1  | HIGH |     |      |                            | The Botslab G980H dash camera firmware contains a path traversal vulnerability in its HTTP server. An attacker with access to the device's WiFi network could submit a crafted request to access files within the device's removable storage that were not intended to be directly accessible through the web server. Exposed files could include recordings, images, diagnostic logs, or... |
| <a href="#">CVE-2026-93229</a> | New    | 7.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: nfsd: add missing read barrier to rpc_status_get_dumpit seqcount retry The hand-rolled seqcount-like protocol in nfsd_nl_rpc_status_get_dumpit() is missing a read memory barrier (smp_rmb) before its second counter check. The standard kernel read_seqcount_retry() includes smp_rmb() to ensure that all data ...    |
| <a href="#">CVE-2026-93816</a> | New    | 7.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: f2fs: validate inline dentry name lengths before conversion Inline dentry conversion copies names out of the inline dentry area before checking that each recorded name length fits in the available filename slots. A corrupted image can therefore make the conversion path read past the inline filename storag...    |
| <a href="#">CVE-2026-96744</a> | New    | 7.1  | HIGH |     |      |                            | Improper neutralization of special elements in data query logic in the cache lock implementation of the MongoDB integration for Laravel can cause a caller-supplied lock owner value to be evaluated as an aggregation expression rather than as a literal value. An authenticated user who can influence the owner value an application uses when acquiring or restoring a lock may take... |
| <a href="#">CVE-2026-97437</a> | New    | 7.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ntfs3: fix out-of-bounds read in ntfs_dir_emit() and hdr_find_e() The bounds check in ntfs_dir_emit() compares fname->name_len (a character count) against e->size (a byte count) without accounting for the 2-byte-per-character UTF-16LE encoding or the ATTR_FILE_NAME header size: if (fname->name_len + siz...      |
| <a href="#">CVE-2026-97438</a> | New    | 7.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: validate index entry key bounds [BUG] A malformed NTFS directory index entry can advertise a key_size larger than the bytes actually present in its NTFS_DE payload. Directory lookup then passes that malformed key to cmp_fnames(), which can read past the end of the kmallo'ed index buffer. BUG: K...     |
| <a href="#">CVE-2026-97496</a> | New    | 7.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Fix OOB memory exposure in get_wave_state() The get_wave_state() function for v9 trusts cp_hqd_cntl_stack_size and cp_hqd_cntl_stack_offset values read directly from the MQD, which are written by GPU microcode and fully attacker-controlled on the CRIU-restore path (via AMDKFD_IOC_RESTORE_PROCES...   |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97520</a> | New    | 7.1  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: gfs2: move quota_init qc iterator increment Move qc++ from the loop body into the for-loop increment expression in gfs2_quota_init(). This keeps iterator progression explicit and avoids mixing pointer advance with duplicate-slot handling in the loop body.                                                          |
| <a href="#">CVE-2026-97731</a> | New    | 7.1  | HIGH |     |      |                            | MinIO through 7aac2a2 does not verify that every x-amz-* header present on a request also appears in the client-supplied X-Amz-SignedHeaders list. extractSignedHeaders() in cmd/signature-v4-utils.go iterates only the claimed list and never enumerates the headers that actually arrived, and thus a header that arrives unsigned is neither hashed into the canonical request nor re... |
| <a href="#">CVE-2026-79959</a> | New    | 7.0  | HIGH |     |      |                            | The Botslab G980H dash camera firmware contains a hard-coded root account password that cannot be changed by the user. An attacker who obtains the firmware or has physical access to the device could recover the credential and use it to obtain root access through the UART interface.                                                                                                   |
| <a href="#">CVE-2026-88956</a> | New    | 7.0  | HIGH |     |      |                            | The Botslab G980H dash camera firmware contains an authentication vulnerability in the root account exposed through the device's UART interface. The affected account does not require a password before granting access to a privileged system interface, and the interface also displays the device's WiFi password during startup. An unauthenticated attacker with physical access to... |
| <a href="#">CVE-2026-93796</a> | New    | 7.0  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: pcie: null RX pointers after free When iwl_pcie_tx_init() fails after RX init, nic init unwinds via iwl_pcie_rx_free(). The freed RX members stayed non-NULL on the live transport object, so later teardown or retry could touch stale RX state. Set rx_pool, global_table, rxq, and alloc_page to...   |
| <a href="#">CVE-2026-93801</a> | New    | 7.0  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: smb/client: zero-initialize stack-allocated cifs_open_info_data Stack-allocated cifs_open_info_data may contain random data. This can make some fields have wrong value if they are not set later.                                                                                                                       |
| <a href="#">CVE-2026-93810</a> | New    | 7.0  | HIGH |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: cachefiles: Fix double fput Fix a double fput() in error handling in cachefiles_create_tmpfile().                                                                                                                                                                                                                        |
| <a href="#">CVE-2026-14441</a> | New    | 6.9  | MEDI |     |      |                            | A logic flaw in Java cache key handling object comparison handling could lead to improper identifier resolution when processing specific user account structures. The issue has been remediated by updating the internal comparison routines to ensure accurate object evaluation and prevent potential identity mismatch conditions.                                                        |
| <a href="#">CVE-2026-14442</a> | New    | 6.9  | MEDI |     |      |                            | An information exposure vulnerability in the job scheduling component of SANnav allows sensitive credentials to be written to application logs in plain text. When scheduled support save jobs or related operational tasks are executed, sensitive parameters including external server passwords and archive protection keys are logged without proper masking. A local or authenticate... |
| <a href="#">CVE-2026-53493</a> | New    | 6.9  | MEDI |     |      |                            | containerd is an open-source container runtime. Prior to versions 1.7.36, 2.0.13, 2.2.9, 2.3.6, and 2.4.1, a crafted OCI index graph can force very high CPU/memory usage during PullImage (before container start), causing long ContainerCreating stalls and, at larger sizes, node/runtime instability. Versions 1.7.36, 2.0.13, 2.2.9, 2.3.6, and 2.4.1 fix the issue.                   |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-84403</a> | New    | 6.9  | MEDI |     |       |                            | The Botslab G980H dash camera firmware does not require authenticated pairing or client binding before permitting access to Bluetooth Low Energy communications and GATT characteristics. An unauthenticated attacker within Bluetooth range could intercept or directly retrieve sensitive device information, including device identifiers, firmware information, and protected WiFi cr... |
| <a href="#">CVE-2026-87118</a> | New    | 6.9  | MEDI |     |       |                            | The Botslab G980H dash camera firmware contains an out of bounds write vulnerability in its command processing functionality. An authenticated attacker with adjacent network access could submit crafted command data that corrupts memory, potentially disrupting authentication state or causing the affected process to terminate and the device to restart, resulting in a temporary... |
| <a href="#">CVE-2026-87739</a> | New    | 6.9  | MEDI |     | 0.004 |                            | An improper authentication vulnerability in PaperCut MF/NG allows an unauthenticated, remote attacker to trigger report generation. By submitting report generation requests without valid credentials, an attacker can generate reports and gain unauthorized access to sensitive information.                                                                                              |
| <a href="#">CVE-2026-97058</a> | New    | 6.9  | MEDI |     |       |                            | sprintf-js through 1.1.3 passes unbounded precision specifiers to toFixed, toExponential, and toPrecision methods without validation, causing uncaught RangeError exceptions. Attackers who control format strings can inject precision values exceeding ECMAScript limits to abort calling operations with minimal payload.                                                                 |
| <a href="#">CVE-2026-97181</a> | New    | 6.9  | MEDI |     | 0.003 |                            | GPM LIGHT developed by ezGlobal has a Sensitive Data Exposure vulnerability. Unauthenticated remote attackers can directly access system logs.                                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-26054</a> | New    | 6.8  | MEDI |     |       |                            | SumatraPDF is a multi-format reader for Windows. Prior to 3.6, the MobiDoc::ParseHeader function in src/MobiDoc.cpp validates a record using kMobiHeaderMinLen but DecodeMobiDocHeader constructs a decoder sized for kMobiHeaderLen without receiving the actual remaining buffer length. A malformed MOBI file can use an attacker-controlled header length to bypass optional-field ea... |
| <a href="#">CVE-2026-57176</a> | New    | 6.8  | MEDI |     |       | pip:social-auth-core       | Python Social Auth is a social authentication/registration mechanism. Prior to version 5.0.0, the Vend OAuth2 backend used only the numeric Vend user_id as the social-auth UID. When multiple Vend shops authenticate through the same application, users from different shops with the same internal Vend user ID could collide in the social-auth association table. A user from one s... |
| <a href="#">CVE-2026-74991</a> | New    | 6.8  | MEDI |     | 0.001 |                            | The WPForms WordPress plugin before 2.0.2 does not verify that a Stripe payment object supplied during a public form submission belongs to it before acting on it, allowing unauthenticated users to trigger a full refund and an immediate subscription cancellation against payments created by other applications on the site owner's Stripe account.                                     |
| <a href="#">CVE-2026-80338</a> | New    | 6.8  | MEDI |     | 0.001 |                            | The CMB2 WordPress plugin before 2.13.0 does not perform any capability check on one of its AJAX actions, allowing users with a role as low as Subscriber to create arbitrary WordPress options and corrupt existing ones, which can break core site settings and take the site offline. Exploitation requires the site's or another CMB2 WordPress plugin before 2.13.0 to have declare...  |
| <a href="#">CVE-2026-84283</a> | New    | 6.8  | MEDI |     |       |                            | Secure Folder 1.2 stores files selected for its password-protected vault as unencrypted files in the Android shared-storage tree. A local application or file manager that has access to the relevant shared-storage path can enumerate, copy, and open those files without authenticating to Secure Folder.                                                                                 |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-88916</a> | New    | 6.8  | MEDI |     |       |                            | Incorrect Authorization vulnerability in TÜB■TAK ULAKB■M UlakPDF allows Privilege Escalation. This issue affects UlakPDF: through 09092026.                                                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-89002</a> | New    | 6.8  | MEDI |     | 0.002 |                            | The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.26 does not sanitize and escape content it retrieves from a user-supplied source before rendering it, which could allow users such as contributors to perform Stored Cross-Site Scripting attacks against higher-privileged users who review the campaign.                                                                        |
| <a href="#">CVE-2026-89005</a> | New    | 6.8  | MEDI |     | 0.002 |                            | The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.26 does not sanitize and escape one of its campaign configuration fields when a certain feature is enabled, which allows users with the Contributor role and above to perform Stored Cross-Site Scripting attacks that execute in the session of any higher-privileged user who later views the campaign.                         |
| <a href="#">CVE-2026-92680</a> | New    | 6.8  | MEDI |     |       |                            | Araxis Merge for Windows version 2011.4074 through 2026.0 stores user-configured credentials for remote servers in the Windows registry and does not apply sufficient cryptographic protection. An authenticated, non-administrative attacker could retrieve and unencrypt all credentials the target user has stored in Merge.                                                              |
| <a href="#">CVE-2026-93290</a> | New    | 6.8  | MEDI |     |       |                            | Omni C20 uses hard-coded credentials that could allow an attacker to monitor log files to obtain credentials to access information like mapping data.                                                                                                                                                                                                                                        |
| <a href="#">CVE-2026-94416</a> | New    | 6.8  | MEDI |     |       |                            | An authorization bypass was found in the Ansible Automation Platform (AAP) gateway. The gateway API allows an authenticated administrator to create a new service key for the Controller service cluster. Because service-key creation is not restricted to the installer-provisioned provisioning path, an administrator-issued key is cryptographically indistinguishable from a legiti... |
| <a href="#">CVE-2026-79761</a> | New    | 6.6  | MEDI |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 1.7.0 until 2.5.1, the Termix SSH key deployment flow derives a grep pattern from a user-controlled public-key token and interpolates it into double-quoted shell commands executed on the selected target host. In src/backend/database/routes/credential-deploy-rout... |
| <a href="#">CVE-2026-97177</a> | New    | 6.6  | MEDI |     | 0.002 |                            | A flaw was found in the user update mechanism of the Keycloak Admin REST API. When Fine-Grained Admin Permissions are enabled, the system fails to check for specific password reset authorizations during a general user profile update. This allows a delegated administrator, who should be restricted from resetting passwords, to change a user's credentials and take over their ac... |
| <a href="#">CVE-2026-4806</a>  | New    | 6.5  | MEDI |     |       |                            | The Custom Thank You Page for WooCommerce plugin for WordPress is vulnerable to unauthorized access and loss of data due to a missing capability check on the save_option() function in all versions up to, and including, 1.1.2. This makes it possible for unauthenticated attackers to to export or reset(delete) the plugin's settings.                                                  |
| <a href="#">CVE-2026-54461</a> | New    | 6.5  | MEDI |     |       |                            | Habitica is a habit tracker application that treats goals like a role-playing game. From 4.172.1 until 5.48.2, a query parameter on Habitica's /api/v3/groups/:groupId/members route is not sanitized before being interpreted as a regular expression. An authenticated caller can supply a computationally expensive regular expression that degrades application performance or halts ... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                            |
|--------------------------------|--------|------|------|-----|-------|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-61811</a> | New    | 6.5  | MEDI |     |       |                            | Wazuh is an open-source security platform providing unified XDR and SIEM protection for endpoints and cloud workloads. From 3.8.0 until 4.14.7, the <code>_getattributes()</code> function in <code>src/os_xml/os_xml.c</code> recursively processes every XML attribute without a depth limit while allocating two large local buffers in each stack frame. An enrolled agent can submit a Windows EventChannel ev... |
| <a href="#">CVE-2026-65422</a> | New    | 6.5  | MEDI |     |       |                            | A flaw in the authorization mechanism for Media Gateway API in Genetec Security Center may allow a user with no playback privileges to generate video thumbnails.                                                                                                                                                                                                                                                      |
| <a href="#">CVE-2026-65827</a> | New    | 6.5  | MEDI |     |       |                            | Docmost is open-source collaborative wiki and documentation software. From 0.21.0 until 0.95.0, any authenticated workspace member with edit rights to a space can upload an archive to the page-import feature whose ZIP extraction routine does not limit total uncompressed size, per-entry size, or entry count. The extractor writes entries to the server temp directory and automa...                           |
| <a href="#">CVE-2026-76907</a> | New    | 6.5  | MEDI |     |       |                            | LaSuite Doc is a collaborative note taking, wiki and documentation platform. From 4.8.2 until 5.4.0, <code>GET /api/v1.0/documents/search/</code> accepts sequential seven-digit document paths to scope descendant searches without requiring the caller to possess the public document UUID. An unauthenticated caller can submit an empty search query and iterate predictable path values to enume...              |
| <a href="#">CVE-2026-77798</a> | New    | 6.5  | MEDI |     |       |                            | Velociraptor contains a deadlock condition that may be triggered by authenticated users. The issue stems from a lock management bug in the user management module.                                                                                                                                                                                                                                                     |
| <a href="#">CVE-2026-78313</a> | New    | 6.5  | MEDI |     | 0.005 |                            | Improper Access Control in DIAEnergie. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                                                                                              |
| <a href="#">CVE-2026-82195</a> | New    | 6.5  | MEDI |     | 0.001 |                            | The 10Web Booster WordPress plugin before 2.34.0 does not restrict access to the routine which issues the shared secret that authenticates its cloud connection, disclosing that secret to unauthenticated visitors and letting them delete it repeatedly, preventing an administrator from completing a legitimate connection.                                                                                        |
| <a href="#">CVE-2026-91133</a> | New    | 6.5  | MEDI |     |       |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, authenticated users could supply unescaped SQL LIKE metacharacters to upload-resolution patterns, causing wildcard input to select unrelated upload records instead of matching a literal identifier. The affected upload metadata, URL-lookup, and cooked-video-placeholder paths ...                           |
| <a href="#">CVE-2026-93541</a> | New    | 6.5  | MEDI |     |       |                            | An out-of-bounds read in libXi's <code>XQueryDeviceState()</code> in libXi before 1.8.4 could be used by a                                                                                                                                                                                                                                                                                                             |
| <a href="#">CVE-2026-93542</a> | New    | 6.5  | MEDI |     |       |                            | An out-of-bounds read in libXi's <code>XI2</code> class parsing via <code>size_classes()</code> and <code>copy_classes()</code> in libXi before 1.8.4 could be used by malicious servers to crash the X client.                                                                                                                                                                                                        |
| <a href="#">CVE-2026-93544</a> | New    | 6.5  | MEDI |     |       |                            | An out-of-bounds read in libXi's <code>XI2</code> <code>XIQueryDevice</code> reply parsing in libXi before 1.8.4 can be used by a malicious X server to crash an attached X client.                                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-93545</a> | New    | 6.5  | MEDI |     |       |                            | An out-of-bounds read in libXi's <code>XListInputDevices()</code> in libXi before 1.8.4 could be used by malicious X servers to crash an attached X client.                                                                                                                                                                                                                                                            |
| <a href="#">CVE-2026-94281</a> | New    | 6.5  | MEDI |     |       |                            | An out-of-bounds read in libXi's <code>XListInputDevices()</code> class parsing in libXi before 1.8.4 could be used by malicious X servers to crash an attached X client.                                                                                                                                                                                                                                              |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2025-14814</a> | New    | 6.4  | MEDI |     |       |                            | The CSS & JavaScript Toolbox plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the plugin's cjtoolbox shortcode in all versions up to, and including, 12.0.6 due to insufficient input sanitization and output escaping on user supplied attributes. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary...  |
| <a href="#">CVE-2026-15731</a> | New    | 6.4  | MEDI |     | 0.003 |                            | The WP Multilang – Translation and Multilingual Plugin plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the post content in all versions up to, and including, 2.4.31 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with Contributor-level access and above, to inject arbitrary web scripts in pa...  |
| <a href="#">CVE-2026-57175</a> | New    | 6.4  | MEDI |     |       | pip:social-auth-core       | Python Social Auth is a social authentication/registration mechanism. Prior to version 5.0.0, the SAML backend accepted SAML responses on the Assertion Consumer Service endpoint without verifying that they matched a previously issued `AuthnRequest`. Applications using SAML account association could allow an attacker with a valid account on a trusted IdP to link the attacker'...  |
| <a href="#">CVE-2026-79760</a> | New    | 6.4  | MEDI |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 2.5.0 until 2.5.1, Termix allows authenticated users to configure webhook or ntfy notification channels with attacker-controlled destination URLs and trigger server-side requests through the notification-channel test endpoint. The request path in src/backend/dat...  |
| <a href="#">CVE-2026-85417</a> | New    | 6.4  | MEDI |     |       |                            | Incomplete property masking in the SANnav logging subsystem permits SNMP authentication and privacy passwords to be recorded in application logs under specific configuration conditions. Individuals with read access to system logs or support bundles can retrieve these credentials, leading to unauthorized read or management access to monitored switch environments                   |
| <a href="#">CVE-2026-91119</a> | New    | 6.4  | MEDI |     |       |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, the topic small-action and nested-activity-log components interpolated the free-form action_code_who value into mention-link href attributes without URL encoding. A quote-bearing display name could terminate the intended URL attribute and inject attacker-controlled elements ...  |
| <a href="#">CVE-2026-91161</a> | New    | 6.4  | MEDI |     |       |                            | OpenWA is a free, open source, self-hosted WhatsApp API gateway. Prior to 0.23.5, the GET /api/sessions/{sessionId}/groups/{groupId}/invite-code endpoint and the GroupGetInviteCode MCP tool have no OPERATOR role requirement, allowing a valid VIEWER key scoped to a session to retrieve an active group invite code. The invite code is a transferable WhatsApp bearer capability, s...  |
| <a href="#">CVE-2026-85738</a> | New    | 6.3  | MEDI |     |       |                            | TREK is a collaborative travel planner. Prior to 3.4.0, the checkSsrF logic in server/src/utills/ssrfGuard.ts does not recognize NAT64, 6to4, or Teredo IPv6 transition addresses that encode an IPv4 destination. An authenticated user who controls a DNS record can supply a URL whose AAAA result is a transition address embedding a private, loopback, or link-local IPv4 target, an... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-96745</a> | New    | 6.3  | MEDI |     |      |                            | Deserialization of untrusted data in the command monitoring support of the MongoDB PHP Driver can cause class names embedded in document content to be honored when the driver builds monitoring event objects. When an application registers a command monitoring subscriber and includes untrusted data in a database operation, an unauthenticated party who controls that data may ca...  |
| <a href="#">CVE-2026-97225</a> | New    | 6.3  | MEDI |     |      |                            | A flaw has been found in DbGate up to 7.2.5-beta.5. This affects an unknown function of the file packages/api/src/controllers/runners.js of the component JSON Runner. Executing a manipulation of the argument comment.text/script.schedule can lead to code injection. The attack may be performed from remote. Upgrading to version 7.2.5-beta.6 mitigates this issue. This patch is c...  |
| <a href="#">CVE-2026-97232</a> | New    | 6.3  | MEDI |     |      |                            | A vulnerability was determined in volotat Anagnorisis up to 0.4.2. Affected by this vulnerability is the function get_file_content/save_file_content/move_files/start_streaming of the file page.html. This manipulation causes path traversal. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about t...  |
| <a href="#">CVE-2026-97320</a> | New    | 6.3  | MEDI |     |      |                            | A flaw has been found in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. The affected element is the function AiKnowledgeDocumentServiceImpl.readUrl of the file AiKnowledgeDocumentServiceImpl.java of the component AI Knowledge Module. This manipulation of the argument url causes server-side request forgery. The attack is possible to be carried out remotely. The exploit has...  |
| <a href="#">CVE-2026-97321</a> | New    | 6.3  | MEDI |     |      |                            | A vulnerability has been found in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. The impacted element is the function GoViewDataServiceImpl.getDataBySQL of the file yuda o-module-report/src/main/java/cn/iocoder/yudao/module/report/service/goview/GoViewDataServiceImpl.java of the component GoView Data Endpoint. Such manipulation of the argument sql leads to sql injection. T... |
| <a href="#">CVE-2026-97365</a> | New    | 6.3  | MEDI |     |      |                            | A vulnerability was determined in chonkie-inc littrs 0.6.1/0.6.2. Impacted is the function Sandbox::mount of the file crates/littrs/src/lib.rs. Executing a manipulation of the argument relative can lead to path traversal. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure ...  |
| <a href="#">CVE-2026-97366</a> | New    | 6.3  | MEDI |     |      |                            | A security flaw has been discovered in jhen0409 react-native-debugger up to 0.14.0. The impacted element is the function openDevTools of the file electron/window.js of the component Open in Editor Handler. The manipulation of the argument host results in os command injection. It is possible to launch the attack remotely. The exploit has been released to the public and may be...  |
| <a href="#">CVE-2026-97368</a> | New    | 6.3  | MEDI |     |      |                            | A weakness has been identified in chillzhuang SpringBlade up to 5.0.2. This affects the function UserServiceImpl.userInfo of the file blade-service/blade-system/src/main/java/org/springblade/system/service/impl/UserServiceImpl.java of the component user-auth-info Endpoint. This manipulation of the argument userId causes authorization bypass. The attack can be initiated remot...  |
| <a href="#">CVE-2026-6544</a>  | New    | 6.2  | MEDI |     |      |                            | IBM Concert 1.0.0 through 3.0.0 allows recursive copying of directories without proper controls which can lead to unintentional inclusion of sensitive or unnecessary files and increased attack surface.                                                                                                                                                                                     |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-61784</a> | New    | 6.1  | MEDI |     |       | npm:xhtml-purifier         | xhtml-purifier is a Node.js library to take in raw/unknown/untrusted HTML and output cleaned, purified, trusted HTML. Versions prior to 0.4.3 do not HTML-entity-encode attribute values when serializing its sanitized output. In attributeString() (XHTMLPurifier.js, around line 148) the attribute value is concatenated directly into a double-quoted attribute without encoding. As... |
| <a href="#">CVE-2026-93405</a> | New    | 6.1  | MEDI |     |       |                            | Mailspring is a fast, cross-platform, open-source email client. Prior to 1.17.0, attachment quick preview converts Markdown, DOCX, and XLSX attachments with Snarkdown, Mammoth, and SheetJS and inserts the resulting HTML into the preview document through innerHTML without sanitization. A remote sender can craft a supported attachment whose converted HTML executes script when ... |
| <a href="#">CVE-2026-67233</a> | New    | 6.0  | MEDI |     |       |                            | RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.1, The shovel management resource's is_authorized/2 delegates to rabbit_mgmt_util:is_authorized_monitor/2, which accepts the monitoring tag. But allowed_methods includes DELETE, and delete_resource/2 deletes / restarts shovel runtime parameters with no additional role chec... |
| <a href="#">CVE-2026-75558</a> | New    | 6.0  | MEDI |     |       |                            | The Botslab G980H dash camera firmware uses a hard-coded cryptographic key and initialization vector to protect WiFi credentials communicated by the device. An attacker who obtains the protected credential and extracts the cryptographic material from the firmware could recover the WiFi password and gain unauthorized access to the device network.                                  |
| <a href="#">CVE-2026-88761</a> | New    | 6.0  | MEDI |     |       |                            | The Botslab G980H dash camera firmware generates the default WiFi password using predictable device information, portions of which are advertised by the product. An unauthenticated attacker within WiFi range could potentially determine the remaining password characters through limited guessing and gain unauthorized access to the device network.                                   |
| <a href="#">CVE-2026-77703</a> | New    | 5.9  | MEDI |     |       |                            | Key exchange without entity authentication vulnerability in HAVELSAN Inc. Liman Render Engine allows Adversary in the Middle (AiTM). This issue affects Liman Render Engine: from 1.0 before 1.2-75.                                                                                                                                                                                         |
| <a href="#">CVE-2026-77707</a> | New    | 5.9  | MEDI |     |       |                            | Improper certificate validation vulnerability in HAVELSAN Inc. Liman Render Engine allows Adversary in the Middle (AiTM). This issue affects Liman Render Engine: from 1.0 before 1.2-75.                                                                                                                                                                                                    |
| <a href="#">CVE-2026-81645</a> | New    | 5.9  | MEDI |     | 0.001 |                            | Out-of-bounds read vulnerability in the graphics module. Successful exploitation of this vulnerability may affect availability.                                                                                                                                                                                                                                                              |
| <a href="#">CVE-2026-79762</a> | New    | 5.5  | MEDI |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 1.7.0 until 2.5.1, Termix derives the keys that wrap OIDC and WebAuthn users' Data Encryption Keys from committed default strings and the public userId salt in src/backend/utils/user-crypto.ts. Because OIDC_SYSTEM_SECRET and WEBAUTHN_SYSTEM_SECRET are not config... |
| <a href="#">CVE-2026-88384</a> | New    | 5.5  | MEDI |     |       |                            | OpenEXR 3.4.14 contains a NULL Pointer Dereference in the C++ attribute parsing path. A specially crafted EXR file containing an unknown-type attribute with dataSize set to zero causes the parser to create an opaque attribute with a NULL packed_data pointer. The OpaqueAttribute constructor passes the NULL pointer to memcpy() without validating the zero-size condition, result... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-96873</a> | New    | 5.5  | MEDI |     |       |                            | Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Mediawiki - CirrusSearch extension allows Reflected XSS. This issue affects Mediawiki - CirrusSearch extension through 1.46.0.                                                                                                                                                         |
| <a href="#">CVE-2026-97182</a> | New    | 5.5  | MEDI |     |       |                            | A security vulnerability has been detected in halo-dev Halo up to 2.25.4/2.26.1. Affected is an unknown function of the file application/src/main/java/run/halo/app/content/comment/ReplyNotificationSubscriptionHelper.java of the component SpEL Handler. Such manipulation leads to improper neutralization. The attack may be performed from remote. The exploit has been disclosed p... |
| <a href="#">CVE-2026-18335</a> | New    | 5.4  | MEDI |     | 0.003 |                            | The Kirki – Freeform Page Builder, Website Builder & Customizer plugin for WordPress is vulnerable to Blind Server-Side Request Forgery in all versions up to, and including, 6.2.0 via the 'kirki_data' Parameter. This makes it possible for unauthenticated attackers to make web requests to arbitrary locations originating from the web application and can be used to query and mo... |
| <a href="#">CVE-2026-47132</a> | New    | 5.4  | MEDI |     |       | composer:thorsten/phpmyfaq | phpMyFAQ is an open source FAQ web application. Prior to version 4.2.0-alpha, an authenticated SQL LIKE wildcard injection vulnerability in phpMyFAQ's chat user search allows any logged-in user to bypass the intended display-name search filter and enumerate active users. The endpoint escapes SQL string syntax but does not escape `%` and `_`, which remain active `LIKE` wildc...  |
| <a href="#">CVE-2026-48540</a> | New    | 5.4  | MEDI |     |       |                            | Krayin CRM through 2.2.6 contains a stored client-side template injection vulnerability that allows authenticated attackers to execute arbitrary JavaScript in other users' browsers by injecting Vue.js template expressions into the lead title field. Attackers can craft a lead title containing double-brace template syntax that reaches the Vue template compiler, enabling protot... |
| <a href="#">CVE-2026-48541</a> | New    | 5.4  | MEDI |     |       |                            | Krayin CRM through 2.2.6 contains a stored client-side template injection vulnerability that allows authenticated attackers to execute arbitrary JavaScript in other users' browsers by injecting Vue.js template expressions into the person name field. Attackers can craft a person name containing double-brace template syntax that reaches the Vue template compiler, enabling prot... |
| <a href="#">CVE-2026-48542</a> | New    | 5.4  | MEDI |     |       |                            | Krayin CRM through 2.2.6 contains a stored client-side template injection vulnerability that allows authenticated attackers to execute arbitrary JavaScript in other users' browsers by injecting Vue.js template expressions into the product name field. Attackers can craft a product name containing double-brace template syntax that reaches the Vue template compiler, enabling pr... |
| <a href="#">CVE-2026-48543</a> | New    | 5.4  | MEDI |     |       |                            | Krayin CRM through 2.2.6 contains a stored client-side template injection vulnerability that allows authenticated attackers to execute arbitrary JavaScript in other users' browsers by injecting Vue.js template expressions into the web form description field. Attackers can craft a web form description containing double-brace template syntax that reaches the Vue template compi... |
| <a href="#">CVE-2026-79758</a> | New    | 5.4  | MEDI |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 1.8.0 until 2.5.1, authenticated Termix users can access the server-stats API without per-host authorization. GET /status returns statuses for hosts the requester cannot access, GET /status/:id accepts an attacker-supplied numeric host identifier, and POST /clea... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-91120</a> | New    | 5.4  | MEDI |     |       |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, provider-controlled video titles in lazy video embeds could be reparsed as HTML when Discourse generated notification emails or chat summaries. A user with standard posting privileges could create a post for an enabled YouTube, Vimeo, or TikTok provider whose title contained... |
| <a href="#">CVE-2026-91134</a> | New    | 5.4  | MEDI |     |       |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, the Discourse post sanitizer allowed a stored cross-origin iframe to bypass the allowed_iframes prefix policy when the iframe src contained encoded userinfo. The sanitizer validated a decoded form differently from the stored iframe src, allowing the browser to interpret an a... |
| <a href="#">CVE-2026-97723</a> | New    | 5.4  | MEDI |     |       |                            | madpsy ka9q_ubersdr before 0.1.58 has a stored cross-site scripting (XSS) vulnerability in the chat message rendering functionality. User-controlled URLs in chat messages were insufficiently neutralized before being converted into HTML links. Quotation characters could break out of the generated href attribute and introduce attacker-controlled HTML attributes, allowing arbit... |
| <a href="#">CVE-2026-97736</a> | New    | 5.4  | MEDI |     |       |                            | tinyauth before 5.1.3 allows rule bypass by appending an allowed route string. This is caused by an unanchored regular expression.                                                                                                                                                                                                                                                           |
| <a href="#">CVE-2026-19532</a> | New    | 5.3  | MEDI |     |       |                            | Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in HAVELSAN Inc. Liman MYS allows Path Traversal. This issue affects Liman MYS: from 2.3.2 before 2.3.4-1124.                                                                                                                                                                                   |
| <a href="#">CVE-2026-48072</a> | New    | 5.3  | MEDI |     |       |                            | Docmost is open-source collaborative wiki and documentation software. Prior to 0.80.1, the public avatar and logo image endpoint accepts attacker-controlled fileName path segments and resolves them against local storage without confinement to the intended image directory. An unauthenticated attacker can traverse outside the avatar or logo directory and read local storage obj... |
| <a href="#">CVE-2026-77320</a> | New    | 5.3  | MEDI |     |       |                            | TREK is a collaborative travel planner. Prior to 3.3.0, getSharedTripData in server/src/services/shareService.ts returns days, assignments, dayNotes, and places through GET /api/shared/:token even when the trip owner disables share_map. The client hides the map, but the public JSON response still includes the itinerary and place names, coordinates, addresses, descriptions, n... |
| <a href="#">CVE-2026-79763</a> | New    | 5.3  | MEDI |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 2.4.0 until 2.5.1, the POST /users/totp/disable and POST /users/totp/backup-codes endpoints accept the account password as the sole reauthentication factor after a 2.4.0 refactor regressed the two-factor check introduced for CVE-2026-45749. In src/backend/databa... |
| <a href="#">CVE-2026-88846</a> | New    | 5.3  | MEDI |     | 0.001 |                            | The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not check whether user registration is enabled on the site before creating an account through one of its front-end registration flows, allowing unauthenticated users to create accounts, and be logged into them, on sites where registration has been deliberately disabled.                                      |
| <a href="#">CVE-2026-92905</a> | New    | 5.3  | MEDI |     | 0.024 |                            | ZohoCorp ManageEngine EventLog Analyzer and Log360 before build 13071 were vulnerable to a DoS vulnerability that allowed attackers to crash the log collector using malformed syslog packets.                                                                                                                                                                                               |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93353</a> | New    | 5.3  | MEDI |     |      |                            | copyparty contains a volume restriction bypass vulnerability in its SFTP front end that allows authenticated SFTP users to create, remove, and truncate arbitrary paths outside permitted volume boundaries by exploiting three handlers that bypass the xvolf flag enforcement. The _mkdir, _rmdir, and _chattr handlers construct destination paths using vfs.get(), vn.canonical(), ...   |
| <a href="#">CVE-2026-96747</a> | New    | 5.3  | MEDI |     |      |                            | The client-side field level encryption support in the MongoDB Python Driver can treat a key management endpoint value ending in ".sock" as a local Unix domain socket path rather than a remote host. A user with write access to the encryption key metadata stored in the database can cause an application using the driver to open connections to local sockets on the application ho... |
| <a href="#">CVE-2026-97226</a> | New    | 5.3  | MEDI |     |      |                            | A vulnerability has been found in DbGate up to 7.2.5/7.3.1-premium-beta.1. This impacts the function fs.readFile of the file packages/api/src/controllers/files.js of the component files-style Endpoint. The manipulation of the argument filePath/uri leads to path traversal. It is possible to initiate the attack remotely. The vendor was contacted early about this disclosure but... |
| <a href="#">CVE-2026-97647</a> | New    | 5.3  | MEDI |     |      |                            | A security vulnerability has been detected in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. This impacts an unknown function of the file user/editLog.php. Such manipulation of the argument sid/addtime/type/reason/detail/logdate leads to authorization bypass. The attack may be performed from remote. The exploit has been disclosed publicl... |
| <a href="#">CVE-2026-97724</a> | New    | 5.3  | MEDI |     |      |                            | A prototype pollution vulnerability in Software Mansion React Native Worklets before 0.12.2 allows an attacker-controlled object containing a __proto__ property to modify the prototype of an object created during serialization in clonePlainJSObject in packages/react-native-worklets/src/memory/serializable.native.ts. When affected data is subsequently processed by React Nativ... |
| <a href="#">CVE-2026-52853</a> | New    | 5.2  | MEDI |     |      |                            | Docmost is open-source collaborative wiki and documentation software. Prior to 0.90.1, an authenticated workspace ADMIN can use the workspace invitation flow to invite an external email address with the OWNER role because the role ceiling does not prevent ADMIN users from granting privileges above their own. When the invitation is accepted, the new account receives OWNER-lev... |
| <a href="#">CVE-2026-17413</a> | New    | 5.1  | MEDI |     |      |                            | IBM PowerVM Hypervisor FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, FW1060.00 through FW1060.81, and FW950.00 through FW950.H3 is affected by a vulnerability in the RTAS firmware-to-OS interface. An attacker with administrator-level (root) access to a logical partition can send a specially crafted request to partition firmware, causing the partition to crash and... |
| <a href="#">CVE-2026-17503</a> | New    | 5.1  | MEDI |     |      |                            | IBM PowerVM Hypervisor FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, FW1060.00 through FW1060.81, and FW950.00 through FW950.H3 is affected by a vulnerability in the partition firmware runtime boot configuration. An attacker with root access to a partition can maliciously alter partition nvram, causing the partition to fail to boot. This condition persists until ... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-17504</a> | New    | 5.1  | MEDI |     |      |                            | IBM PowerVM Hypervisor FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, FW1060.00 through FW1060.81, and FW950.00 through FW950.H3 is affected by a vulnerability in the partition firmware runtime. An attacker with root access to a partition can send a specially crafted request to the partition firmware runtime, causing it to crash with possible memory corruption.        |
| <a href="#">CVE-2026-4637</a>  | New    | 5.1  | MEDI |     |      |                            | Paessler PRTG Network Monitor before version 26.2.120.1449 is affected by a reflected Cross-Site Scripting (XSS) vulnerability. When a request is made for a non-existent resource ending in \".html\", the web interface returns an HTTP 403 \"Forbidden Path\" error page that echoes the requested URL path into the HTML response body without proper output encoding or sanitization.... |
| <a href="#">CVE-2026-82716</a> | New    | 5.1  | MEDI |     |      |                            | The Botslab G980H dash camera firmware includes sensitive configuration information, including WiFi credentials, in diagnostic logs generated during the support process. These logs remain accessible on removable storage after the support operation has completed. An unauthenticated attacker with physical access to the storage media could retrieve the logs and obtain sensitive...  |
| <a href="#">CVE-2026-97062</a> | New    | 5.1  | MEDI |     |      |                            | Aureus ERP through 1.6.0 stores uploaded SVG files on its public disk and serves them from the application origin, allowing authenticated users to upload malicious SVG files containing JavaScript. Attackers can craft SVG files with script elements that execute in the application's origin when the file URL is opened directly, enabling session cookie theft and CSRF token exfil...  |
| <a href="#">CVE-2026-97732</a> | New    | 5.1  | MEDI |     |      |                            | IRONMACE Ironshield 1.0.0.167 has a tvk.sys kernel-mode driver that authenticates client executables by checking for expected publisher and root-certificate strings in WIN_CERTIFICATE data ("IRONMACE Co., Ltd." and "DigiCert Trusted Root G4") instead of parsing and validating the PKCS signature data. As a result, a local unprivileged attacker may bypass this via crafted cert...  |
| <a href="#">CVE-2026-91121</a> | New    | 5.0  | MEDI |     |      |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, attacker-controlled upload filenames used in chat message excerpts were rendered as unescaped HTML. A user able to upload a file and send chat content could place markup in a filename that was then interpreted by chat channel lists, chat summary emails, pinned message bars, ...  |
| <a href="#">CVE-2026-77825</a> | New    | 4.9  | MEDI |     |      |                            | IBM ContextForge MCP Gateway 1.0.0 through 1.0.8 was vulnerable to path traversal in its Admin API log-download endpoint (`GET /v1/admin/logs/file`). The path confinement check uses `str.startswith()` rather than proper boundary validation, allowing an authenticated admin to read `.log`, `.jsonl`, and `.json` files outside the configured `LOG_FOLDER` by supplying a filename ...  |
| <a href="#">CVE-2026-97649</a> | New    | 4.7  | MEDI |     |      |                            | A flaw has been found in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this vulnerability is an unknown functionality of the file example_lite.sql. Executing a manipulation can lead to use of default credentials. It is possible to launch the attack remotely. The exploit has been published and may be used. The project was inf...  |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-79680</a> | New    | 4.5  | MEDI |     |      |                            | Authentication bypass vulnerability in the password authentication mechanism of the Qt VNC Server module. An attacker using a specially modified VNC client that violates the RFB protocol can bypass Qt VNC Server's password authentication and gain unauthorized remote access to the shared application, compromising the confidentiality and integrity of the session.                  |
| <a href="#">CVE-2026-56792</a> | New    | 4.4  | MEDI |     |      |                            | Dell Rugged Control Center (RCC), versions prior to 5.2.206, contain an Improper Authorization vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of Privileges.                                                                                                                                                  |
| <a href="#">CVE-2025-32000</a> | New    | 4.3  | MEDI |     |      |                            | HCL Sametime is vulnerable to insufficient input sanitization. The application did not appropriately sanitize user input. When user input is implicitly or explicitly trusted without sufficient sanitization, malicious actors can leverage this vulnerability.                                                                                                                             |
| <a href="#">CVE-2026-16302</a> | New    | 4.3  | MEDI |     |      |                            | The Spectra Legacy – Gutenberg Blocks plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 2.20.0 via the editor_assets function, which exposes the uag_insta_linked_accounts option through the uagb_blocks_info object without a capability check. This makes it possible for authenticated attackers, with Contributor-level ac...  |
| <a href="#">CVE-2026-18870</a> | New    | 4.3  | MEDI |     |      |                            | IBM PowerVM Hypervisor FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, FW1060.00 through FW1060.81, and FW950.00 through FW950.H3 could allow a remote attacker to obtain sensitive information due to an out-of-bounds read.                                                                                                                                                      |
| <a href="#">CVE-2026-3253</a>  | New    | 4.3  | MEDI |     |      |                            | The MailerLite – Signup forms (official) plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on the forms() method of the AdminController class in all versions up to, and including, 1.7.21. This makes it possible for authenticated attackers, with Contributor-level access and above, to create or delete arbitrary signup forms. |
| <a href="#">CVE-2026-48073</a> | New    | 4.3  | MEDI |     |      |                            | Docmost is open-source collaborative wiki and documentation software. From 0.70.0 until 0.80.1, a low-privileged authenticated user who can edit an exportable page can embed a forged attachmentId that belongs to a restricted page in the same space. Exporting the attacker-controlled page with includeAttachments=true causes the page export flow to read the restricted attachmen... |
| <a href="#">CVE-2026-52850</a> | New    | 4.3  | MEDI |     |      |                            | Docmost is open-source collaborative wiki and documentation software. Prior to 0.90.1, an authenticated workspace member who does not belong to a private space can call the transclusion / sync-block lookup API with a known sourcePageId and transclusionId pair because the lookup does not enforce private space membership before resolving the source page. The API can return con... |
| <a href="#">CVE-2026-57177</a> | New    | 4.3  | MEDI |     |      | pip:social-auth-core       | Python Social Auth is a social authentication/registration mechanism. Prior to version 5.0.0, the LoginRadius backend did not validate OAuth state during the authentication flow. Applications using this backend were vulnerable to login CSRF. An attacker could cause a victim's browser session to complete authentication using an attacker-controlled LoginRadius token, making th... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package  | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-62286</a> | New    | 4.3  | MEDI |     |       | go:github.com/amir20/dozzle | Dozzle is a realtime log viewer for docker containers. Prior to 10.6.7, streamEvents in internal/web/events.go applies a restricted user's label filter to container lists but not to the container-stat and container-event channels returned by GET /api/events/stream. In a simple-auth deployment using per-user filters, any authenticated restricted account can receive resource t... |
| <a href="#">CVE-2026-77321</a> | New    | 4.3  | MEDI |     |       |                             | TREK is a collaborative travel planner. Prior to 3.3.0, the get_trip_summary tool in server/src/mcp/tools/trips.ts is registered for scoped OAuth MCP tokens without requiring trips:read and returns core trip summary data regardless of the delegated scopes. A token granted only an unrelated capability, such as weather:read, can receive trip metadata, member email addresses fr... |
| <a href="#">CVE-2026-78310</a> | New    | 4.3  | MEDI |     | 0.002 |                             | Authorization Bypass Through User-Controlled Key in DIAEnergie. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                                           |
| <a href="#">CVE-2026-79759</a> | New    | 4.3  | MEDI |     |       |                             | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 1.7.0 until 2.5.1, the POST /credentials/:id/deploy-to-host endpoint resolves credential and target-host records from attacker-controlled credentialId and targetHostId integer values without checking that either record belongs to the requesting user. In src/back... |
| <a href="#">CVE-2026-81508</a> | New    | 4.3  | MEDI |     |       |                             | ESF-IDF is the Espressif Internet of Things (IoT) Development Framework. In 5.5.5, 6.0.1, and 6.1, the BlueDroid A2DP sink function btc_a2dp_sink_handle_inc_media() reads a timestamp field from the received media buffer before validating that the packet layout contains the field. A paired BR/EDR audio source within radio range can send a malformed A2DP media packet to a buil... |
| <a href="#">CVE-2026-82849</a> | New    | 4.3  | MEDI |     | 0.001 |                             | The Masteriyo LMS WordPress plugin before 3.4.2 does not verify that the user making the request owns the course-progress records being returned, allowing any authenticated user, such as a self-registered subscriber, to read another user's learning activity. The ownership check it applies is skipped whenever the requested account is not named with a non-zero value, in which...  |
| <a href="#">CVE-2026-82850</a> | New    | 4.3  | MEDI |     | 0.001 |                             | The Masteriyo LMS WordPress plugin before 3.4.2 does not restrict access to quiz answer keys, allowing any authenticated user, such as a student, to retrieve the correct answers for any quiz on the site, including quizzes in courses they are not enrolled in. The redaction that hides them is applied only to a fixed list of question types, so the answers to every other type a...  |
| <a href="#">CVE-2026-88845</a> | New    | 4.3  | MEDI |     | 0.001 |                             | The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not perform any capability or nonce checks on an administrative maintenance action, allowing any authenticated user, such as a subscriber, to trigger it and create published content on the site attributed to their own account.                                                                                  |
| <a href="#">CVE-2026-88847</a> | New    | 4.3  | MEDI |     | 0.001 |                             | The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not verify that a user is enrolled in a course before recording lesson completions against it, allowing any authenticated user, such as a subscriber, to create course progress records for courses they have no access to.                                                                                         |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-91132</a> | New    | 4.3  | MEDI |     |       |                            | Discourse is an open-source discussion platform. Prior to 2026.1.8, 2026.6.3, 2026.7.2, and 2026.8.0, sites using wildcard patterns in the allowed_iframes setting could accept a crafted iframe URL whose allowlisted suffix appeared after a URL authority separator. The wildcard origin check matched the allowed domain text, while browser URL parsing selected a different attacke... |
| <a href="#">CVE-2026-93662</a> | New    | 4.3  | MEDI |     | 0.001 |                            | The Events Manager WordPress plugin before 7.4.5 does not force the scope of its logged-in event and location search when a caller supplies their own owner value, letting a low-privileged user read other accounts' unpublished, pending or trashed event and venue content, including full street addresses.                                                                              |
| <a href="#">CVE-2026-97061</a> | New    | 4.3  | MEDI |     |       |                            | Black Candy through 3.2.1 fails to scope playlist search queries to the authenticated session user, allowing any authenticated user to enumerate all playlists on the instance. Attackers can query the SearchController or Search::PlaylistsController endpoints with blank or targeted search parameters to retrieve playlist names belonging to other users without authorization.        |
| <a href="#">CVE-2026-97311</a> | New    | 4.3  | MEDI |     |       |                            | A flaw was found in the Admin REST API of Keycloak, an identity and access management solution. The endpoints used to retrieve groups associated with a specific role do not properly check for individual group visibility permissions. This allows a delegated administrator with basic search privileges to view detailed information about all groups assigned to a role, bypassing i... |
| <a href="#">CVE-2026-97322</a> | New    | 4.3  | MEDI |     |       |                            | A vulnerability was found in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. This affects an unknown function of the file yudao-module-infra/src/main/java/cn/iocoder/yudao/module/infra/controller/admin/file/FileController.java of the component File Upload. Performing a manipulation results in cross site scripting. It is possible to initiate the attack remotely. The exploit... |
| <a href="#">CVE-2026-97325</a> | New    | 4.3  | MEDI |     |       |                            | A security flaw has been discovered in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. Affected by this vulnerability is the function validOAuthClientFromCache of the file yudao-module-system/src/main/java/cn/iocoder/yudao/module/system/service/oauth2/OAuth2ClientServiceImpl.java of the component OAuth2 Client. The manipulation of the argument redirect_uri results in open ... |
| <a href="#">CVE-2026-97648</a> | New    | 4.3  | MEDI |     |       |                            | A vulnerability was detected in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected is an unknown function. Performing a manipulation results in cross-site request forgery. It is possible to initiate the attack remotely. The exploit is now public and may be used. The project was informed of the problem early through an issue report b... |
| <a href="#">CVE-2026-97650</a> | New    | 4.3  | MEDI |     |       |                            | A vulnerability has been found in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this issue is the function echo of the file admin/fun/addLog.php. The manipulation of the argument reason/detail leads to cross site scripting. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. Th... |
| <a href="#">CVE-2026-57179</a> | New    | 4.2  | MEDI |     |       | pip:social-auth-core       | Python Social Auth is a social authentication/registration mechanism. Prior to version 5.0.0, the partial-pipeline resume mechanism accepted `partial_token` as a bearer credential without binding it to the browser session that created it. Applications using resumable partial pipeline steps could allow an attacker to start an authentication flow, obtain a valid partial token ... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-84302</a> | New    | 4.2  | MEDI |     |       |                            | Discourse is an open-source discussion platform. Prior to 2026.1.6, 2026.5.2, 2026.6.1, and 2026.7.0, Discourse AI reviewables associated with private messages could appear in the moderator review queue of a moderator who was not a participant in the message. Reviewable visibility filtering did not restrict private-message reviewables to the audience permitted to access the ... |
| <a href="#">CVE-2026-97176</a> | New    | 4.2  | MEDI |     | 0.002 |                            | A flaw was found in the Level of Authentication enforcement mechanism of Keycloak, an identity and access management solution. The issue occurs when a client specifically requires a higher security level for a user who already has an active session at a lower level. Due to a logic error in how session re-evaluations are handled, Keycloak may incorrectly issue a token at the ... |
| <a href="#">CVE-2026-11744</a> | New    | 3.8  | LOW  |     | 0.002 |                            | An input validation vulnerability exists in the PaperCut Hive embedded application for Ricoh devices. The application fails to properly sanitize input received during the NFC card reading process before passing it to the application's web view interface. A local attacker with physical access to the device and a specially crafted NFC card or emulator could exploit this flaw t... |
| <a href="#">CVE-2026-97764</a> | New    | 3.7  | LOW  |     |       |                            | django-allauth before 65.19.4 does not have the expected limits on failed login attempts because, in some common configurations, an attacker can leverage the handling of diacritics (e.g., accents) for a higher effective limit.                                                                                                                                                           |
| <a href="#">CVE-2026-77797</a> | New    | 3.6  | LOW  |     |       |                            | Velociraptor's prefetch library contains an out of bound vulnerability which may cause a crash when parsing certain malformed prefetch files.                                                                                                                                                                                                                                                |
| <a href="#">CVE-2026-84151</a> | New    | 3.5  | LOW  |     | 0.002 |                            | The Post Grid WordPress plugin before 7.9.5 does not limit an expansion of the WordPress allowed-HTML list to its own markup and applies it site-wide, allowing users with the Contributor role and above to store iframe, style and input elements that are normally stripped from their content, leading to HTML injection (phishing frames, CSS defacement and spoofed input forms) t...  |
| <a href="#">CVE-2026-97233</a> | New    | 3.5  | LOW  |     |       |                            | A vulnerability was identified in volotat Anagnorisis up to 0.4.11. Affected by this issue is the function html of the file PlaylistManager.js of the component Media Filename Handler. Such manipulation of the argument file_path leads to cross site scripting. The attack can be launched remotely. The exploit is publicly available and might be used. The vendor was contacted ear... |
| <a href="#">CVE-2026-17511</a> | New    | 3.4  | LOW  |     |       |                            | IBM PowerVM Hypervisor FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, FW1060.00 through FW1060.81, and FW950.00 through FW950.H3 is affected by a vulnerability in the partition resource dump interface. An attacker with authenticated administrator-level access to the HMC or service processor can obtain a limited snapshot of partition processor state. Successful exp... |
| <a href="#">CVE-2026-18857</a> | New    | 3.4  | LOW  |     |       |                            | IBM OPENBMC FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, and FW1060.00 through FW1060.81 is affected by a vulnerability in the BMC firmware management interface. The host system can cause the BMC firmware management service to crash or allow a limited amount of BMC internal memory to be read, resulting in a confidentiality and availability impact to the managed ... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-63630</a> | New    | 3.4  | LOW  |     |       |                            | BentoPDF is a client-side PDF toolkit that is self hostable. In 2.8.6 and earlier, deserializeWorkflow() accepts the Timestamp node's tsaUrl control from imported JSON without schema or destination validation. When a user imports the crafted workflow and runs it against a PDF, timestampPdf() sends an RFC 3161 TimeStampReq containing the PDF's SHA-256 MessageImprint to the at...  |
| <a href="#">CVE-2026-18104</a> | New    | 3.3  | LOW  |     |       |                            | IBM Db2 Mirror for i 7.6, 7.5, and 7.4 could allow a local attacker to obtain sensitive information due to the use of the AES Electronic Codebook (ECB) mode for encryption.                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-19492</a> | New    | 3.2  | LOW  |     |       |                            | IBM PowerVM Hypervisor FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, and FW1060.00 through FW1060.81 is affected by a vulnerability in a hypervisor call interface. An attacker with root access to a guest partition can read a limited amount of hypervisor memory, potentially exposing sensitive data belonging to the hypervisor or other guest partitions hosted on the...  |
| <a href="#">CVE-2026-73064</a> | New    | 2.9  | LOW  |     |       |                            | In Mbed TLS 3.2.0 though 3.6.6 and 4.0.0 through 4.1.0, an attacker who can cause an entropy source to fail can remove or inject bytes into the start of the TLS stream. This only affects TLS 1.3 servers.                                                                                                                                                                                   |
| <a href="#">CVE-2026-89004</a> | New    | 2.7  | LOW  |     | 0.001 |                            | The WPeMatico RSS Feed Fetcher WordPress plugin before 2.8.26 does not verify ownership or authorization before returning a campaign's stored configuration and run log, allowing users with contributor-level access and above to read the configuration and execution logs of campaigns created by other users, including administrators.                                                   |
| <a href="#">CVE-2026-93661</a> | New    | 2.7  | LOW  |     | 0.001 |                            | The Events Manager WordPress plugin before 7.4.5 does not stop a ticket-update request from replacing the identifiers of the ticket it was authorized against, letting a user who can manage one event's tickets overwrite and reassign any ticket on the site to their own event.                                                                                                            |
| <a href="#">CVE-2026-97179</a> | New    | 2.1  | LOW  |     |       |                            | A security vulnerability has been detected in O2OA up to 9.5.3/10.0.2. This vulnerability affects the function list of the file o2server/x_base_core_project/src/main/java/com/x/bas e/core/project/connection/CipherConnectionAction.java of the component Cipher Connection Handler. Such manipulation of the argument fileId leads to information disclosure. It is possible to launch...  |
| <a href="#">CVE-2026-97224</a> | New    | 2.1  | LOW  |     |       |                            | A vulnerability was detected in Excalidraw up to 0.18.1. The impacted element is an unknown function of the file packages/excalidraw/data/restore.ts of the component Imported File Handler. Performing a manipulation of the argument customData.generationData.html results in cross site scripting. The attack is possible to be carried out remotely. The exploit is now public and m...  |
| <a href="#">CVE-2026-97323</a> | New    | 2.1  | LOW  |     |       |                            | A vulnerability was determined in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. This impacts the function getOriginalFilename of the file yudao-module-mp/src/main/java/cn/i ocoder/yudao/module/mp/service/material/MpMaterialServiceImpl.java of the component File Upload. Executing a manipulation can lead to path traversal. It is possible to launch the attack remotely. The e... |
| <a href="#">CVE-2026-12957</a> | New    |      | HIGH |     | 0.002 | npm:@aws/lsp-codewhisperer | ### Summary Language Servers for AWS (the aws/language-servers project) provide the underlying language-server runtime that powers Amazon Q Developer's AI coding assistance across its IDE plugins (Visual Studio Code, JetBrains, Eclipse, and Visual Studio). Improper trust boundary enforcement in Language Servers for AWS may allow for arbitrary code execution. If a local user...   |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package                                                                                                        | Description                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------|--------|------|------|-----|-------|-----------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-12958</a> | New    |      | HIGH |     | 0.002 | npm:@aws/lsp-codewhisperer                                                                                                        | ## Summary Language Servers for AWS (the aws/language-servers project) provides the Language Server Protocol implementations that power AWS developer tooling, including the Amazon Q Developer agentic chat experience, across IDEs such as VS Code, JetBrains, Visual Studio, and Eclipse. Missing symlink validation in Language Servers for AWS may allow an arbitrary file write ou... |
| <a href="#">CVE-2026-19730</a> | New    |      | MODE |     | 0.002 | Go:github.com/containers/podman/v5                                                                                                | ### Impact When running `podman quadlet install --replace` to replace a Quadlet file, if the original Quadlet is larger than the new Quadlet, the file would not be truncated and content from the original would be preserved. There is no risk of information leakage as the user already had access to the Quadlet in order to replace it, and in most cases, this would only lead to... |
| <a href="#">CVE-2026-51994</a> | New    |      |      |     |       |                                                                                                                                   | mcp-remote versions 0.1.32 through 0.1.38 are vulnerable to Server-Side Request Forgery (SSRF) via the resource_metadata URL extracted from a remote MCP server's WWW-Authenticate header                                                                                                                                                                                                   |
| <a href="#">CVE-2026-51996</a> | New    |      |      |     |       |                                                                                                                                   | An issue in geelen mcp-remote 0.1.16 through 0.1.38 allows a remote attacker to execute arbitrary code via the src/lib/utls.ts and the getServerUriHash function                                                                                                                                                                                                                            |
| <a href="#">CVE-2026-51997</a> | New    |      |      |     |       |                                                                                                                                   | An issue in geelen mcp-remote 0.1.16 through 0.1.38 allows a remote attacker to execute arbitrary code via the open() functions                                                                                                                                                                                                                                                             |
| <a href="#">CVE-2026-52001</a> | New    |      |      |     |       |                                                                                                                                   | An issue in geelen mcp-remote 0.1.18 through 0.1.38 allows a remote attacker to obtain sensitive information via the SSE transport eventSourceInit fetch wrapper " src/lib/utls.ts                                                                                                                                                                                                          |
| <a href="#">CVE-2026-56742</a> | New    |      | MODE |     | 0.003 | Go:github.com/cilium/cilium,<br>Go:github.com/cilium/ciliumCilium                                                                 | ### Impact In Cilium clusters using [Gateway API](https://docs.cilium.io/en/stable/network/servicemesh/gateway-api/gateway-api/), users with permissions to create or update namespaced HTTPRoutes can mirror HTTP traffic to any Service in any namespace, bypassing the ReferenceGrant authorization mechanism. Gateway API functionality is disabled by default. ### Patches This ...    |
| <a href="#">CVE-2026-57170</a> | New    |      | HIGH |     | 0.002 | PyPI:compliance-trestle                                                                                                           | Reporter: Cavan Loughran, Celvex Group Inc. Summary ----- The fix for CVE-2026-46439 (3.12.2 / 4.0.3) removed the recursive re-render loop in trestle/core/commands/author/jinja.py render_template, but the custom include tags in trestle/core/jinja/tags.py (MDSectionInclude, MDCleanInclude) still re-parse the CONTENT of an included markdown file as a Jinja2 template via Par...   |
| <a href="#">CVE-2026-57171</a> | New    |      | HIGH |     | 0.002 | PyPI:compliance-trestle                                                                                                           | **At a glance** - **Actor:** attacker who controls the -o/--output argument to trestle author {catalog,profile,ssp}-generate (e.g. via a CI pipeline that derives the output directory from repository-controlled data) - **Primitive:** attacker-controlled --output value reaches trestle_root / args.output write sink with only is_directory_name_allowed() (parts[0]-only task-nam...  |
| <a href="#">CVE-2026-57231</a> | New    |      | HIGH |     | 0.004 | Go:github.com/containers/podman,<br>Go:github.com/containers/podman/v2,<br>Go:github.com/containers/podman/v3,<br>Go:github.com/c | ## Summary An container image that contains a environment variable with just a key and no value can trick podman into passing that variable from the host into the container. This is made worse by the fact that using an asterisk (*) will cause podman to pass all host variables into the container. So essentially a malicious image can exfiltrate all podman environment variable... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-57439</a> | New    |      | MODE |     | 0.002 | npm:cyberchef              | On 5 June 2026 CyberChef received a security vulnerability report from @hyuunnn detailing a vulnerability in the Series Chart operation, where malicious input could result in prototype pollution of the data structures outputted from the operation. Other operations following Series Chart could have their behaviour manipulated by the attacker-controlled prototype, for example,...  |
| <a href="#">CVE-2026-59723</a> | New    |      | HIGH |     | 0.002 | npm:cline                  | ### Summary The Cline Hub dashboard server (`@cline/cline-hub`), launched via the `cline dashboard` CLI command, accepts WebSocket connections on the `/browser` endpoint without validating the HTTP `Origin` header. When `ROOM_SECRET` is not set—the default for local (`127.0.0.1`) binds—`isAuthorizedBrowserRequest()` returns `true` unconditionally, allowing any website a dev...   |
| <a href="#">CVE-2026-85491</a> | New    |      |      |     |       |                            | Catalyst::Seal versions before 0.03 for Perl allow one request to disable a path or route a later one past an authorization check via a dispatch memo keyed on the request path alone. Catalyst::Seal replaces the dispatcher's prepare_action with a version that memoises how a path resolved: which dispatch type matched, at which level, and what was left over as arguments. The k...   |
| <a href="#">CVE-2026-88351</a> | New    |      |      |     |       |                            | An integer overflow vulnerability exists in the MPack Node API in MPack 1.1.1 on 32-bit platforms. When parsing a specially crafted MessagePack array32 or map32 object with an excessively large element count, the page allocation size calculation in mpack_tree_parse_children() can overflow size_t and produce an undersized allocation. Subsequent parsing writes mpack_node_data_...  |
| <a href="#">CVE-2026-88355</a> | New    |      |      |     |       |                            | An incorrect buffer size calculation vulnerability exists in tinyexpr commit 4a7456e in new_expr(). For arity-0 expression nodes, including constants, variables, and zero-argument functions, the function allocates less memory than sizeof(te_expr) but treats the returned allocation as a complete te_expr object. This results in undefined behavior and can cause deterministic pr...  |
| <a href="#">CVE-2026-88358</a> | New    |      |      |     |       |                            | simdjson 4.6.1 contains a one-byte out-of-bounds read vulnerability in dom::parser::parse_unpadded(). A specially crafted truncated JSON document whose final structural token closes a nested array or object can cause json_iterator::walk_document() to access buff[len] after the input buffer has been exhausted. This results in a heap out-of-bounds read and may cause application... |
| <a href="#">CVE-2026-88359</a> | New    |      |      |     |       |                            | libfyaml 0.9.6 contains a stack exhaustion vulnerability in fy_atom_iter_format(). When processing a specially crafted YAML document containing a very large literal or folded block scalar, the function repeatedly grows an internal buffer using alloca() inside a loop. The allocated stack memory is not released until the function returns, causing cumulative stack growth that c...  |
| <a href="#">CVE-2026-88360</a> | New    |      |      |     |       |                            | libvips 8.19.0 contains a memory access vulnerability when processing little-endian PFM images. If the PFM text header length is not a multiple of four bytes, the mmap-based loader can expose pixel data at an address that is not properly aligned for float access. vips_avg_scan() subsequently dereferences the buffer through a float pointer, resulting in undefined behavior and...  |
| <a href="#">CVE-2026-88361</a> | New    |      |      |     |       |                            | SumatraPDF 3.6.1 contains an integer overflow vulnerability in EngineMupdf::BuildPageLabelRec() when parsing PDF PageLabels /Nums entries.                                                                                                                                                                                                                                                    |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|-----|-----|------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-88362</a> | New    |      |     |     |      |                            | MuJS e892c9fdb contains an incorrect numeric conversion vulnerability in jsR_isindex() in jsrun.c. A specially crafted JavaScript input containing an excessively large numeric array index can cause an out-of-range floating-point value to be converted to an integer without proper range validation. This results in undefined behavior and can cause process termination, leading t...  |
| <a href="#">CVE-2026-88365</a> | New    |      |     |     |      |                            | minimp3 commit ea99364f contains an integer overflow vulnerability in mp3dec_skip_id3v1() when parsing the APEv2 tag-size field.                                                                                                                                                                                                                                                              |
| <a href="#">CVE-2026-88366</a> | New    |      |     |     |      |                            | NanoSVG commit 239e102ec contains an incorrect numeric conversion vulnerability in nsvg__pathArcTo() when parsing SVG arc commands. A specially crafted SVG document containing extreme arc radius values can cause intermediate arc calculations to produce a NaN delta angle. The function subsequently converts this NaN value to int without validating that it is finite and represe...  |
| <a href="#">CVE-2026-88367</a> | New    |      |     |     |      |                            | NanoSVG 239e102ec contains an incorrect numeric conversion vulnerability in nsvg__curveDivs() during SVG stroke rasterization. A specially crafted SVG document containing an extremely large stroke-width can cause floating-point rounding to produce a zero subdivision angle. The subsequent arc division yields infinity, which is converted to int without range validation, result...  |
| <a href="#">CVE-2026-88369</a> | New    |      |     |     |      |                            | zserge jsmn commit 25647e6 is vulnerable to Buffer Overflow in example/jsondump.c dump()).                                                                                                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-88370</a> | New    |      |     |     |      |                            | libconfini 1.16.4 contains a heap out-of-bounds write condition involving the bundled load_ini_buffer.h utility and strip_ini_cache(). The bundled utility allocates exactly ini_length bytes, while strip_ini_cache() unconditionally writes a NUL terminator at ini_source[ini_length], requiring an additional writable byte. Applications using the bundled allocation pattern can tr...  |
| <a href="#">CVE-2026-88371</a> | New    |      |     |     |      |                            | ZBar commit 2ea2ca58 contains an undefined-behavior vulnerability in the Code 128 decode6() function. When processing specially crafted Code 128 input, decode_e() can return -1 for an invalid edge pattern, and decode6() subsequently left-shifts this negative signed value while constructing the edge signature. The operation invokes undefined behavior and can terminate trap-mo...  |
| <a href="#">CVE-2026-88373</a> | New    |      |     |     |      |                            | libde265 commit 4d45a6b contains a NULL pointer dereference vulnerability in the NAL parsing path. When de265_push_NAL() is called with a zero-length NAL unit, the resulting NAL_unit may retain a NULL backing buffer, which is subsequently passed as the destination argument to memcpy() in NAL_unit::set_data(). Although the copy length is zero, this violates the nonnull requir...  |
| <a href="#">CVE-2026-88377</a> | New    |      |     |     |      |                            | Bento4 1.6.0.0 contains an integer underflow vulnerability in the avcC and hvccC configuration atom parsers. A specially crafted MP4 file containing an atom with a declared size smaller than AP4_ATOM_HEADER_SIZE can cause AP4_AvccAtom::Create() or AP4_HvccAtom::Create() to underflow the payload-size calculation. The resulting oversized buffer operation can cause invalid or NU... |
| <a href="#">CVE-2026-88378</a> | New    |      |     |     |      |                            | QuickJS commit 04be24600 contains a heap out-of-bounds write condition in JS_ReadFunctionTag()).                                                                                                                                                                                                                                                                                              |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                    |
|--------------------------------|--------|------|-----|-----|------|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-88383</a> | New    |      |     |     |      |                            | libical 4.0.6 contains an incompatible function pointer in icalparameter_string_to_kind(). When parsing iCalendar data containing a parameterized property, the function passes icalparameter_compare_kind_map() to bsearch() through an incompatible comparator function pointer type. bsearch() invokes the callback through the mismatched type, resulting in undefined behavior and p...   |
| <a href="#">CVE-2026-88385</a> | New    |      |     |     |      |                            | Mini-XML 4.0.5 contains a memory leak vulnerability in mxmml_load_data() during malformed XML parsing. Specially crafted XML input can cause text nodes allocated by mxmmlNewText() to become unlinked before a parse error transfers control to the cleanup path. These orphaned nodes are not released, resulting in a persistent memory leak on each parsing attempt. Repeated attacker-... |
| <a href="#">CVE-2026-88386</a> | New    |      |     |     |      |                            | libsndfile 1.2.2 contains a misaligned memory access issue in psf_binheader_readf() while parsing WAV fmt chunks. A specially crafted WAV file can cause the function to cast an unaligned destination address to unsigned int * and perform a 4-byte store. This results in undefined behavior leading to denial of service.                                                                  |
| <a href="#">CVE-2026-88387</a> | New    |      |     |     |      |                            | LibRaw 0.22.0 contains an incorrect numeric conversion vulnerability in LibRaw::parse_tiff_ifd() when processing TIFF tag 0x00fe (NewSubfileType). A specially crafted RAW, TIFF, or DNG file can supply an attacker-controlled NewSubfileType value outside the range of a signed int. The parser converts this value and narrows it to int without performing range validation. This ou...   |
| <a href="#">CVE-2026-88388</a> | New    |      |     |     |      |                            | Espruino 2v29 (commit bffc6d0) contains a stack-based buffer overflow vulnerability in the JavaScript error stack-trace handling path on 64-bit builds. A remote attacker can supply JavaScript input that triggers an exception and reaches jsIPrintTokenLineMarker(), which passes the address of a 4-byte int column variable to jsvGetLineAndCol() as a size_t pointer. jsvGetLineAnd...   |
| <a href="#">CVE-2026-92288</a> | New    |      |     |     |      |                            | Lemonldap::NG::Portal versions from 2.20.0 before 2.21.6, from 2.22.0 before 2.23.4 for Perl allow unauthenticated OAuth2 token introspection because checkEndPointAuthenticationCredentials does not verify the client secret of a public Relying Party. checkEndPointAuthenticationCredentials() skips the secret comparison for a Relying Party marked public and still returns the a...    |
| <a href="#">CVE-2026-92289</a> | New    |      |     |     |      |                            | Lemonldap::NG::Portal versions from 2.23.0 before 2.23.4 for Perl allow a PKCE bypass for public Relying Parties in "PKCE or secret" mode because checkEndPointAuthenticationCredentials does not verify the client secret. With oidcRPMetaDataOptionsRequirePKCE set to 2, the authorization endpoint issues a code even when the request carries no code_challenge, and token() admits...    |
| <a href="#">CVE-2026-93205</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: iommu/arm-smmu-v3: Manage teardown with devm arm_smmu_device_remove() manually frees the IOPF queue, destroys the vmid_map and disables the device, while the IRQs and queues are devm managed. devm unwinds only after remove() returns, so the cleanup runs in the wrong order. The IOPF queue is freed before th...     |
| <a href="#">CVE-2026-93206</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI/proc: Use file_ns_capable() when checking config space read access proc_bus_pci_read() decides how much of the config space is readable based on capable(CAP_SYS_ADMIN), which checks the credentials of the task calling read(), not the credentials of the process that opened the file. The sysfs equivalen...      |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93208</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: kasan: fix cache shrink race with CPU hotplug kasan_quarantine_remove_cache() first invokes per_cpu_remove_cache() on all online CPUs. Each callback moves objects belonging to the cache from cpu_quarantine to the CPU's shrink_qlist, where they can later be freed from task context. kmem_cache_destroy() in...   |
| <a href="#">CVE-2026-93209</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: Bluetooth: hci_core: use skb_get() instead of skb_clone() for req_skb BT enable fails intermittently with -ETIMEDOUT (-110). The kernel log shows the HCI Read Local Version command was sent and the firmware replied with status 0x00 (logged by hci_req_cmd_complete() BT_DBG), but the waiter in __hci_cmd_syn...  |
| <a href="#">CVE-2026-93210</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: smb: client: harden DFS cache against invalid target hints Currently, get_tgt_name() returns ERR_PTR(-ENOENT) when ce->tgthint is NULL, and dfs_cache_noreq_update_tgthint() assumes ce->tgthint is always valid. In preparation for clearing ce->tgthint in free_tgts(), harden callers of get_tgt_name() against...  |
| <a href="#">CVE-2026-93211</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: nfsd: initialize DRC hash table before registering shrinker shrinker_register() precedes the INIT_LIST_HEAD loop and the drc_hashsize store. On weakly-ordered architectures (arm64, ppc), a shrinker scan can observe drc_hashsize before the bucket list heads are initialized, causing a NULL deref in the DRC s... |
| <a href="#">CVE-2026-93212</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: nfsd: guard nfsd_serv deref in nfsd_file_net_dispose nfsd_file_net_dispose() is the consumer side of l->freeme: the nfsd service thread loop calls it to drain entries that the filecache garbage collector and shrinker append via nfsd_file_dispose_list_delayed(). During per-net teardown, nn->nfsd_serv is cl...  |
| <a href="#">CVE-2026-93213</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: of: fix out-of-bounds read in of_alias_scan() stem parser The stem parser tests isdigit(*(end - 1)) before checking end > start and so reads one byte before the property name when the name is empty or all digits. Check the bound first.                                                                            |
| <a href="#">CVE-2026-93214</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: usb: gadget: f_tcm: fix deadlock in usbg_make_tpg() usbg_make_tpg() held dep_lock while calling configs_depend_item_unlocked(), which acquires the configs root inode lock when operating across subsystems. This creates a circular lock dependency with configs_rmdir(): dep_lock -> configs root inode lo...        |
| <a href="#">CVE-2026-93215</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: cdx: Fix double free when sysfs file creation fails In cdx_create_res_attr(), if sysfs_create_bin_file() fails, the code frees res_attr but doesn't set cdx_dev->res_attr[num] to NULL. This leaves a dangling pointer in the array. Then cdx_destroy_res_attr() frees the already-freed memory. Fix the double fre... |
| <a href="#">CVE-2026-93216</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/page_owner: use memcg_data snapshot to avoid TOCTOU in print_page_owner_memcg() print_page_owner_memcg() reads page->memcg_data via READ_ONCE() at the start to guard against tail pages and NULL data. However, it later re-reads page->memcg_data locklessly in two places: 1: page_memcg_check(page) 2: Pa...    |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93217</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/madvise: skip device-private PMDs in cold and pageout walks madvise_cold_or_pageout_pte_range() takes pmd_trans_huge_lock(), whose pmd_is_huge() check returns true for a device-private PMD. The subsequent !pmd_present() branch has a VM_BUG_ON() asserting migration is the only allowed non-present case; ...  |
| <a href="#">CVE-2026-93218</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/huge_memory: skip device-private PMDs in madvise_free_huge_pmd madvise_free_pte_range() checks pmd_trans_huge(*pmd) unlocked, then madvise_free_huge_pmd() takes pmd_trans_huge_lock(). pmd_is_huge() returns true for a device-private PMD, so orig_pmd can be device-private and enter the !pmd_present() bra...  |
| <a href="#">CVE-2026-93219</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: clocksource/drivers/timer-sun4i: Advertise a real minimum delta sun4i_clkevt_next_event() compensates for the timer stop/start synchronization delay by programming evt - TIMER_SYNC_TICKS into the hardware interval register. The clockevent device currently advertises TIMER_SYNC_TICKS as min_delta_ticks, so ... |
| <a href="#">CVE-2026-93220</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: sched_ext: Keep kick_sync waiting on the rq's own CPU kick_sync_wait_bal_cb() assumes it runs on the rq's CPU from the __schedule() tail: the snapshots it compares against live in that CPU's percpu area and the busy-wait runs with the rq lock dropped and IRQs enabled. However, dispatch can now drop the rq...  |
| <a href="#">CVE-2026-93222</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: signal: avoid shared signifo namespace rewrites send_signal_locked() rewrites sender ids for the target namespace. Group sends reuse the same signifo, so one recipient can affect the next. Copy the signifo before changing it.                                                                                      |
| <a href="#">CVE-2026-93223</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: staging: media: tegra-video: fix of_node_put() on VIP parse errors tegra_vip_channel_of_parse() initializes np from dev->of_node without taking a reference, but its error paths drop one through the err_node_put label. This underflows the refcount of the VIP device's OF node when endpoint parsing fails on a... |
| <a href="#">CVE-2026-93226</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ipv6: use RCU iterator to dump route exceptions rt6_nh_dump_exceptions() uses hlist_for_each_entry() to iterate over RCU-protected exception lists. The caller holds rcu_read_lock(), but does not hold rt6_exception_lock, so rt6_insert_exception() can concurrently add an entry with hlist_add_head_rcu(). KCS...  |
| <a href="#">CVE-2026-93227</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/mm_init: deferred_grow_zone(): fix out-of-range first_deferred_pfn With CONFIG_DEFERRED_STRUCT_PAGE_INIT enabled, deferred_grow_zone() initializes struct pages early in boot to satisfy an allocation. With a large CMA reservation in place, the ranges deferred_init_memmap() finds may not add up to the al...  |
| <a href="#">CVE-2026-93230</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/hugetlb: initialize gigantic bootmem hugepage struct pages earlier Gigantic bootmem HugeTLB pages are currently initialized from hugetlb_init(), but page_alloc_init_early() runs earlier and walks pageblocks to determine zone contiguity. If a bootmem HugeTLB region is marked noint, set_zone_contiguous()...  |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93231</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: lockd: fix swapped arguments in nlmsvc_match_ip() When releasing locks by server IP address via /proc/fs/nfsd/unlock_ip, nlmsvc_unlock_all_by_ip() calls nlm_traverse_files() with the server sockaddr as the opaque @data argument: nlm_traverse_files(server_addr, nlmsvc_match_ip, NULL); The match callback ...    |
| <a href="#">CVE-2026-93232</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/hugetlb: fix boot panic with CONFIG_DEBUG_VM and HVO bootmem pages Patch series "mm: Refactor bootmem gigantic hugepage allocation", v4. This series is split out from the earlier larger series "mm: Generalize HVO for HugeTLB and device DAX" [1]. It collects the first 19 patches of that series as a sta...   |
| <a href="#">CVE-2026-93233</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/nouveau/dmem: fix callocated underflow on large folio split nouveau_dmem_folio_free() drops chunk->callocated once per freed folio, while a large (compound) device-private folio is only counted once when it is allocated. When such a folio is split, the mm core invokes ->folio_split() (nouveau_dmem_fol...  |
| <a href="#">CVE-2026-93234</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/gud: validate TV mode names before creating enum property The GUD protocol returns TV mode names as fixed-size GUD_CONNECTOR_TV_MODE_NAME_LEN entries and requires each name to be NUL-terminated. gud_connector_add_tv_mode() currently passes each fixed-size entry directly to drm_mode_create_tv_propertie...  |
| <a href="#">CVE-2026-93235</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: f2fs: fix to zero post-EOF data when extending file size generic/794 4s ... - output mismatch (see /share/git/fstests/results/generic/794.out.bad) --- tests/generic/794.out 2026-06-12 08:46:32.766426241 +0800 +++ /share/git/fstests/results/generic/794.out.bad 2026-07-05 18:32:55.000000000 +080...              |
| <a href="#">CVE-2026-93236</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: media: meson: vdec: fix NULL pointer deref in vdec_try_fmt_common When VIDIOC_TRY_FMT is called with an unsupported pixel format on the OUTPUT queue, vdec_try_fmt_common() falls back to V4L2_PIX_FMT_MPEG2. However, if a distro has locally patched MPEG2 support out (as it has been broken for some time) the ... |
| <a href="#">CVE-2026-93238</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: s390/vfio-ap: fix potential use of uninitialized apm_filtered bitmap The DECLARE_BITMAP(apm_filtered, AP_DEVICES) macro allocates the bitmap on the stack without zero-initializing it. In vfio_ap_mdev_hot_plug_cfg(), the vfio_ap_mdev_filter_matrix() function is only called to initialize and populate apm_fi...  |
| <a href="#">CVE-2026-93239</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: arm64: mm: Fix the lockless page-table walk in show_pte() show_pte() walks page tables locklessly and can run with interrupts enabled. A concurrent teardown can free a table page while it is being walked. It can also clear a parent entry after show_pte() checked it; the regular pXd_offset() helpers then re... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93240</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: memcg: make the v1 soft limit knob inert The v1 soft limit has been deprecated since v6.12 and nobody has reported depending on it. Start the removal by decoupling the interface from the implementation: keep memory.soft_limit_in_bytes, but ignore writes to it and always report the maximum value on read si...  |
| <a href="#">CVE-2026-93241</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: memcg: bypass the reclaim and oom killer for dying tasks once oom_reaper is done At Meta, we are seeing instances where an OOM killed job is stuck in the exit path for several hours. In one particular case, the job was stuck for more than 8 hours and I had to manually remove the memory.max limits to allow...  |
| <a href="#">CVE-2026-93242</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix response queue over-consumption in __qla_consume_iocb() qla24xx_process_response_queue() advances ring_ptr past the head IOCB before dispatching, so by the time __qla_consume_iocb() runs, ring_ptr already points at the first continuation IOCB. The function however looped purex->entry_cou... |
| <a href="#">CVE-2026-93243</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mm/secretmem: properly account locked pages secretmem accounts folios by treating memory as if it were mlock()'d and thus limited by the RLIMIT_MEMLOCK limit. However the folios are unevictable and remain so until the inode is evicted, eliminating usual mlock() semantics - mapping folios then unmapping th...  |
| <a href="#">CVE-2026-93244</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/sysfb: simpledrm: Improve stride validation Validate the computed stride against the maximum value INT_MAX.                                                                                                                                                                                                        |
| <a href="#">CVE-2026-93245</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: apparmor: policy_int make sure list heads are initialized before fail path If profile create fails before policy_init is complete the list heads are not properly initialized causing profile_free() sanity checks to trigger the following splat. AppArmor WARN aa_policy_destroy: (((!list_empty(&policy->profil...  |
| <a href="#">CVE-2026-93246</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: octeontx2-af: fix out-of-bounds read setting MSI-X irq affinity rvu_register_interrupts() walks every MSI-X vector and uses strstr() to match "Mbox" or "FLR" in irq_name before pinning those interrupts to CPU 0. irq_name is a per-vector NAME_SIZE buffer, but not every slot is populated before this loop run... |
| <a href="#">CVE-2026-93247</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: Bluetooth: mgmt: fix 'hdev->discovery.uuids' NULL dereference 'uuid_count' member of struct 'discovery_state' is assigned and read without any locks, so there is a chance of situation when uuid_count != 0, but uuids is NULL and there will be NULL pointer dereference. Possible race: 'hci_update_passive_sca...  |
| <a href="#">CVE-2026-93248</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/xe: don't WARN on kernel job timeout when device already wedged igt@xe_wedged@wedged-at-any-timeout wedges the device in mode 2 (UPON_ANY_HANG_NO_RESET) and then rebinds the driver. During unbind, a GSC proxy kernel submission can still time out; with the device wedged and the GuC CT stopped it can nev... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93249</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: spi: amlogic-spisg: Make sure clk_init_data is fully initialized The clk_init_data structure contains several mutually-exclusive members for different methods to specify the possible parents of a clock, prompting drivers to initialize only the members they need. However, not initializing all members may c...  |
| <a href="#">CVE-2026-93251</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPI: bus: Introduce acpi_bus_get_primary_device() The function used for obtaining the first "physical" device for which the given ACPI one is the ACPI companion, acpi_get_first_physical_node(), may return a stale device pointer (mostly in theory) because acpi_unbind_one() may run as a whole after dropping... |
| <a href="#">CVE-2026-93252</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ocfs2: fix circular locking dependency in ocfs2_init_acl() A lockdep warning indicates a circular locking dependency between `&oi->ip_xattr_sem` and `&journal->j_trans_barrier`: WARNING: possible circular locking dependency detected is trying to acquire lock: (&oi->ip_xattr_sem){++++}-{4:4}, at: ocfs2_in...   |
| <a href="#">CVE-2026-93253</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: sched/isolation: Defer freeing of cpumask memblock memory to initcall When testing a linux-next kernel with commit 59bd1d914bb5 ("memblock: warn when freeing reserved memory before memory map is initialized"), the following warning was hit when there was a "nohz_full" kernel boot parameter. Cannot free ...    |
| <a href="#">CVE-2026-93254</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: arm64: entry: Avoid unnecessary local_irq_disable() on kernel exit Currently, when exiting to kernel mode, we attempt involuntary preemption. The preemption logic expects IRQs to be disabled, which is why we call local_irq_disable() before attempting preemption. However, depending on the context, local_ir...  |
| <a href="#">CVE-2026-93255</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: btrfs: make sure EXTENT_BUFFER_READING is cleared under refs_lock [FALSE ALERTS] There is a bug report that the warning inside invalidate_and_check_btree_folios() got triggered during btrfs/298: BTRFS info (device sdd): first mount of filesystem f9bf732a-a19b-44b9-99a7-614ddff168e2 BTRFS info (device sd...    |
| <a href="#">CVE-2026-93256</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: arm64: hibernate: mask DAIF before restoring hibernated kernel The arm64 hibernate code manages the exception masking in an unsound way, leading to potential crashes and/or warnings during resume. When a hibernation image is saved in `swsusp_arch_suspend()`, all DAIF exceptions are masked (by virtue of `l...  |
| <a href="#">CVE-2026-93257</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: block: handle nogenerate/noverify properly in fs-integrity Check the BIP_CHECK flags before generating or verifying PI information, otherwise this can be incorrectly called for non-PI metadata and cause generation of incorrect metadata and crashed in the verification handler. The new behavior matches that...  |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93258</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ocfs2: do not use make_bad_inode() in ocfs2_read_inode_block_full() This reverts commit 58b6fcd2ab34 ("ocfs2: mark inode bad upon validation failure during read"). Since 'make_bad_inode()' resets inode type to S_IFREG, doing this for directory inode during active VFS lookup is likely to confuse the latter...  |
| <a href="#">CVE-2026-93259</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: powerpc/irq: Fix missing r2 clobber in PCREL inline assembly In CONFIG_PPC_KERNEL_PCREL mode, r2 is no longer reserved for the TOC pointer and is available as a caller-saved register [0]. Both call_do_irq() and call_do_softirq() use inline assembly to call functions with stack switching, but fail to list ...  |
| <a href="#">CVE-2026-93261</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: locking/lockdep: Fix NULL pointer dereference in __lock_set_class() register_lock_class() can return NULL when the lock class pool is exhausted, graph_lock() fails, or key validation fails. However, __lock_set_class() uses the return value directly in pointer arithmetic without a NULL check: class = reg...    |
| <a href="#">CVE-2026-93263</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: clk: eswin: Zero-initialize stack-allocated clk_init_data eswin_clk_register_pll() and eswin_register_clkdiv() declare a struct clk_init_data on the stack and only initialize some of its fields (parent_data respectively parent_hws). clk_core_populate_parent_map() checks parent_names first and parent_data s... |
| <a href="#">CVE-2026-93264</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: RDMA/efa: Fix PBL chunk length computation On register MR, when creating the PBL, if it's an indirect PBL we create a chunk list to hold the PBL pages pointers. Each chunk is 4KB in size and can hold 510 addresses (EFA_PTRS_PER_CHUNK) and has a 12-byte control buffer at the end of it holding the next chunk... |
| <a href="#">CVE-2026-93266</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: arm64: RSI: fix field-spanning write warning in attestation token init The challenge is passed in registers a1 through a8. However, copying to &regs.a1 makes FORTIFY treat the destination as the single a1 field, resulting in a field-spanning write warning. [1] Overlay the SMCCC register structure with an ...  |
| <a href="#">CVE-2026-93267</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: RDMA/core: Fix potential use after free in uverbs_free_dmah() When accessing a dmah via the netlink path the only synchronization mechanism for the said dmah is rdma_restrack_get(). Currently, rdma_restrack_del() is invoked at the end of uverbs_free_dmah(), which is too late, since by that point vendor-spe... |
| <a href="#">CVE-2026-93268</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ext4: skip extra isize expansion during mount to prevent deadlock ext4_try_to_expand_extra_isize() is called from __ext4_mark_inode_dirty() while holding an active jbd2 handle. During mount (!SB_ACTIVE), the expand path may move xattrs to external blocks and release ea_inodes via iput(). When !SB_ACTIVE,...   |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93269</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ext4: fix circular lock dependency in ext4_ext_migrate Move iput(tmp_inode) after ext4_writepages_up_write() to avoid a circular lock dependency between s_writepages_rwsem and sb_internal (freeze protection). The deadlock scenario: CPU0 (EXT4_IOC_MIGRATE) CPU1 (orphan cleanup during mount) ----...             |
| <a href="#">CVE-2026-93270</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: bpf: Disallow interpreter fallback for BPF_ADDR_PERCPU insn The BPF_MOV64_PERCPU_REG insn requires JIT to emit native code to for 'dst_reg = src_reg + <percpu_base_off>'. However, the interpreter ignores the 'off' at its ALU64_MOV_X label. The 'off' indicates the insn is BPF_MOV64_PERCPU_REG insn. Then, w...  |
| <a href="#">CVE-2026-93271</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: ath11k: cap out-of-range rx MCS instead of leaving bogus rate ath11k can receive HT/VHT/HE frames whose reported MCS is above the maximum that can be expressed in the corresponding mac80211 rate space (e.g. an HE frame reported with MCS 12, while HE tops out at MCS 11). The frame itself is valid and...  |
| <a href="#">CVE-2026-93272</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: remoteproc: qcom_wcnss: Fix handling the lack of PD regulators in v3 The changes introduced to handle single power domain platforms have swapped the info pointer increment from num_pd_vregs to num_pds, which would shift the info pointer past the end of the array for pronto-v3, which does not list power dom... |
| <a href="#">CVE-2026-93273</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: regulator: tps6594: Fix device node reference leaks in multiphase loop In tps6594_regulator_probe(), the multi-phase configuration loop calls of_find_node_by_name() to find buck nodes by name, and of_get_parent() twice to navigate to the PMIC parent node. None of the acquired node references (np, intermedi... |
| <a href="#">CVE-2026-93274</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: pinctrl: bcm2835: Don't remove an unregistered GPIO chip If the devm_pinctrl_register() function fails, bcm2835_pinctrl_probe() calls gpiochip_remove() before gpiochip_add_data() has registered the GPIO chip. This means that upon failure the gpio_chip.gpiodev is NULL resulting in a null pointer dereferen...   |
| <a href="#">CVE-2026-93275</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: perf/x86/intel/pt: Fix stop/start with no update If pt_event_stop() is called without PERF_EF_UPDATE flag, then perf_aux_output_end() is not called. A subsequent call to pt_event_start() will call perf_aux_output_begin() again which violates the rule against nesting and triggers a WARNING in perf_aux_outp...  |
| <a href="#">CVE-2026-93276</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: phy: renesas: phy-rcar-gen3-usb2: Fix devm action registration for disabled VBUS regulator devm_regulator_get_exclusive() initialises the regulator with enable_count = 1, requiring the consumer to disable it before release. The devm disable action was previously only registered when the caller explicitly ...  |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93278</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: staging: octeon: add missing napi_disable in cvm_oct_rx_shutdown cvm_oct_rx_shutdown calls free_irq and netif_napi_del without disabling the napi instance first. As the free_irq only waits for completion of hard interrupt handlers, the napi poll function could still be active. If cvm_oct_remove proceeds to... |
| <a href="#">CVE-2026-93279</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: staging: octeon: add missing tasklet_kill in cvm_oct_tx_shutdown The TX cleanup tasklet can be scheduled by the watchdog IRQ handler to execute cvm_oct_tx_do_cleanup. There can be a pending tasklet in the queue which might run after the cvm_oct_remove() frees net_device structures, causing a use-after-free... |
| <a href="#">CVE-2026-93281</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: rtw89: fix HE extended capability length check rtw89_mac_check_he_obss_narrow_bw_ru_iter() reads extended capability byte 10, but rejects only datalen values below 10. Byte 10 requires at least 11 bytes. Require datalen >= 11 before reading data[10].                                                       |
| <a href="#">CVE-2026-93283</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: i3c: master: Fix device_register() error path When device_register() fails in i3c_master_register_new_i3c_devs(), put_device() is called to drop the reference taken by device_register(). That drops the last reference, so the device's release callback i3c_device_release() runs and frees the i3c_device. Tw...   |
| <a href="#">CVE-2026-93285</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: f2fs: embed f2fs_gc_kthread in f2fs_sb_info Instead of allocating f2fs_gc_kthread dynamically, embed it in f2fs_sb_info. This simplifies lifetime management and prepares for fixing race conditions during teardown. - __sbi_store - remount shutdown - f2fs_stop_gc_thread - access sbi->gc_thread ...               |
| <a href="#">CVE-2026-93286</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: net: appletalk: fix NULL pointer dereference in aarp_send_ddp() aarp_send_ddp() calls atalk_find_dev_addr(dev) in the LocalTalk fast path without checking for NULL. When the device has no AppleTalk interface configured (dev->atalk_ptr == NULL), this leads to a NULL pointer dereference at the at->s_net acce... |
| <a href="#">CVE-2026-93781</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: scsi: core: Do not block on tag allocation in scsi_eh_lock_door() scsi_eh_lock_door() is called from scsi_restart_operations() while the host is still in the SHOST_RECOVERY state, i.e. before the host is switched back to SHOST_RUNNING and scsi_run_host_queues() restarts the queues. It allocates a request v... |
| <a href="#">CVE-2026-93783</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: Bluetooth: RFCOMM: validate skb length in rfcomm_recv_frame rfcomm_recv_frame() casts skb->data to struct rfcomm_hdr and dereferences hdr->addr and hdr->ctrl without validating skb->len first. A truncated frame with skb->len less than the minimum header size causes an out-of-bounds read of uninitialized me... |
| <a href="#">CVE-2026-93784</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: cfg80211: validate IEs in cfg80211_wext_siwgenie() The KASAN allocation trace shows that a malformed IE buffer is stored via SIOCSIWGENIE (cfg80211_wext_siwgenie()) without any validation. The crash trace shows that a subsequent SIOCSIWESSID triggers a connection attempt which calls cfg80211_sme_get_... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93785</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: cifs: validate idmap key payload length The cifs.idmap key type stores its payload length in key->datalen, which is limited to U16_MAX. Accepting a larger key payload truncates the recorded length and can make later users interpret the payload using inconsistent bounds. Reject oversized preparsed payload...   |
| <a href="#">CVE-2026-93788</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: acpi: validate WGDS table revision index Check tbl_rev bounds before BIT(tbl_rev) to avoid undefined shifts when firmware reports an invalid revision value.                                                                                                                                            |
| <a href="#">CVE-2026-93789</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: bound aligned TLV advance in FW parser Validate ALIGN(tlv_len, 4) against remaining parser length before consuming bytes from the firmware image. This avoids length underflow on malformed TLVs.                                                                                                       |
| <a href="#">CVE-2026-93791</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mvm: add a check on the tid coming from the firmware ba_notif->tid is a firmware-controlled u8 that is used directly as an array index into tid_data[] without any validation. Add a bounds check against IWL_MAX_TID_COUNT before dereferencing the array.                                             |
| <a href="#">CVE-2026-93792</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mvm: fix a possible underflow We shouldn't trust the firmware about the length of the wowlan packet.                                                                                                                                                                                                    |
| <a href="#">CVE-2026-93794</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: smb/client: flush dirty data before punching a hole Punching a hole after a large buffered write may leave the range reported as data. Reproduce it with: xfs_io -f \ -c "pwrite -b 3m -S 0x61 0 3m" \ -c "fpunch 1m 1m" \ -c "seek -h 0" \ -c "seek -d 1m" \ /mnt/test/repro Punching 1 Mi...                         |
| <a href="#">CVE-2026-93795</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: blk-cgroup: fix leaks and online flag on radix_tree_insert failure When radix_tree_insert() fails in blkcg_create(), the error path has two issues: 1. blkcg->online is set to true unconditionally, even when the blkcg was never fully inserted. Move the assignment inside the success block. 2. The error pa...    |
| <a href="#">CVE-2026-93797</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mvm: fix an off-by-1 boundary check Before looking at the 11th byte, check the length is big enough.                                                                                                                                                                                                    |
| <a href="#">CVE-2026-93800</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: btrfs: fix use-after-free on reloc root after error in insert_dirty_subvol() If during relocation we fail in insert_dirty_subvol() because btrfs_update_reloc_root() returned an error, we will leave a root's reloc_root field pointing to a reloc root that was freed instead of NULL, resulting later in a use-a... |
| <a href="#">CVE-2026-93802</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: rsi: validate beacon length before fixed buffer copy rsi_prepare_beacon() copies the mac80211 beacon frame after FRAME_DESC_SZ into a management skb whose usable tailroom may be smaller than MAX_MGMT_PKT_SIZE after alignment. Validate the beacon length against the actual tailroom before the copy and...  |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93803</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: libipw: fix key index receive bound checks libipw_rx() reads skb->data[hdrlen + 3] to extract the WEP key index in both the software-decrypt key selection path and the hardware-decrypt IV/ICV strip path. In both places the existing guard only checks skb->len >= hdrlen + 3, which proves bytes up to ...   |
| <a href="#">CVE-2026-93804</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: mac80211: ibss: wait for in-flight TX on disconnect While leaving an IBSS in ieee80211_ibss_disconnect() mac80211 flushes stations, turns the carrier off and immediately tells the driver to leave as well. While there may be synchronize_net() in station flush and in this code later, packets can still ... |
| <a href="#">CVE-2026-93805</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: cfg80211: validate rx/tx MLME callback frame lengths before access cfg80211_rx_mlme_mgmt() and cfg80211_tx_mlme_mgmt() call tracepoints before rejecting frames shorter than the frame-control field. After that, they only require len >= 2 before dispatching into subtype handlers that assume their fixed... |
| <a href="#">CVE-2026-93807</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: rsi: avoid reading TKIP MIC keys for non-TKIP ciphers rsi_hal_load_key() copies tx_mic_key and rx_mic_key from data[16] and data[24] whenever key data is present. Those offsets are only part of the 32-byte TKIP key layout. Shorter keys used by other ciphers, such as CCMP, do not provide those bytes, ... |
| <a href="#">CVE-2026-93808</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ALSA: usb-audio: caiaq: validate EP1 reply lengths usb_ep1_command_reply_dispatch() uses buf[0] as a command byte and then reads command-specific fixed items from the same URB buffer. Several paths use buf + 1, buf[1], buf[2], or buf + 3 without first proving that urb->actual_length contains those bytes. ...  |
| <a href="#">CVE-2026-93809</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: flush pending RCU callbacks on module unload Call rcu_barrier() in module exit to wait for outstanding call_rcu() callbacks before freeing module text, preventing late callback execution in freed memory. BUG: unable to handle page fault for address: ffffffff1d59c40 PGD 6a12067 P4D 6a12067 PUD...   |
| <a href="#">CVE-2026-93811</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ksmbd: Fix acl.sd_buf memory leak and invalid sd_size error handling 1. When ndr_decode_v4_ntacl() fails, the code jumped to free_n_data which only freed n.data, skipping kfree(acl.sd_buf) and leaking the buffer. Zero-initialize struct xattr_ntacl acl, reorder error labels to out_free to release a...          |
| <a href="#">CVE-2026-93812</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix sd_ndr.data memory leak in ksmbd_vfs_set_sd_xattr ndr_encode_v4_ntacl() allocates sd_ndr.data via kzalloc() at entry. If any subsequent ndr_write_*(*) call returns error during encoding, the allocated sd_ndr.data won't be freed and causes memory leak. Move kfree(sd_ndr.data) into out label to en... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------|--------|------|-----|-----|------|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93814</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: spi: core: Abort active target transfer on controller suspend When an SPI controller operating in target mode has a transfer in progress at the time of system suspend, the suspend path proceeds without aborting the ongoing transfer. This can leave the hardware in an inconsistent state, potentially causing ...  |
| <a href="#">CVE-2026-93815</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: net: au1000: move free_irq out of the close-time spinlocked section au1000_close() calls free_irq() while aup->lock is still held with spin_lock_irqsave(). free_irq() can sleep because it takes the IRQ descriptor request mutex, so it does not belong inside the close-time spinlocked section. This was found...   |
| <a href="#">CVE-2026-93818</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI: plda: Protect root bus removal with rescan lock Hold the pci_rescan_remove_lock lock while stopping and removing a root bus to avoid racing with concurrent rescan or hotplug operations triggered via sysfs. Such races may lead to use-after-free issues or system crashes. [bhelgaas: commit log]               |
| <a href="#">CVE-2026-93819</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI: mediatek: Protect root bus removal with rescan lock Hold the pci_rescan_remove_lock lock while stopping and removing a root bus to avoid racing with concurrent rescan or hotplug operations triggered via sysfs. Such races may lead to use-after-free issues or system crashes. [bhelgaas: commit log]           |
| <a href="#">CVE-2026-93820</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI: rockchip: Protect root bus removal with rescan lock Hold the pci_rescan_remove_lock lock while stopping and removing a root bus to avoid racing with concurrent rescan or hotplug operations triggered via sysfs. Such races may lead to use-after-free issues or system crashes. [bhelgaas: commit log]           |
| <a href="#">CVE-2026-93821</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI: altera: Protect root bus removal with rescan lock Hold the pci_rescan_remove_lock lock while stopping and removing a root bus to avoid racing with concurrent rescan or hotplug operations triggered via sysfs. Such races may lead to use-after-free issues or system crashes. [bhelgaas: commit log]             |
| <a href="#">CVE-2026-93822</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI: iproc: Protect root bus removal with rescan lock Hold the pci_rescan_remove_lock lock while stopping and removing a root bus to avoid racing with concurrent rescan or hotplug operations triggered via sysfs. Such races may lead to use-after-free issues or system crashes. [bhelgaas: commit log]              |
| <a href="#">CVE-2026-93823</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Let driver decide buffer size at AMDKFD_IOC_GET_DMABUF_INFO ioctl amdtkfd driver needs allocate buffer to return bo metadata to user space. The buffer size is controlled by user currently. It is a potential security issue that hostile value (e.g. 2 GiB) lets any render-group user trigger order-M... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------|--------|------|-----|-----|------|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93824</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: tls: reject the combination of TLS and sockmap TLS and sockmap (BPF psock) integration hides a lot of latent bugs. Bugs which may be more or less relevant for real users but they are definitely exploitable. We could not find anyone actively using this integration so let's reject this config. Adding a TLS ...   |
| <a href="#">CVE-2026-93825</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: spi: Add NULL check for spi_get_device_id() in spi_get_device_match_data() Prevent NULL pointer dereference when spi_get_device_id() returns NULL, which can happen when using driver_override without matching SPI ID entry.                                                                                           |
| <a href="#">CVE-2026-93828</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: exfat: fix handling of damaged volume in exfat_create_upcase_table() When the size of the upcase table is set to zero in the dentry for any reason(e.g. corrupted media or misbehaving device), an integer overflow causes the module to loop indefinitely. If the size of the upcase table is read zero, do not a...   |
| <a href="#">CVE-2026-93829</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: smb: client: fix races in cifs thread creation The cifs demultiplex thread can run and access tcp_ses before the parent thread has finished populating tcp_ses, which the worker thread accesses locklessly. Also, the kthread_run macro may start the thread before returning the thread pointer. Because the p...     |
| <a href="#">CVE-2026-94604</a> | New    |      |     |     |      |                            | Rejected reason: This CVE is a duplicate of another CVE.                                                                                                                                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-95811</a> | New    |      |     |     |      |                            | Lemonldap::NG::Handler versions from 2.0.0 before 2.16.10, from 2.17.0 before 2.21.6, from 2.22.0 before 2.23.4 for Perl allow an equivalent spelling of a path to bypass the locationRules that restrict it. The handler matches each vhost's locationRules regular expressions against REQUEST_URI, the raw request line, while the web server routes on the path it has already perce... |
| <a href="#">CVE-2026-97168</a> | New    |      |     |     |      |                            | Rejected reason: it is a suggestion                                                                                                                                                                                                                                                                                                                                                         |
| <a href="#">CVE-2026-97230</a> | New    |      |     |     |      |                            | IO::Socket::SSL::SelfCertificate versions 1.00 for Perl contains malware which executes Python code from an obfuscated URL. The generate_certificate runs a Python script saved as a certificate file. The pyhton script attempts to retrieve code from a hardcoded http URL that is obfuscated with base64 encoding and run the response body directly. The impact is that arbitrary ...   |
| <a href="#">CVE-2026-97387</a> | New    |      |     |     |      |                            | Rejected reason: This CVE is a duplicate of another CVE.                                                                                                                                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-97407</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ASoC: rockchip: rockchip_pdm: Handle runtime PM resume failures in set_fmt rockchip_pdm_set_fmt() calls pm_runtime_get_sync() before accessing hardware registers, but ignores its return value. If the runtime resume fails, the function continues to perform register accesses while the device state is undefin...  |
| <a href="#">CVE-2026-97408</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: validate connectionless PSM length Connectionless L2CAP frames carry a two-byte PSM at the start of the payload. l2cap_rcv_frame() currently reads that PSM unconditionally after validating only the outer L2CAP length. A malformed connectionless frame with a zero- or one-byte payload ca...     |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|-----|-----|------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97410</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: netconsole: take target_cleanup_list_lock in drop_netconsole_target() drop_netconsole_target() unlinks the target while only holding target_list_lock. However, when the underlying interface has been unregistered, netconsole_netdev_event() moves the target from target_list to target_cleanup_list, and netcon...    |
| <a href="#">CVE-2026-97411</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: net: ibm: emac: mal: fix potential system hang in mal_remove() napi_disable() is not idempotent and calling it on an already-disabled or unenabled NAPI context will cause the kernel to spin indefinitely waiting for the NAPI_STATE_SCHED bit to clear. In mal_remove(), napi_disable() is called unconditionall...     |
| <a href="#">CVE-2026-97412</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: pds_core: quiesce DMA before freeing resources pdsc_tearardown() frees DMA buffers but does not disable bus mastering, leaving the device able to perform DMA after the buffers are freed. This can lead to use-after-free if the device writes to freed memory. Add pci_clear_master() to pdsc_tearardown() to disabl... |
| <a href="#">CVE-2026-97414</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ASoC: mediatek: mt8365-afe-pcm: fix possible NULL-pointer dereferences in mt8365_afe_suspend() mt8365_afe_suspend() allocates the register backup buffer with devm_kcalloc(), but does not check for allocation failure before using the returned pointer. This may lead to a NULL pointer dereference when accessi...    |
| <a href="#">CVE-2026-97416</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: btrfs: balance: fix potential bg lookup failure in btrfs_may_alloc_data_chunk() [BUG] Running btrfs balance can trigger a null-ptr-deref before relocating a data chunk when metadata corruption leaves a chunk in the chunk tree without a corresponding block group in the in-memory cache: KASAN: null-ptr-de...       |
| <a href="#">CVE-2026-97418</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ALSA: es18xx: check control allocation before private data setup snd_es18xx_mixer() creates controls with snd_ctl_new1() and then stores bookkeeping pointers or sets private_free before calling snd_ctl_add(). snd_ctl_new1() can return NULL on allocation failure, so those writes can dereference a NULL contr...    |
| <a href="#">CVE-2026-97419</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: hsr: broadcast netlink notifications in the device's net namespace The HSR generic netlink family sets .netnsok = true. HSR devices can live in network namespaces other than init_net. Two async notifiers broadcast events with genlmsg_multicast(). They are hsr_nl_ringerror() and hsr_nl_nodedown(). That hel...     |
| <a href="#">CVE-2026-97420</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: bpf: NUL-terminate replaced sysctl value When writing to sysctls, proc_sys_call_handler() guarantees that the buffer passed to proc handlers is NUL-terminated. If bpf_sysctl_set_new_value() replaces the pending sysctl value, it can hand a replacement buffer directly to proc handlers. However, the helper cu...    |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97422</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: fix SMI event cross-process information leak kfd_smi_ev_enabled() skips the suser privilege check when pid=0. PROCESS_START, PROCESS_END, and VMFAULT events are emitted with pid=0 while carrying another process's PID and command name, so any /dev/kfd user in the render group can monitor all GPU... |
| <a href="#">CVE-2026-97423</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: cxl/region: Validate partition index before array access construct_region() reads cxled->part and uses it to index cxlds->part[] without checking for a negative value. If the partition was never resolved, part remains at its initial value of -1, causing an out-of-bounds array access. Add a guard to return...  |
| <a href="#">CVE-2026-97424</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/ras: add ras_suspend callback and use it for cp_ecc_error_irq cp_ecc_error_irq is acquired in amdgpu_gfx_ras_late_init() but released in gfx_v9_0_hw_fini(), so the put site has to query amdgpu_irq_enabled() because the get is skipped on SR-IOV VF. ras_late_init / ras_fini have no suspend counte...  |
| <a href="#">CVE-2026-97425</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: fix buffer overflow during vBIOS update Clamp the buffer position to write by setting the bin attribute to the maximum buffer size so that VFS layer will block the out-of-bounds accessing.                                                                                                               |
| <a href="#">CVE-2026-97426</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/pm: fix SmartShift bias sysfs store PM refcount on parse error Return the parse error before acquiring PM access.                                                                                                                                                                                           |
| <a href="#">CVE-2026-97427</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amd/pm: bound pp_dpm_set_pp_table() memcpy The powerplay path allocates hardcode_pp_table once with kmemdup(..., soft_pp_table_size). memcpy(..., size) used the sysfs store count (up to PAGE_SIZE) with no upper bound, causing heap overflow. Reject writes where size exceeds soft_pp_table_size.              |
| <a href="#">CVE-2026-97430</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: xhci: Prevent queuing new commands if xhci is inaccessible Refuse to queue a new command on the command ring if xHC is marked inaccessible with the HCD_FLAG_HW_ACCESSIBLE. HCD_FLAG_HW_ACCESSIBLE is set and cleared in suspend and resume. Also print a warning if xhci is being suspended with commands still ...   |
| <a href="#">CVE-2026-97431</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amd/display: Avoid DPMS-on for phantom stream [Why & How] Calling dc_update_planes_and_stream separately for stream and its phantom stream causes a NULL pointer dereference, since the phantom is destroyed on the first call. Skip the call for phantom streams.                                                 |
| <a href="#">CVE-2026-97432</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: iwlmwifi: mvm: fix P2P-Device binding handling Our binding handling for P2P-Device can run into the following scenario, as observed by our testing: - a station interface is connected on some channel - the P2P-Device does a remain-on-channel (ROC) on that channel - the ROC ends, and the P2P-Device ...    |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97434</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: dpaa2-switch: fix handling of NAPI on the remove path All the NAPI instances for a DPSW device are attached to the first switch port's net_device but shared by all ports. The NAPI instances get disabled only once the last port goes down. This causes an issue on the .remove() path where each port is unregi...  |
| <a href="#">CVE-2026-97435</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: net: dsa: sja1105: flower: reject cross-chip redirect dsa_port_from_netdev() may return a valid port from a different switch chip. Programming another chip's port index into the local hardware causes redirection to the wrong port, or an out-of-bounds access if the index exceeds the local chip's port count.... |
| <a href="#">CVE-2026-97436</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: dpaa2-switch: rework FDB management on the bridge leave path On bridge leave, the dpaa2_switch_port_set_fdb() function always allocates a new FDB for the port which is becoming standalone. In case no FDB is found, then the port leaving a bridge will continue to use the current one. The above logic does no...  |
| <a href="#">CVE-2026-97439</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: fs/ntfs3: preserve non-DOS attribute bits in system.dos_attr [BUG] A corrupted ntfs3 image can hit a NULL function pointer call in generic_perform_write() after toggling system.ntfs_attr and then overwriting system.dos_attr on the same file. BUG: kernel NULL pointer dereference, address: 000000000000...       |
| <a href="#">CVE-2026-97440</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: net: qrtr: fix node refcount leak on ctrl packet alloc failure qrtr_send_resume_tx() calls qrtr_node_lookup() which takes a reference on the returned node. If the subsequent call to qrtr_alloc_ctrl_packet() fails due to memory allocation failure, the function returns -ENOMEM without calling qrtr_node_relea... |
| <a href="#">CVE-2026-97441</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ata: ahci: fail probe if BAR too small for claimed ports When an AHCI controller is disabled in BIOS, its HOST_CAP register may contain a bogus value, e.g. 0xFFFFFFFF. Since CAP.NP (Number of Ports) is a zeroes based 5-bit register field, a value of 0x1f means 32 ports. If CAP.NP claims more ports than ca...  |
| <a href="#">CVE-2026-97443</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: perf/trace: Fix WARNING in __unregister_ftrace_function perf_ftrace_function_unregister() unconditionally calls unregister_ftrace_function() without checking whether the ftrace_ops was ever successfully registered. This triggers a WARN_ON in __unregister_ftrace_function() when the ops doesn't have FTRACE_...  |
| <a href="#">CVE-2026-97446</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Fix NULL pointer dereference in acpi_ns_custom_package() acpi_ns_custom_package() unconditionally dereferences the first element of the package to read the _BIX version number, without checking for NULL: if ((*Elements)->Common.Type != ACPI_TYPE_INTEGER) When firmware returns a _BIX package w...       |
| <a href="#">CVE-2026-97447</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Enhance OEM ID and Table ID validation in acpi_ex_load_table_op() Enhance OEM ID and Table ID validation in acpi_ex_load_table_op() to prevent buffer overflows.                                                                                                                                               |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97449</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Add package limit checks in parser functions Add package limit checks in parser functions to prevent out-of-bounds access.                                                                                                                                                                                     |
| <a href="#">CVE-2026-97453</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: validate byte_count in acpi_ps_get_next_package_length() Validate package length reading in acpi_ps_get_next_package_length().                                                                                                                                                                                 |
| <a href="#">CVE-2026-97456</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ACPICA: Fix condition check in acpi_ps_parse_loop() Fix condition check for AML_ELSE_OP in acpi_ps_parse_loop() to prevent out-of-bounds access.                                                                                                                                                                       |
| <a href="#">CVE-2026-97472</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: ipv6: addrconf: fix temp address generation after prefix deprecation When a router temporarily deprecates an IPv6 prefix (either by sending a Router Advertisement with Preferred Lifetime = 0 or by letting the lifetime expire) and later restores it, the kernel permanently loses its ability to generate tempo... |
| <a href="#">CVE-2026-97473</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: powercap: intel_rapl: Fix memory leak in rapl_add_package_cpuslocked() When topology_physical_package_id()/topology_logical_die_id() returns a negative value, rapl_add_package_cpuslocked() returns ERR_PTR(-EINVAL) directly without freeing the rapl_package structure that was just allocated by kzalloc_obj(),... |
| <a href="#">CVE-2026-97475</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: thermal/drivers/tegra/soctherma: Switch to devm cooling device registration Use devm_thermal_of_cooling_device_register() to simplify resource management and avoid manual cleanup in error paths. As a side effect this change has the benefit of solving an existing issue. Before, the function tegra_soctherm_...  |
| <a href="#">CVE-2026-97476</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: rds: filter RDS_INFO_* getsockopt by caller's netns The RDS_INFO_* family of getsockopt(2) options reads several file-scope global lists that are not per-netns: rds_sock_info / rds6_sock_info, rds_sock_inc_info / rds6_sock_inc_info -> rds_sock_list rds_tcp_tc_info / rds6_tcp_tc_info ...                        |
| <a href="#">CVE-2026-97477</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: RDMA/counter: Fix num_counters leak on bind_qp failure in alloc_and_bind() When __rdma_counter_bind_qp() fails in alloc_and_bind(), the error path jumps to err_mode which frees the counter without decrementing port_counter->num_counters. The only place that decrements is rdma_counter_free(), which is unrea... |
| <a href="#">CVE-2026-97479</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: driver core: Avoid warning when removing a device while its supplier is unbinding During driver removal, the following warning can appear: WARNING: CPU: 1 PID: 139 at drivers/base/core.c:1497 __device_links_no_driver+0xcc/0xfc ... Call trace: __device_links_no_driver+0xcc/0xfc (P) device...                    |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97480</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: tty: serial: 8250: protect against NULL uart->port.dev in register serial8250_register_8250_port() conditionally copies uart->port.dev from up->port.dev only when up->port.dev is non-NULL: if (up->port.dev) { uart->port.dev = up->port.dev; ... } So if both the existing uart slot and up have a NULL ...         |
| <a href="#">CVE-2026-97481</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: serial: 8250: fix possible ISR soft lockup There are rare cases in which the host gets stuck in the ISR because it is flooded with messages during the startup phase. The reason for the soft lockup in the ISR is the missing FIFO error IRQ (FIFOE) handling. Not handling it and reporting IRQ_HANDLED triggers...  |
| <a href="#">CVE-2026-97482</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: usb: gadget: goku_udc: avoid NULL deref of dev->driver in INT_USBRESET log goku_irq() handles a number of bus events under a single ep0 path. It already guards the gadget driver suspend/resume callbacks against a NULL ->driver: if (dev->gadget.speed != USB_SPEED_UNKNOWN && dev->driver && dev->drive...         |
| <a href="#">CVE-2026-97483</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: usb: core: hcd: fix possible deadlock in rh control transfers >From within the SCSI error handler memory allocations must not trigger IO. Handling errors in UAS and the storage driver may involve resetting a device. The thread doing the reset itself relies on VM magic. However, that is insufficient, as res... |
| <a href="#">CVE-2026-97484</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: usbip: vhci_hcd: fix NULL deref in status_show_vhci platform_get_drvdata() can return NULL if a VHCI host controller's probe failed (e.g. due to USB bus number exhaustion). status_show_vhci() checked for a NULL pdev but not for a NULL hcd returned by platform_get_drvdata(). Passing NULL to hcd_to_vhci_hcd(... |
| <a href="#">CVE-2026-97485</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: omfs: handle set_blocksize failures omfs uses buffer_heads, which don't handle block size > PAGE_SIZE well. Without this, mounting we will hit the BUG_ON(offset >= folio_size(folio)); in folio_set_bh on the first __bread_gfp call.                                                                                 |
| <a href="#">CVE-2026-97486</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: hpfs: handle set_blocksize failures hpfs uses buffer_heads, which don't handle block size > PAGE_SIZE well. Without this, mounting will hit the BUG_ON(offset >= folio_size(folio)); in folio_set_bh on the first __bread_gfp call.                                                                                    |
| <a href="#">CVE-2026-97487</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: jfs: handle set_blocksize failures jfs uses buffer_heads, which don't handle block size > PAGE_SIZE well. Without this, mounting we will hit the BUG_ON(offset >= folio_size(folio)); in folio_set_bh on the first __bread_gfp call.                                                                                   |
| <a href="#">CVE-2026-97488</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: qnx4: handle set_blocksize failures qnx4 uses buffer_heads, which don't handle block size > PAGE_SIZE well. Without this, mounting will hit the BUG_ON(offset >= folio_size(folio)); in folio_set_bh on the first __bread_gfp call.                                                                                    |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97489</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: bfs: handle set_blocksize failures bfs uses buffer_heads, which don't handle block size > PAGE_SIZE well. Without this, mounting will hit the BUG_ON(offset >= folio_size(folio)); in folio_set_bh on the first __bread_gfp call.                                                                                      |
| <a href="#">CVE-2026-97490</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: affs: handle set_blocksize failures affs uses buffer_heads, which don't handle block size > PAGE_SIZE well. Without this, mounting we will hit the BUG_ON(offset >= folio_size(folio)); in folio_set_bh on the first __bread_gfp call.                                                                                 |
| <a href="#">CVE-2026-97491</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: net/rds: Don't sleep inside rds_ib_conn_path_shutdown New rds rdma self tests exposed a hang when tearing down the ib network configs. This is caused by the shutdown worker thread sleeping on the wait_event call, which blocks other work items in the queue. Fix this by changing wait_event to wait_event tim...  |
| <a href="#">CVE-2026-97492</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: mac80211: don't call ieee80211_handle_reconfig_failure when not needed In case reconfiguration of NAN fails, we call ieee80211_handle_reconfig_failure, that marks all interfaces as not in the driver. Then, at the error path of the reconfig, cfg80211_shutdown_all_interfaces is called to destroy all th... |
| <a href="#">CVE-2026-97493</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: Bound GPIO I2C table entry count from VBIOS Reject undersized tables and cap the derived entry count to AMDGPU_MAX_I2C_BUS so we do not overrun adev->i2c_bus[] or walk an absurd number of entries on corrupt size fields.                                                                                |
| <a href="#">CVE-2026-97494</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: validate and share PSP fw_pri_buf copies via psp_copy_fw Change psp_copy_fw from void to int: return -ENODEV when drm_dev_enter fails, and -EINVAL when the image size is zero or larger than the 1 MiB PSP private buffer. Replace open-coded memset/memcpy into fw_pri_buf with psp_copy_fw.             |
| <a href="#">CVE-2026-97495</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdkfd: Check bounds on allocate_doorbell allocated_doorbell has an option to set the doorbell id to a specific value (used by CRIU). This value was not bounds checked. Check to confirm it's less than KFD_MAX_NUM_OF_QUEUES_PER_PROCESS.                                                                        |
| <a href="#">CVE-2026-97498</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu/userq: pin mqd and fw object bo to avoid eviction mqd and fw objects are queue core objects which should remain valid and never be unmapped and evicted for user queues to work properly. During eviction if these buffers are evicted the hw continue to use the invalid addresses and caused page fau...  |
| <a href="#">CVE-2026-97499</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: coresight: perf: Retrieve path and source from event data ETM perf callbacks currently use the per-CPU csdev_src pointer, which can race with updates during device registration and unregistration. The AUX setup already builds and stores the path in the event data. Use this path to retrieve the source inst...  |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97500</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: rtw89: phy: check length before parsing PHY status IE Hardware might report PHY status IE with unexpected length, and parser might access out of range. Check the length ahead.                                                                                                                                  |
| <a href="#">CVE-2026-97501</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: pinctrl: mediatek: paris: bypass pinctrl GPIO layer in set GPIO direction pinctrl_gpio_direction_input() / pinctrl_gpio_direction_output() take the pinctrl mutex. This causes a gpiochip operations to need to sleep. Worse yet, the .can_sleep field in the gpiochip is not set. This causes the shared GPIO prox... |
| <a href="#">CVE-2026-97502</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: mmc: davinci: avoid NULL deref of host->data in IRQ handler mmc_davinci_irq() returns early only when both host->cmd and host->data are NULL: if (host->cmd == NULL && host->data == NULL) { ... return IRQ_NONE; } So we may legitimately reach the rest of the handler with host->data ...                           |
| <a href="#">CVE-2026-97503</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: genirq/proc: Size interrupt directory names for 10-digit interrupt numbers /proc/irq/<n>/ directory names are built in `char name[10]` buffers with `sprintf(name, "%u", irq)`. Ten-digit IRQ numbers already need 11 bytes including the trailing NUL, and current sparse-IRQ configurations allow interrupt numb...  |
| <a href="#">CVE-2026-97504</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: watchdog: lenovo_se10_wdt: Fix use-after-free and resource leak risk Review by sashiko.dev highlighted potential use after free and resource leak instances. Set se10_pdev to null to prevent use after free Remove DMI call back and instead directly call se10_create_platform_device. Handle error cases appro...   |
| <a href="#">CVE-2026-97505</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: PCI/sysfs: Add CAP_SYS_ADMIN check to __resource_resize_store() Currently, the __resource_resize_store() allows writing to the resourceN_resize sysfs attribute to change a BAR's size without checking for capabilities, currently relying only on the file access check. Resizing a BAR modifies PCI device conf...  |
| <a href="#">CVE-2026-97506</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: crypto: ixp4xx - fix buffer chain unwind on allocation failure chainup_buffers() builds a linked list of buffer descriptors for a scatterlist. If dma_pool_alloc() fails while constructing the list, the current code sets buf to NULL and later dereferences it unconditionally at the end of the function: bu...    |
| <a href="#">CVE-2026-97507</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: media: dm1105: fix missing error check for dma_alloc_coherent The return value of dm1105_dma_map(), which handles DMA memory allocation, is ignored in dm1105_hw_init(). If dma_alloc_coherent() fails, the driver will proceed using a NULL pointer for DMA transfers, leading to a kernel oops or invalid hardwar... |
| <a href="#">CVE-2026-97510</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: thunderbolt: Release request if tb_cfg_request() fails in __tb_xdomain_response() If tb_cfg_request() fails setting up the request (for example the control channel is shut down already) it returns an error without calling the callback. To avoid leaking that memory, call tb_cfg_request_put() if tb_cfg_reque... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97511</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: mac80211: avoid out-of-bounds access in monitor In NAN, we don't know on what band the frame will be sent. Therefore we set info->band to NUM_NL80211_BANDS. However, this leads to out-of-bound access in ieee80211_add_tx_radiotap_header when we try to access the sbands array. Fix it by not accessing ...  |
| <a href="#">CVE-2026-97512</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: spi: spi-qcom-qspi: Fix incomplete error handling in runtime PM The runtime PM functions had incomplete error handling that could leave the system in an inconsistent state. If any operation failed midway through suspend or resume, some resources would be left in the wrong state while others were already ch... |
| <a href="#">CVE-2026-97514</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: media: chips-media: wave5: Fix Reports from Kernel Lock Validator handle_dynamic_resolution change requires that the state_lock be acquired based on the lockdep_assert_held. However, the handle_dynamic_resolution_change call in initialize_sequence does not properly obtain the lock before calling. Since th...  |
| <a href="#">CVE-2026-97515</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: i3c: master: svc: Prevent IRQ storm from false SLVSTART on NPCM845 On NPCM845, when a target on the I3C bus gets stuck holding SDA low, the controller reports a false Master Request (MR) in-band interrupt event. The driver handles this by emitting a STOP condition to restore the bus. However, the hardware...  |
| <a href="#">CVE-2026-97516</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: rtw88: Add NULL check for chip->edcca_th in rtw_fw_adaptivity_result() It was recently reported that rtw_fw_adaptivity_result() in fw.c dereferences rtwdev->chip->edcca_th without a NULL check. The issue is that devices with the 8821CE chip don't define edcca_th in their chip info. As a result, when ... |
| <a href="#">CVE-2026-97517</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: nl80211: reject beacons with bad HE operation The HE operation element not only needs to be longer than the fixed part, but also have an appropriate size for the variable part inside of it. Check this.                                                                                                        |
| <a href="#">CVE-2026-97518</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: wifi: cfg80211: reject duplicate wiphy cipher suite entries Duplicate entries in wiphy->cipher_suites do not describe any additional capability, but cfg80211 currently accepts them and leaves individual consumers to deal with them. One such consumer is the WEXT compatibility code, which appends a WEP key ...  |
| <a href="#">CVE-2026-97519</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: drm/xe: Fix null pointer dereference in devcoredump cleanup In xe_devcoredump_snapshot_free(), ss->gt may be NULL when the snapshot was never fully populated (e.g., when cleanup is triggered without a prior capture). Guard the xe_guc_capture_put_matched_nodes() call with IS_ERR_OR_NULL() to prevent a null ... |
| <a href="#">CVE-2026-97521</a> | New    |      |     |     |      |                            | In the Linux kernel, the following vulnerability has been resolved: gfs2: fix quota init duplicate scan gfs2_quota_init() checks for duplicate quota_change IDs while holding qd_lock and the quota hash bucket bitlock. That path used gfs2_qd_search_bucket(), which takes a lockref reference via lockref_get_not_dead(). On PREEMPT_RT this may sleep, which is not allowed under ...  |

| ID                                   | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package         | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------------|--------|------|------|-----|------|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97636</a>       | New    |      |      |     |      |                                    | Apache Airflow HashiCorp provider: the HashiCorp Vault secrets backend's team-scope guard can be bypassed with a user-controlled key. In a multi-team deployment, a Dag author scoped to one team can supply a Variable key containing a path separator that causes the backend to resolve a secret belonging to a different team, because after the team-scoped lookup misses the backen... |
| <a href="#">GHSA-g28h-2cm-m-rj9x</a> | New    |      | HIGH |     |      | PyPI:langchain-nvidia-ai-endpoints | ## Summary `langchain-nvidia-ai-endpoints` versions before 1.4.2 accepted local filesystem paths as image inputs for Vision Language Model (VLM) requests. If an application passed attacker-controlled image input to `ChatNVIDIA` or VLM reranking APIs, an attacker could cause files readable by the application process to be read and included in the outbound request to the conf...  |
| <a href="#">MAL-2026-17153</a>       | New    |      |      |     |      | npm:@birbalo/aliftech-ui           | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f6392dad6c7467b1d2b75c329d517982f061f3ca0792b8879b72127813d26aa8) The npm package @birbalo/aliftech-ui@99.9.9 ships a postinstall.js lifecycle script that runs automatically on npm install. The script imports the built-in os and https modules, reads os.hostname() and os.userInfo().user...   |
| <a href="#">MAL-2026-17154</a>       | New    |      |      |     |      | npm:@nf-addons/am-global-header    | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5f4f7297a2ae76eee65506183462a7138df6115ee2bfad9c84878b7f3c7998c8) The package's `install` lifecycle script runs `node index.js`, which loads `runtime/support/telemetry/probe/impl.js`. That module reads `os.userInfo().username`, `os.hostname()`, and `process.cwd()`, concatenates them wi...   |
| <a href="#">MAL-2026-17155</a>       | New    |      |      |     |      | npm:@osl-design/react              | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0a3237fada0f96b2160cb8adea5c7734951ca960f71f3f4bf788fec9446b6d3b) The package declares `"install": "node index.js"` in package.json, so `npm install` automatically executes its top-level script. That script loads `runtime/support/telemetry/probe/impl.js`, which reads the installer's OS...   |
| <a href="#">MAL-2026-17156</a>       | New    |      |      |     |      | npm:aliftech-ui                    | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e61479316af4cfc0884dfe88744a0ed14fa64e052471cc216667c80502689860) postinstall.js runs automatically on npm install and reads os.hostname() and os.userInfo().username, then issues an https.get to a hardcoded webhook.site collector URL (https://webhook.site/539f8bb9-497a-4104-92f7-f95a77...   |
| <a href="#">MAL-2026-17157</a>       | New    |      |      |     |      | npm:eslint-config-compact-base     | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (dbc01e3a8316b2d4e11b34a9c8cbe1cf5bd2af83a6a70052e40a22b54f13f78b) index.js executes on module load and collects host reconnaissance data — os.platform(), os.hostname(), os.userInfo().username, architecture, Node version, current working directory — together with CI-context environment ...   |
| <a href="#">MAL-2026-17158</a>       | New    |      |      |     |      | npm:simple-date-formatter-new-11   | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (10e00618100992f74fd0b4c908be0db1c3e13de1b37ae9dc5952b7836f564042) Package presents itself as a date-formatting utility but performs credential theft against the installer through two channels. The postinstall script in package.json curls cloud instance-metadata endpoints (Alibaba 100.1...   |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package       | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">MAL-2026-17159</a> | New    |      |     |     |      | npm:simple-date-formatter-new-13 | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8f295d4208d67cbb14c8804b287109ad5ed7946e39f0256e601f846e485c6c54) simple-date-formatter-new-13@1.0.0 presents itself as a date-formatting utility but ships a trivial three-line stub while its package.json postinstall script performs an SSRF probe and out-of-band exfiltration on every `... |
| <a href="#">MAL-2026-17160</a> | New    |      |     |     |      | npm:simple-date-formatter-new-14 | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cbe2adf4e9d3b54b33c0e80285a5b0eb4d81dfde75c7a5b7a202ac43793268cd) The package presents itself as a date-formatting utility (index.js is a 160-byte formatDate stub) but the published tarball contains an SSH-key exfiltration payload and an install-time DNS beacon. package.json declares a... |
| <a href="#">MAL-2026-17161</a> | New    |      |     |     |      | npm:simple-date-formatter-new-15 | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (005b96d3c3d5f1a071c40a8b72ea22b5e0221db32cfffacfc8f2343f0ee97eb0) The package's package.json postinstall script curls cloud instance-metadata endpoints (AWS IMDS at 169.254.169.254/latest/meta-data/sts-credential, Alibaba/Tencent metadata at metadata.tencentyun.com and 169.254.0.23) in... |
| <a href="#">MAL-2026-17162</a> | New    |      |     |     |      | npm:simple-date-formatter-new-16 | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5e57e9eff2fae987a2a23e3107d64c818e020b03380e31d6a3ae9cf8d4eb14ec) package.json declares a postinstall lifecycle script that pipes a string-reversed shell one-liner through `rev   bash`, decoding to a bash reverse shell that opens /dev/tcp/124.221.154.135/4444 and attaches an interactiv... |
| <a href="#">MAL-2026-17163</a> | New    |      |     |     |      | npm:analytics-widget             | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4b78f3ed716380da74c5d54de6e24b6b128536a7ce5772e8b05d03108a1d9b74) The package is published as 'analytics-widget' with an empty description, but its main module contains no analytics functionality. On load, index.js schedules a 2-second timer that reads the 'token' key from browser loca... |
| <a href="#">MAL-2026-17164</a> | New    |      |     |     |      | npm:building-build               | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4618f06d0398ff90ef90003464e79f23609a160f4d1606f60cf797fb73fa6dcb) The package's sole content is index.js, which on load schedules a timer that fetches a hardcoded list of privileged same-origin paths (/admin, /dashboard, /flag, /api/flag, /secret, /admin/flag) and POSTs each response b... |
| <a href="#">MAL-2026-17165</a> | New    |      |     |     |      | npm:c2-client                    | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8c5e21fe48a0a1a03a1846e11cb06360950603c3bd8ccba5979c431c84779ba0) The package name is 'c2-client' and package.json declares a postinstall hook that executes 'node setup.js' automatically on npm install. The setup script runs unattended in the installer's environment with the installer'... |
| <a href="#">MAL-2026-17166</a> | New    |      |     |     |      | npm:cache-swipper                | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (50cb98e5f107fe5bd1cd9434505219880014742674def9c64a8ce8552e04a626) cache-swipper advertises itself as a safe cache and build-artifact cleanup utility, but the exported runOperation() function performs an unbounded recursive deletion of the caller's current working directory. On invocati... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                |
|--------------------------------|--------|------|-----|-----|------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">MAL-2026-17167</a> | New    |      |     |     |      | PyPI:prosocks              | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cb2bf0fd5f445eed9825601f2b4497502054176d106d4fecb9eabf38312dd582) prosocks 1.0.25 enrolls the installer's host as a remote-controlled SOCKS5 exit node under a hardcoded control plane at https://kalnetz.store. setup.py's custom install command writes prosocks.bat into the Windows Startu... |
| <a href="#">MAL-2026-17168</a> | New    |      |     |     |      | PyPI:vercel-runtime-python | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f59b48451cf996ea42b291d60ed56205aeb9803222d156f7880fd6b92032b1c6) The package presents itself as a Vercel Python runtime helper but ships no runtime functionality. Its only substantive code path is a public function send_info() that gathers hostname, resolved IP, operating system, and ... |
| <a href="#">MAL-2026-17169</a> | New    |      |     |     |      | npm:@alphaspace/core       | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (42d10ba1427af01794dfb0a6b39a05f969547455e9d86d75f18601b1d035c507) preinstall.js runs unconditionally on npm install and POSTs a JSON payload to a hardcoded Pipedream collector at https://f5778d1d81cc30c39dcdd0da5ca1d49a.m.pipedream.net. The payload includes os.hostname(), os.userInfo()... |
| <a href="#">MAL-2026-17170</a> | New    |      |     |     |      | npm:agency-test-exercise   | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (43eddaf152e2aa60b9f823513a2d9b11fc424a5c44b3c031f6823a48dc2f4e) package.json declares a postinstall hook `wscript.exe 4444.vbs` that fires automatically on `npm install`. The shipped 4444.vbs contains a ~660-entry base64 string array (ArtifactBundleHX) that is reassembled and decrypt...   |
| <a href="#">MAL-2026-17171</a> | New    |      |     |     |      | npm:agency-testts          | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ac3bbe97b41f8d8d1a74e9f369318620c08d648365a4e78d49d1da31d085531d) package.json declares a postinstall lifecycle hook `wscript.exe 4444.vbs` that auto-runs on `npm install` on Windows. The bundled 4444.vbs is a ~674KB script containing large opaque base64 blobs and an AES key/IV pair (`... |
| <a href="#">MAL-2026-17172</a> | New    |      |     |     |      | npm:better-dotenv3         | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f996c75c75423a57a64c1c89b04f2e1ba87674973dba2dd359df5b0937ffe3cf) The package is a dotenv typosquat that runs a hidden Windows loader on every require() and on CLI startup. dist/index.cjs and dist/cli.cjs invoke dispatchAnalytics() unconditionally at module top-level; that routine read... |
| <a href="#">MAL-2026-17173</a> | New    |      |     |     |      | npm:chromatitle            | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (793cf7eb2b4de9c41e229fc89c393e38f05141991762f69f310e1397fa464f9c) chromatitle advertises itself as an ANSI color/title formatting library but its main entry src/index.js unconditionally calls _bootstrap() at top level, transferring control to src/utlis/bootstrap.js. bootstrap.js is a ~... |
| <a href="#">MAL-2026-17174</a> | New    |      |     |     |      | npm:chromatitle-js         | --- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (eff7b9f53e0aed7a8a1c48ae92851ea0ed67b86566d208c78329ecb1b8a73173) src/index.js unconditionally invokes _bootstrap() from src/utlis/bootstrap.js at module load time. bootstrap.js is heavily obfuscated with javascript-obfuscator (400-entry rotating string-array decoder, hex-escaped ident... |

| ID                             | Reason | CVSS | Sev | KEV | EPSS | Vendor / Product / Package    | Description                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------|--------|------|-----|-----|------|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">MAL-2026-17175</a> | New    |      |     |     |      | npm:n8n-nodes-flowstats       | --- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (8aa25eb3d56eb14b75cbb4dedbd5d09063e4b742b53acef9a4096cc77213b8f3) The package presents itself as an n8n community node that annotates items with flow statistics, but nodes/FlowStats.node.js contains two independent attacker-benefiting mechanisms. First, a top-level IIFE runs when the m...   |
| <a href="#">MAL-2026-17176</a> | New    |      |     |     |      | npm:n8n-nodes-moonlet-helpers | --- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (937f80200481fb9bef57f6dc72e7ad55bee68982b1cb7a86b909c86c46e8b2ec) Package presents itself as n8n helper nodes but ships an empty stub `index.js` ( `module.exports = {}` ) and no functional node modules. On `npm install`, `postinstall.js` runs automatically: it performs an HTTPS GET to `h... |
| <a href="#">MAL-2026-17177</a> | New    |      |     |     |      | npm:n8n-nodes-moonlet-utils   | --- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (f49ee5bcbcb7e8f1028de4021134fdbbc895e737700cf82a834fb26d3b23dd05) postinstall.js fetches an opaque binary from https://mkicom.com/.well-known/pki-validation/ct_dn8, writes it to /tmp/.nc, chmods it 0755, and launches it detached via `spawn('/bin/sh', ['-c', 'setsid ' + OUT + '...' &], ...   |
| <a href="#">MAL-2026-17178</a> | New    |      |     |     |      | npm:secure-env3               | --- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (5cb86188f9853b34c6dc3cf9c8259a789920326e8ddf4ae4cd3566385bba3ea1) The package presents itself as a dotenv-style environment loader but ships a Windows dropper that fires automatically on module load and on CLI invocation. Both dist/index.cjs (the package main) and dist/cli.cjs (the bin...   |
| <a href="#">MAL-2026-17179</a> | New    |      |     |     |      | npm:wallet-connect-adapter    | --- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (4135dd91724bdca6fc36f3a49906d219acc67afde7802cb1bd114d128984ca3d) The package's postinstall hook runs `node./loader.js`, which base64-decodes an ~8 KB embedded blob, XOR-decrypts it with a hardcoded 32-byte key, and pipes the resulting bytes into a detached, window-hidden `python -c -`...   |
| <a href="#">MAL-2026-17180</a> | New    |      |     |     |      | PyPI:my-private-pkg           | --- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (d8008c5637dfae2dfc4162f1dd5152c5e90e03b0fc8593fda5055f44e9745b22) setup.py registers a custom install command (PostInstallCommand) that runs my_private_pkg/index.py automatically on `pip install`. That script gathers installer-side identifiers — os.getlogin(), socket.gethostname(), loc...   |

## Significant updates today - original Published Date retained

| ID                             | Reason                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|------------------------------------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-93352</a> | Updated - CVSS changed (9.8 → 9.3) | 9.3  | CRIT |     | 0.006 |                            | Laravel-Mediable 7.0.0 before 7.0.2 contains an incomplete patch for CVE-2026-49972 in which the .pht extension is absent from the forbidden_extensions blocklist in config/mediable.php. The blocklist introduced to address CVE-2026-49972 includes phpt but omits pht, which Apache executes as PHP via the default FilesMatch directive on Debian and Ubuntu systems. An attacker can... |

| ID                             | Reason                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|------------------------------------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-96891</a> | Updated - CVSS changed (9.8 → 9.3) | 9.3  | CRIT |     | 0.007 |                            | A vulnerability was identified in D-Link DIR-825 3.00b32. Affected is the function tunnel_set_params of the file tunnel.c of the component rp-l2tp. The manipulation of the argument peer_hostname leads to out-of-bounds write. The attack may be initiated remotely.                                                                                                                       |
| <a href="#">CVE-2026-97055</a> | Updated - CVSS changed (8.1 → 9.2) | 9.2  | CRIT |     | 0.004 |                            | SigNoz from v0.8.0 before v0.143.0 defaults the JWT tokenizer signing secret (tokenizer::jwt::secret, set via SIGNOZ_TOKENIZER_JWT_SECRET or the deprecated SIGNOZ_JWT_SECRET) to an empty string, and Config.Validate() does not reject the empty value, so a deployment that does not configure a secret starts up and both signs and verifies session tokens with an empty HMAC key. B... |
| <a href="#">CVE-2026-86930</a> | Updated - CVSS added               | 9.1  | CRIT |     | 0.001 |                            | An out-of-bounds read vulnerability in FileMaker Server for Linux allowed an attacker uploading a specially crafted image file to a container field to disclose process memory during thumbnail generation in FileMaker WebDirect. This vulnerability is addressed in FileMaker Server version 26.0.3.                                                                                       |
| <a href="#">CVE-2026-86934</a> | Updated - CVSS added               | 9.1  | CRIT |     | 0.001 |                            | An authorization bypass vulnerability in the FileMaker Server Web Publishing Engine allowed requests containing an extended privilege header to bypass the disabled Custom Web Publishing with XML setting and access the XML Web Publishing interface. This vulnerability is addressed in FileMaker Server version 26.0.3.                                                                  |
| <a href="#">CVE-2026-61652</a> | Updated - CVSS added               | 8.7  | HIGH |     | 0.004 |                            | Zapros, a Python HTTP client, prior to version 0.14.0 is vulnerable to denial of service via memory exhaustion. The issue affects all callers who streamed compressed responses relying on the chunk size — explicit (iter_bytes(chunk_size=...)) or the default — to bound memory. The decoder ignored that bound, so a chunk could be far larger than requested and a single compress...   |
| <a href="#">CVE-2026-86926</a> | Updated - CVSS added               | 7.8  | HIGH |     | 0.002 |                            | A heap buffer overflow vulnerability in the FileMaker Server database engine block parsing routine allowed a maliciously crafted .fmp12 database file to cause memory corruption, potentially leading to arbitrary code execution. This vulnerability is addressed in FileMaker Server version 26.0.3.                                                                                       |
| <a href="#">CVE-2026-97056</a> | Updated - CVSS changed (6.8 → 7.6) | 7.6  | HIGH |     | 0.004 |                            | SigNoz versions from v0.98.0 up to (but not including) v0.143.0, when configured to use the opaque session tokenizer (which was not the default before v0.143.0), do not revoke a user's existing login sessions when the user's password is reset with a reset token (UpdatePasswordByResetPasswordToken, reachable via POST /api/v2/factor_password/reset) or when the user is deleted ... |
| <a href="#">CVE-2026-82356</a> | Updated - CVSS added               | 7.5  | HIGH |     | 0.001 |                            | Imprivata EAM <=26.2.6 lacks the ability to rotate its RSA key pair after deployment when generating an X.509 certificate. Using an RSA key pair indefinitely for certificate generation is against best practices.                                                                                                                                                                          |
| <a href="#">CVE-2026-86938</a> | Updated - CVSS added               | 7.3  | HIGH |     | 0.001 |                            | A DLL hijacking vulnerability in the FileMaker Pro installer for Windows allowed a local user to execute arbitrary code with elevated administrator privileges by placing a malicious DLL file in the installer directory. This vulnerability is addressed in FileMaker Pro version 26.0.3.                                                                                                  |
| <a href="#">CVE-2026-96774</a> | Updated - CVSS changed (5.3 → 6.9) | 6.9  | MEDI |     | 0.003 |                            | A vulnerability was found in SPON Communications IP Network Audio Device XC-9603 1.2.3_20181106 Build 107. This affects the function loadCfg of the file /ini/sys_cfg.txt of the component Configuration File Download. The manipulation results in information disclosure. The attack can be launched remotely. The vendor was contacted early about this disclosure but did not respond... |

| ID                             | Reason                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|------------------------------------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-86867</a> | Updated - CVSS added               | 6.5  | MEDI |     | 0.001 |                            | Cinnamon's Kotaemon (all versions up to and including v0.12.0) multi-user chat interface contains multiple vulnerabilities due to incorrect authorization and improper access controls. There are four handler methods in `libs/ktem/ktem/pages/chat/control.py` that load a Conversation record by its ID without comparing the requester's `user_id` to the conversation's owner `Conve... |
| <a href="#">CVE-2026-59980</a> | Updated - Fix/version updated      | 6.3  | MEDI |     | 0.003 | pip:hpack                  | ### Impact Users of the python-hyper/hpack library, most commonly used as downstream dependency of the python-hyper/h2 library (an HTTP/2 client and server implementation). Unbounded variable integer decoding can cause run-away computation on malformed input leading to O(n^2) runtime, effectively blocking further processing with large enough unsanitized input. ### Patches ...   |
| <a href="#">CVE-2026-96556</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A flaw has been found in Neethuharii CafeManagement. Affected by this vulnerability is the function addcashier of the file AddCashierCode.php. Executing a manipulation of the argument uname/pass/role/status can lead to improper authorization. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this dis... |
| <a href="#">CVE-2026-96601</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability was detected in Abdurrab5 online-makeup-store. This affects an unknown function of the file index.php of the component Admin Login Handler. The manipulation of the argument id/password results in sql injection. The attack can be executed remotely. The exploit is now public and may be used. This product implements a rolling release for ongoing delivery, which ... |
| <a href="#">CVE-2026-96603</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability has been found in Abdurrab5 online-makeup-store. Affected is the function confirm_logged_in/confirm_user of the file functions.php of the component Admin Handler. Such manipulation of the argument adminid leads to missing authorization. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. This product utilizes... |
| <a href="#">CVE-2026-96604</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability was identified in SoftNews Media Group DataLife Engine 18.0. This affects the function strip_data of the file engine/modules/search.php of the component Search Module. The manipulation of the argument story leads to sql injection. The attack can be initiated remotely. The exploit is publicly available and might be used. The vendor was contacted early about th... |
| <a href="#">CVE-2026-96751</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability has been found in pmTicket Project-Management-Software up to 078fa56a782490c5059a0814f84df27984f4d7e2. This affects the function setSync of the file /ajax/add_project.php. Such manipulation of the argument conn_settings leads to sql injection. The attack may be launched remotely. This product operates on a rolling release basis, ensuring continuous delivery. ... |
| <a href="#">CVE-2026-96762</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability was determined in kvcache-ai mooncake up to 0.3.12/0.3.13.post1. This affects the function UnmountSegment of the component RPC Path Handler. This manipulation of the argument client_id/segment_id causes authorization bypass. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted ear... |

| ID                             | Reason                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|------------------------------------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-96772</a> | Updated - CVSS changed (5.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A security flaw has been discovered in Intellian's Subrion CMS up to 4.2.1. This affects an unknown part of the file /actions.json?action=assign-owner. The manipulation of the argument q results in information disclosure. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this dis... |
| <a href="#">CVE-2026-96803</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability was identified in java110 MicroCommunity up to 2.0. Affected is the function QueryServiceSMOImpl.fallBack of the file BusinessApi.java of the component fallBack API Endpoint. Such manipulation of the argument fallBackSql leads to sql injection. The attack may be launched remotely. The exploit is publicly available and might be used. The project was informed o... |
| <a href="#">CVE-2026-96880</a> | Updated - CVSS changed (5.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability was found in TaleLin lin-cms-spring-boot up to 0.2.1. This impacts the function getBook of the file src/main/java/io/github/talelin/latticy/controller/v1/BookController.java of the component book Endpoint. Performing a manipulation of the argument ID results in improper authorization. The attack is possible to be carried out remotely. The exploit has been mad... |
| <a href="#">CVE-2026-96881</a> | Updated - CVSS changed (5.3 → 5.5) | 5.5  | MEDI |     | 0.003 |                            | A vulnerability was determined in TaleLin lin-cms-spring-boot up to 0.2.1. Affected is the function getBooks of the file src/main/java/io/github/talelin/latticy/controller/v1/BookController.java of the component book Endpoint. Executing a manipulation can lead to improper authorization. The attack may be performed from remote. The exploit has been publicly disclosed and may ... |
| <a href="#">CVE-2026-96898</a> | Updated - CVSS changed (7.3 → 5.5) | 5.5  | MEDI |     | 0.004 |                            | A vulnerability was detected in yhx070424 ShopXO up to 2.2.7. Affected by this vulnerability is an unknown functionality of the file config/ueditor.php of the component Ueditor Upload Interface. The manipulation of the argument path_type results in path traversal. It is possible to launch the attack remotely. The exploit is now public and may be used. The project was informe... |
| <a href="#">CVE-2026-96551</a> | Updated - CVSS changed (4.3 → 2.1) | 2.1  | LOW  |     | 0.002 |                            | A vulnerability was determined in sfturing hosp_order up to 627f426331da8086ce8ff2017d65b1ddef384f8. Impacted is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/CommonUserController.java. Executing a manipulation can lead to cross-site request forgery. The attack can be launched remotely. The exploit has been publicly disclosed and may be utilized. Thi...  |
| <a href="#">CVE-2026-96676</a> | Updated - CVSS changed (6.3 → 2.1) | 2.1  | LOW  |     | 0.002 |                            | A vulnerability was identified in Fast FAC1900R 20190827_2.0.2. The impacted element is the function get_alias_name of the component uhttpd. Such manipulation leads to stack-based buffer overflow. The attack may be performed from remote. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond in any way.      |
| <a href="#">CVE-2026-96680</a> | Updated - CVSS changed (4.3 → 2.1) | 2.1  | LOW  |     | 0.003 |                            | A vulnerability was detected in ByteDance Coze Scraper Extension up to 2.0.2. Affected by this vulnerability is the function chrome.runtime.onMessageExternal.addListener of the file static/background/index.js of the component External Message Handler. The manipulation of the argument body.url/paginationConfig/xPathConfig/body.urls/xPaths results in missing authorization. The... |

| ID                             | Reason                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                    |
|--------------------------------|------------------------------------|------|------|-----|-------|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-96739</a> | Updated - CVSS changed (4.3 → 2.1) | 2.1  | LOW  |     | 0.003 |                            | A flaw has been found in SEMCMS up to 4.2. Affected by this issue is some unknown functionality of the file /Edit/php/upload_json.php of the component KindEditor Upload Interface. This manipulation of the argument imgFile causes cross site scripting. The attack may be initiated remotely. The exploit has been published and may be used. The vendor was contacted early about thi...   |
| <a href="#">CVE-2026-96764</a> | Updated - CVSS changed (4.3 → 2.1) | 2.1  | LOW  |     | 0.003 |                            | A weakness has been identified in kvcache-ai mooncake up to 0.3.12/0.3.14-rc1. Impacted is the function MasterService::GetReplicaListByRegex of the component Regular Expression Handler. Executing a manipulation can lead to allocation of resources. The attack may be performed from remote. The exploit has been made available to the public and could be used for attacks. The ven...   |
| <a href="#">CVE-2026-96773</a> | Updated - CVSS changed (4.3 → 2.1) | 2.1  | LOW  |     | 0.003 |                            | A weakness has been identified in Intelliants Subrion CMS up to 4.2.1. This vulnerability affects the function iaUsers::authorize of the file front/login.php of the component Login Page. This manipulation of the argument \$_SERVER['HTTP_REFERER'] causes open redirect. The attack is possible to be carried out remotely. The exploit has been made available to the public and coul...  |
| <a href="#">CVE-2026-96884</a> | Updated - CVSS changed (6.3 → 2.1) | 2.1  | LOW  |     | 0.003 |                            | A security flaw has been discovered in MantisZip up to 0.4.5. Affected by this issue is the function Path.Combine of the file MainWindow.UI.cs of the component Preview. The manipulation results in path traversal. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. The project was informed of the problem early...   |
| <a href="#">CVE-2026-96892</a> | Updated - CVSS changed (4.3 → 2.1) | 2.1  | LOW  |     | 0.003 |                            | A flaw has been found in Edimax BR-6428nC 1.16. The impacted element is the function websRedirect of the component goform Handler. Executing a manipulation of the argument submit-url can lead to open redirect. The attack may be launched remotely. The exploit has been published and may be used. Multiple endpoints are affected. The vendor was contacted early about this disclos...   |
| <a href="#">CVE-2026-96810</a> | Updated - CVSS changed (3.5 → 2.0) | 2.0  | LOW  |     | 0.002 |                            | A vulnerability was identified in huanzi-qch base-admin up to 52816b760cd53244989fd664bbb2b3d4edbfdbf1. This issue affects the function Save of the file base-admin-master\src\main\java\cn\huanzi\qch\baseadmin\common\controller\C commonController.java of the component Add User Handler. The manipulation of the argument Username leads to cross site scripting. The attack can be in... |
| <a href="#">CVE-2026-96552</a> | Updated - CVSS changed (3.1 → 1.3) | 1.3  | LOW  |     | 0.002 |                            | A vulnerability was identified in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The affected element is the function MD5.getMD5 of the file ssm_pro/src/main/java/cn/sfturing/utills/MD5.java of the component User Password Handler. The manipulation leads to one-way hash without salt. The attack may be initiated remotely. A high degree of complexity is need...  |
| <a href="#">CVE-2026-59167</a> | Updated - Fix/version updated      |      | CRIT |     | 0.004 | npm:suneditor              | ## Summary SUNEDITOR `v2.47.10` appears to allow JavaScript execution through crafted namespaced HTML elements. The sanitization logic does not fully remove executable event-handler attributes from certain custom/namespaced tags. As a result, an attacker may be able to inject HTML content that executes JavaScript when the rendered element is interacted with. This behavior...      |

| ID                             | Reason                        | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|-------------------------------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-62998</a> | Updated - Fix/version updated |      |      |     | 0.003 | composer:redaxo/source     | ### Summary The `rex_list` component reads the SQL sort column directly from the `sort` GET parameter without validating it against the set of columns declared sortable via `setColumnSortable()`. Although the value is wrapped in backticks via `escapeldentifier()` (preventing classical SQL injection), this still allows any authenticated backend user to ORDER BY any column in ... |
| <a href="#">CVE-2026-92164</a> | Updated - Fix/version updated |      | MODE |     | 0.003 | pip:streamlink             | ## Summary `HTTPSession` mounts a `FileAdapter` for the `file://` scheme and inherits redirect handling unchanged from `requests.Session`. `requests` does not check for scheme downgrades or cross-protocol transitions when it follows a redirect, so any http(s) request Streamlink makes can be redirected by the remote server into `file:///...` and the local file is returned as...  |

## Added to CISA KEV today

| ID                             | Reason       | CVSS | Sev | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                           |
|--------------------------------|--------------|------|-----|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-5430</a>  | Added to KEV |      |     | Yes | 0.004 | wso2:multiple products     | WSO2 API Control Plane, API Manager, Traffic Manager & Universal Gateway contain a path traversal vulnerability that could allow for unrestricted file upload and lead to remote code execution.                      |
| <a href="#">CVE-2026-71362</a> | Added to KEV |      |     | Yes | 0.023 | adobe:commerce and magento | Adobe Commerce and Magento contains an incorrect authorization vulnerability that could allow an attacker to leverage this vulnerability to gain elevated access to sensitive resources without any user interaction. |

## P1 new today

None in this window.

## P2 new today

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package                              | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|---------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-61732</a> | New    | 10.0 | CRIT |     |      | pip:decepticon, pip:decepticon-core, pip:decepticon-sdk | Decepticon is an autonomous hacking agent for red teams. Versions prior to 1.1.17 wrap web crawl results — the output of agent reconnaissance against target services — into LLM messages without neutralizing ChatML special-token literals. Under the BYOK (Bring Your Own Key) deployment model, users configure their own LLM credentials to any OpenAI-compatible endpoint. Most ope... |
| <a href="#">CVE-2026-97359</a> | New    | 10.0 | CRIT |     |      |                                                         | HFS2 version 2.4.0 and earlier contains a template injection vulnerability in the multipart upload handler that allows unauthenticated attackers to achieve remote code execution by embedding malicious template syntax in a filename. Attackers can craft a filename containing a closing template quoting sequence followed by an exec macro, which bypasses the authorization check i... |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------|--------|------|------|-----|-------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97360</a> | New    | 10.0 | CRIT |     |       |                            | HFS2 version 2.4.0 and earlier contains an unauthenticated arbitrary file access vulnerability that allows unauthenticated attackers to read, write, append, and delete files anywhere the HFS service account has filesystem access outside the shared folder. Attackers can exploit the macro dispatcher's lack of authorization model combined with the path resolver's failure to con...  |
| <a href="#">CVE-2026-19072</a> | New    | 9.9  | CRIT |     |       |                            | Velociraptor stores the compiled VQL in the hunt object internally to avoid having to recompile the artifacts for each endpoint in the hunt. Although the field "compiled_collector_args" is an internal field, Velociraptor allowed the field to be set from a user API call. This allows another user who can schedule a hunt (minimal role of "investigator" ) to set the compiled VQL...  |
| <a href="#">CVE-2026-93425</a> | New    | 9.9  | CRIT |     |       |                            | Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the patch.readRepoDirectories tRPC procedure passes the user-controlled repoPath value from apps/dokploy/server/api/routers/patch.ts into a shell command in packages/server/src/services/patch-repo.ts without safe argument quoting. An authenticated organization member with service:read permission...  |
| <a href="#">CVE-2026-12227</a> | New    | 9.8  | CRIT |     | 0.008 |                            | The Visual Composer Website Builder plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 45.16.0 via the `vcv-template` parameter. This makes it possible for unauthenticated attackers to include and execute arbitrary files on the server, allowing the execution of any PHP code in those files. This can be used to bypass access contro...  |
| <a href="#">CVE-2026-13249</a> | New    | 9.8  | CRIT |     |       |                            | An unauthenticated Remote Code Execution via Arbitrary File Upload vulnerability in the web management interface in Honeywell PD45 Industrial Printer version F10.19.010040, allows upload of attacker controlled files without requiring authentication. An attacker could potentially exploit this vulnerability, leading to the execution of malicious files and commands. Honeywell...    |
| <a href="#">CVE-2026-78308</a> | New    | 9.8  | CRIT |     | 0.003 |                            | Improper Authentication vulnerability in DIAEnergie allows Authentication Bypass. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                          |
| <a href="#">CVE-2026-93207</a> | New    | 9.8  | CRIT |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: SUNRPC: Zero rpc_gss_wire_cred at svcauth_gss_decode_credbody() entry<br>svcauth_gss_decode_credbody() writes the caller's rpc_gss_wire_cred field by field and assigns gc_ctx.len only on the success tail. The caller storage is svcdata->clcred, which lives in the per-svc_rqst gss_svc_data and is reused across...  |
| <a href="#">CVE-2026-97413</a> | New    | 9.8  | CRIT |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: RDMA/rtrs-srv: Fix integer underflow in process_read and process_write<br>usr_len is read from a network-supplied message field (le16_to_cpu) and used to compute data_len = off - usr_len without validating that usr_len <= off. A malicious RDMA client can send usr_len > off causing an integer underflow, result... |
| <a href="#">CVE-2026-81549</a> | New    | 9.6  | CRIT |     |       |                            | IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of the X-Forwarded-Proto header.                                                                                                                                                                                                           |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS | Vendor / Product / Package                                                                                               | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|------|--------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-13016</a> | New    | 9.3  | CRIT |     |      |                                                                                                                          | ServiceNow has remediated a SQL injection vulnerability that was identified in the ServiceNow AI Platform. This vulnerability could enable an unauthenticated user, in certain circumstances, to execute arbitrary SQL statements against the instance's underlying database and gain access to, or modify, instance data beyond what was intended. ServiceNow deployed a security ...       |
| <a href="#">CVE-2026-61604</a> | New    | 9.3  | CRIT |     |      | go:github.com/ixofoundation/ixo-blockchain, go:github.com/ixofoundation/ixo-blockchain/v3, go:github.com/ixofoundation/i | The ixo Blockchain is a Layer 1 blockchain that runs on both Testnet and Mainnet. Prior to version 8.0.0, the x/bonds module moved funds from an address that was resolved from a DID verification method, without verifying that the resolved address belonged to the transaction signer. Affected handlers included MsgMakeOutcomePayment, MsgBuy, MsgSell, MsgSwap, and MsgWithdrawSha... |
| <a href="#">CVE-2026-61741</a> | New    | 9.3  | CRIT |     |      | maven:org.http4s:http4s-scala-xml_2.12, maven:org.http4s:http4s-scala-xml_2.13, maven:org.http4s:http4s-scala-xml_3      | http4s-scala-xml provides `EntityDecoder[F, scala.xml.Elem]` instances that parse XML message bodies. Prior to versions 0.24.1 and 1.0.0-M39, these decoders used a `javax.xml.parsers.SAXParserFactory` obtained from `SAXParserFactory.newInstance` without any security configuration. With the JDK's default settings, the parser resolves DOCTYPE declarations, external general an...  |
| <a href="#">CVE-2026-61742</a> | New    | 9.3  | CRIT |     |      | npm:@bytebase/dbhub                                                                                                      | DBHub is a database MCP server for Postgres, MySQL, SQL Server, Oracle, MariaDB, SQLite. Versions prior to 0.22.5 expose an unauthenticated HTTP MCP endpoint when started with the documented HTTP transport mode, for example `--transport http --port 8080`. The HTTP server attempts to protect browser-origin access by checking whether the `Origin` hostname equals the `Host` hos... |
| <a href="#">CVE-2026-86860</a> | New    | 9.3  | CRIT |     |      |                                                                                                                          | ServiceNow has remediated a missing authorization vulnerability that was identified in the ServiceNow AI Platform. This vulnerability could enable an unauthenticated user, in certain circumstances, to extract instance data beyond what was intended, resulting in privilege escalation. ServiceNow deployed a security update to hosted instances and ServiceNow provided the up...      |
| <a href="#">CVE-2026-91187</a> | New    | 9.3  | CRIT |     |      |                                                                                                                          | Improper Verification of Cryptographic Signature vulnerability in dashbit nimble_zta allows an unauthenticated remote attacker to authenticate as an arbitrary Cloudflare service token. Applications using the Cloudflare Zero Trust authentication strategy are affected. verify_token/2 in lib/nimble_zta/cloudflare.ex matches the result of JOSE.JWT.verify/2 against {_, token, _s...  |
| <a href="#">CVE-2026-93291</a> | New    | 9.3  | CRIT |     |      |                                                                                                                          | Omni C20 lacks proper certificate validation which could allow an attacker to perform a man-in-the-middle attack which could allow them to execute arbitrary code.                                                                                                                                                                                                                           |
| <a href="#">CVE-2026-81630</a> | New    | 9.2  | CRIT |     |      |                                                                                                                          | The Botslab G980H dash camera firmware does not adequately verify the authenticity of firmware updates. The update process retrieves firmware through an unprotected connection and relies on an integrity value supplied with the firmware instead of a trusted cryptographic signature. A suitably positioned attacker who intercepts a firmware download, or an authenticated attacker... |
| <a href="#">CVE-2026-90481</a> | New    | 9.2  | CRIT |     |      |                                                                                                                          | In PortSwigger Burp Suite DAST (formerly Burp Suite Enterprise Edition) before 2026.8, an authentication bypass can occur via an alternate path or channel.                                                                                                                                                                                                                                  |

| ID                             | Reason | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                  |
|--------------------------------|--------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-97404</a> | New    | 9.2  | CRIT |     |       |                            | In OpenStack Zaqar before 22.0.2, WSGI transport mishandles the URL-Signature header. By sending a request with an empty URL-Signature header, an unauthenticated remote attacker who knows a target project's UUID may bypass both Keystone authentication and pre-signed URL verification, resulting in the ability to read, enumerate, create, and delete that project's queues, messa... |
| <a href="#">CVE-2026-78312</a> | New    | 9.1  | CRIT |     | 0.003 |                            | Path Traversal in DIAEnergie. This issue affects DIAEnergie: before 1.11.00.022.                                                                                                                                                                                                                                                                                                             |
| <a href="#">CVE-2026-79766</a> | New    | 9.1  | CRIT |     |       |                            | Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. From 2.4.1 until 2.5.1, an authenticated Termix administrator can store attacker-controlled domain and email values through PATCH /users/acme-ssl-settings and trigger their interpolation into a certbot shell command through POST /users/acme-ssl-request. In src/backen... |
| <a href="#">CVE-2026-93228</a> | New    | 9.1  | CRIT |     |       |                            | In the Linux kernel, the following vulnerability has been resolved: svcrdma: Reject Write/Reply chunks with segcount 0 A peer can send a Write or Reply chunk whose segcount field is zero. xdr_check_write_chunk() only rejects segcount > rc_maxpages, so zero passes the range check, and xdr_inline_decode(stream, 0) returns the current (non-NULL) cursor without advancing. The ...   |
| <a href="#">CVE-2026-93289</a> | New    | 9.0  | CRIT |     |       |                            | The affected products are vulnerable to command injection attack that could allow an unauthenticated attacker to execute system commands during the pairing process.                                                                                                                                                                                                                         |

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.